信息系统和组织的风险管理框架

安全与隐私的系统生命周期方法

本出版物对风险管理框架进行了全面更新。更新内容包括：与 NIST 网络安全框架中的结构保持一致；整合隐私风险管理流程；与系统生命周期安全工程流程保持一致；以及纳入供应链风险管理流程。组织可以在 RMF 内以互补的方式使用这些框架和流程，以有效管理对组织运营和资产、个人、其他组织和国家的隐私和安全风险。修订版 2 包括一组组织范围的 RMF 任务，旨在帮助信息系统所有者做好开展系统级风险管理活动的准备。其目的是通过在组织任务和业务功能之间建立更紧密的联系，并改善高级领导者、管理者和操作人员之间的沟通，来提高 RMF 的有效性、效率和成本效益。

联合工作组

本出版物可免费下载：

https://doi.org/10.6028/NIST.SP.800-37r2

2018 年 12 月

美国商务部

Wilbur L. Ross, Jr.，部长

国家标准与技术研究院

Walter Copan，NIST 院长兼商务部标准与技术副部长

授权

本出版物由 NIST 制定，旨在进一步履行其在《联邦信息安全现代化法案》(FISMA)、44 U.S.C. § 3551 等、公法 (P.L.) 113-283 下的法定职责。NIST 负责制定信息安全标准和指南，包括联邦信息系统的最低要求，但此类标准和指南未经管理此类系统的适当联邦官员明确批准，不适用于国家安全系统。本指南与管理与预算办公室 (OMB) A-130 通告的要求一致。

本出版物中的任何内容均不得被视为与商务部部长根据法定授权对联邦机构强制并具有约束力的标准和指南相矛盾。这些指南也不得解释为改变或取代商务部部长、OMB 主任或任何其他联邦官员的现有权限。本出版物可供非政府组织自愿使用，在美国不受版权保护。但是，NIST 希望得到致谢。

国家标准与技术研究院特别出版物 800-37，修订版 2
Natl. Inst. Stand. Technol. Spec. Publ. 800-37, Rev. 2, 183 页 (2018 年 12 月)

CODEN: NSPUE2

本出版物可免费下载：

https://doi.org/10.6028/NIST.SP.800-37r2

本文件中可能会识别某些商业实体、设备或材料，以充分描述实验程序或概念。此类识别并不意味着 NIST 的推荐或认可，也不意味着这些实体、材料或设备必然是可用的最佳选择。

本出版物可能会引用 NIST 根据其分配的法定职责正在开发的其他出版物。本出版物中的信息（包括概念、实践和方法）即使在此类配套出版物完成之前，也可供联邦机构使用。因此，在每份出版物完成之前，当前的要求、指南和程序（如存在）仍然有效。为了规划和过渡目的，联邦机构可能希望密切关注 NIST 这些新出版物的开发。

鼓励组织在指定的公众评论期间审查草案出版物，并向 NIST 提供反馈。除上述出版物外，许多 NIST 出版物可在 https://csrc.nist.gov/publications 获取。

关于本出版物的评论可提交至：

国家标准与技术研究院
注意：信息技术实验室，计算机安全部门
100 Bureau Drive (Mail Stop 8930)
Gaithersburg, MD 20899-8930
电子邮件：sec-cert@nist.gov

所有评论均须根据《信息自由法案》(FOIA) 发布。

计算机系统技术报告

国家标准与技术研究院 (NIST) 信息技术实验室 (ITL) 通过为国家的测量和标准基础设施提供技术领导力，促进美国经济和公共福利。ITL 开发测试、测试方法、参考数据、概念验证实施和技术分析，以推进信息技术的开发和生产性使用。ITL 的职责包括为联邦信息系统中非国家安全相关信息的成本效益安全开发管理、行政、技术和物理标准及指南。特别出版物 800 系列报告 ITL 在信息系统安全和隐私方面的研究、指南和宣传工作，以及与工业界、政府和学术组织的合作活动。

摘要

本出版物描述了风险管理框架 (RMF)，并提供了将 RMF 应用于信息系统和组织的指南。RMF 为管理安全和隐私风险提供了严谨、结构化和灵活的流程，包括信息安全分类；控制选择、实施和评估；系统和公共控制授权；以及持续监控。RMF 包括准备组织在适当风险管理级别执行框架的活动。RMF 还通过实施持续监控流程促进近乎实时的风险管理和持续的信息系统及公共控制授权；为高级领导者和高管提供必要信息，使其能够就支持其任务和业务功能的系统做出高效、具有成本效益的风险管理决策；并将安全性和隐私性纳入系统开发生命周期。执行 RMF 任务将系统级的重要风险管理流程与组织级的风险管理流程联系起来。此外，它还明确了组织信息系统内实施的控制以及这些系统继承的控制的责任和问责制。

关键词

评估；运营授权；使用授权；授权官员；分类；公共控制；公共控制授权；公共控制提供者；持续监控；控制评估员；控制基线；网络安全框架配置文件；混合控制；信息所有者或管理者；信息安全；监控；持续授权；行动计划和里程碑；隐私；隐私评估报告；隐私控制；隐私计划；隐私风险；风险评估；风险执行功能；风险管理；风险管理框架；安全；安全评估报告；安全控制；安全工程；安全计

划；安全风险；高级机构信息安全官；高级机构隐私官；供应链风险管理；系统开发生命周期；系统所有者；系统隐私官；系统安全官；系统特定控制。

致谢

本出版物由联合工作组机构间工作组开发。该小组包括来自民事、国防和情报界的代表。国家标准与技术研究院希望感谢来自商务部和国防部、国家情报总监办公室、国家信息安全系统的委员会的高级领导者，以及机构间工作组的成员，他们的奉献努力对本出版物的贡献重大。

国防部

- **Dana Deasy** - 首席信息官
- **Essye B. Miller** - 首席信息官主要副手兼国防部高级信息安全官
- **Thomas P. Michelli** - 网络安全代理副首席信息官
- **Vicki Michetti** - 网络安全政策、战略、国际和国防工业基地理事会理事

国家标准与技术研究院

- **Charles H. Romine** - 信息技术实验室主任
- **Donna Dodson** - 信息技术实验室网络安全顾问
- **Matt Scholl** - 计算机安全部门 chief
- **Kevin Stine** - 应用网络安全部门 chief
- **Ron Ross** - FISMA 实施项目负责人

国家情报总监办公室

- **John Sherman** - 首席信息官
- **Vacant** - 副首席信息官
- **Susan Dorr** - 网络安全部门主任兼首席信息安全官
- **Wallace Coggins** - 安全协调中心主任

国家信息安全系统委员会

- **Thomas Michelli** - 主席——国防界
- **Susan Dorr**——情报界联合主席
- **Vicki Michetti**——国防界三主席
- **Chris Johnson**——情报界三主席
- **Paul Cunningham**——民事机构三主席

联合工作组工作组

- **Ron Ross** - NIST，JTF 负责人
- **Taylor Roberts** - OMB
- **Jordan Burris** - OMB
- **Jeff Marron** - NIST
- **Dorian Pappas** - CNSS
- **Daniel Faigin** - 航空航天公司
- **Kevin Dulany** - 国防部
- **Ellen Nadeau** - NIST
- **Charles Cutshall** - OMB
- **Kaitlin Boeckl** - NIST
- **Dominic Cussatt** - 退伍军人事务部
- **Christina Sames** - MITRE 公司

- **Peter Duspiva** - 情报界
- **Victoria Pillitteri** - NIST
- **Kevin Herms** - OMB
- **Kirsten Moncada** - OMB
- **Esten Porter** - MITRE 公司
- **Julie Snyder** - MITRE 公司
- **Kelley Dempsey** - NIST
- **Naomi Lefkovitz** - NIST
- **Carol Bales** - OMB
- **Jon Boyens** - NIST
- **Celia Paulsen** - NIST
- **Martin Stanley** - 国土安全部

作者还要感谢 Matt Barrett、Kathleen Coupe、Jeff Eisensmith、Chris Enloe、Ned Goren、Matthew Halstead、Jody Jacobs、Ralph Jones、Martin Kihiko、Raquel Leone，以及计算机安全部门和应用网络安全部门的科学家、工程师和研究工作人员，他们在帮助改进出版物内容方面做出了卓越贡献。特别感谢 Jim Foti 和 NIST 网络团队的出色行政支持。

此外，作者希望感谢美国空军和"RMF Next"计划，该计划由空军 CyberWorx 促进，为 RMF 本次更新中的一些新想法提供了灵感。该工作组由 Lauren Knausenberger、Bill Bryant 和 Venice Goodwine 领导，包括政府和行业代表 Jake Ames、Chris Bailey、James Barnett、Steve Bogue、Wes Chiu、Kurt Danis、Shane Deichman；Joe Erskine、Terence Goodman、Jason Howe、Brandon Howell、Todd Jacobs、Peter Klabe、William Kramer、Bryon Kroger、Kevin LaSalle、Dinh Le、Noam Liran、Sam Miles、Michael Morrison、Raymond Tom Nagley、Wendy Nather、Jasmine Neal、Ryan Perry、Eugene Peterson、Lawrence Rampaul、Jessica Rheinschmidt、Greg Roman、Susanna Scarveles、Justin Schoenthal、Christian Sorenson、Stacy Studstill、Charles Wade、Shawn Whitney、David Wilcox 和 Thomas Woodring。

最后，作者还衷心感谢来自公共和私营部门、国内和国际的个人和组织的重大贡献，他们深思熟虑和建设性的意见提高了本出版物的整体质量、彻底性和实用性。

对 NIST 特别出版物 800-37 的历史贡献

作者感谢自 2005 年特别出版物 800-37 开始以来为先前版本做出贡献的许多人。他们包括 Marshall Abrams、William Barker、Beckie Koonge、Roger Caslow、John Gilligan、Peter Gouldmann、Richard Graubart、John Grimes、Gus Guissanie、Priscilla Guthrie、Jennifer Fabius、Cita Furlani、Richard Hale、Peggy Himes、William Hunteman、Arnold Johnson、Donald Jones、Stuart Katzke、Eustace King、Mark Morrison、Sherrill Nicely、Karen Quigg、George Rogers、Cheryl Roby、Gary Stoneburner、Marianne Swanson、Glenda Turner 和 Peter Williams。

执行摘要

随着我们将计算机推向"边缘"，构建一个相互连接的信息系统和设备的复杂世界，安全和隐私风险（包括供应链风险）继续成为全国对话的重要部分和重要议题。公共和私营部门（包括美国关键基础设施）内硬件、软件、固件和系统的复杂性显著增加，代表了攻击面的显著增加，可能被对手利用。此外，对手正在使用供应链作为攻击载体和渗透我们系统、破坏系统元素完整性并获得关键资产访问权限的有效手段。

国防科学委员会报告《弹性军事系统和高级网络威胁》[DSB 2013] 对美国政府、美国关键基础设施以及支持公共和私营部门任务基本运营和资产的系统的脆弱性提供了令人清醒的评估。

> ".....工作组指出，对美国关键基础设施的网络威胁正超过减少普遍脆弱性的努力，因此在未来至少十年内，美国必须严重依赖威慑来应对来自美国最强大对手的网络威胁。显然，迫切需要采取更主动和系统的方法来处理美国网络威慑....."

迫切需要进一步加强我们在关键基础设施每个部门所依赖的基础信息系统、组件产品和服务——确保系统、产品和服务在系统开发生命周期 (SDLC) 中足够可信，并能够提供必要的弹性以支持美国的经济和国家安全利益。系统现代化、自动化的增加使用，以及联邦系统和网络的整合、标准化和优化以加强高价值资产的保护 [OMB M-19-03]，是联邦政府的关键目标。

行政命令 (E.O.) 13800《加强联邦网络和关键基础设施的网络安全》[EO 13800] 认识到联邦信息系统日益增强的互联性，要求机构负责人确保不仅为联邦机构的企业，而且为整个行政部门进行适当的风险管理。该行政命令指出：

> ".....行政部门代表美国人民运营其信息技术 (IT)。其 IT 和数据应使用所有美国政府能力负责任地保护....."

> ".....网络安全风险管理包括为保护 IT 和数据免受未经授权的访问和其他网络威胁、保持对网络威胁的认识、检测对 IT 和数据产生不利影响的事件和异常，以及减轻、响应和从事件中恢复而采取的全部活动....."

OMB 备忘录 M-17-25《关于加强联邦网络和关键基础设施网络安全的行政命令的报告指南》[OMB M-17-25] 为联邦机构实施 E.O. 13800 提供了实施指南。该备忘录指出：

> ".....有效的企业风险管理计划促进了对可能影响机构任务和服务交付的潜在风险的认识和描述的共同理解。此类风险包括但不限于战略、市场、网络、法律、声誉、政治以及广泛的操作风险，如信息安全、人力资本、业务连续性和相关风险....."

> ".....有效的网络安全风险管理要求机构将信息安全管理流程与战略、运营和预算规划流程保持一致....."

OMB 通告 A-130《将信息作为战略资源进行管理》[OMB A-130] 涉及保护联邦信息资源和管理个人身份信息 (PII) 的职责。通告 A-130 要求机构实施本指南中描述的 RMF，并要求机构将隐私整合到 RMF 流程中。在建立信息安全计划和隐私计划的要求时，OMB 通告强调两个计划需要就共同目标进行协作：

> "虽然安全和隐私是独立且不同的学科，但它们密切相关，机构必须采取协调方法来识别和管理安全和隐私风险并遵守适用要求.....。"

NIST 特别出版物 800-37（修订版 2）的本次更新响应了国防科学委员会、行政命令和 OMB 政策备忘录的号召，为信息系统、组织和个人开发下一代风险管理框架 (RMF)。

本次更新有七个主要目标：

1. **提供更紧密的联系和沟通**：在组织的 C 套件或治理层面的风险管理流程与活动和组织系统和操作层面的个人、流程与活动之间
2. **制度化关键风险管理准备活动**：在所有风险管理层面，以促进更有效、高效和具有成本效益的 RMF 执行
3. **展示 NIST 网络安全框架如何与 RMF 保持一致**：并使用既定的 NIST 风险管理流程实施
4. **将隐私风险管理流程整合到 RMF 中**：以更好地支持隐私计划负责的隐私保护需求
5. **促进可信安全软件和系统的开发**：通过将 NIST 特别出版物 800-160 第 1 卷中基于生命周期的系统工程流程与 RMF 中的相关任务保持一致
6. **将安全相关的供应链风险管理 (SCRM) 概念整合到 RMF 中**：以应对不可信的供应商、假冒产品的插入、篡改、未经授权的生产、盗窃、恶意代码的插入以及整个 SDLC 中糟糕的制造和开发实践
7. **允许组织生成的控制选择方法**：以补充传统的基线控制选择方法，并支持在 NIST 特别出版物 800-53 修订版 5 中使用整合的控制目录

准备步骤的添加是 RMF 的关键变化之一——旨在实现更有效、高效和具有成本效益的安全和隐私风险管理流程。制度化组织级和系统级准备的主要目标是：

- 促进组织层面和任务/业务流程层面的高级领导者和高管与操作层面的系统所有者之间的有效沟通

- 促进组织范围内公共控制的识别和组织定制控制基线的开发，减少单个系统所有者工作量和系统开发及资产保护成本
- 使用企业架构概念和模型减少信息技术 (IT) 和操作技术 (OT) 基础设施的复杂性，以整合、优化和标准化组织系统、应用程序和服务
- 通过消除不解决安全和隐私风险的不必要功能和安全隐私能力来降低系统复杂性
- 识别、优先排序和集中资源于组织的高价值资产 (HVA)，这些资产需要增加保护级别——采取与这些资产风险相称的措施

通过实现上述目标，组织可以简化 RMF 执行，采用创新方法来管理风险，并在执行特定任务时提高自动化水平。实施 RMF 的组织将能够：

- 使用组织级和系统级准备步骤的任务和输出，在组织内促进一致的开始点来执行 RMF
- 最大化使用组织级的公共控制，促进标准化、一致和具有成本效益的安全和隐私能力继承
- 最大化使用共享或基于云的系统、服务和应用程序，以减少整个组织所需的授权数量
- 采用组织定制的控制基线，提高安全和隐私计划开发的速度以及安全和隐私计划内容的一致性
- 采用基于从系统安全工程流程生成的安全和隐私要求的组织定义控制
- 最大化使用自动化工具来管理安全分类；控制选择、评估和监控；以及授权流程
- 减少低影响系统的工作量和资源支出（如果这些系统无法通过系统连接对更高影响系统产生不利影响）
- 最大化重复使用 RMF 工件（例如，安全和隐私评估结果），用于标准化硬件/软件部署，包括配置设置
- 通过消除不必要的系统、系统组件和服务来减少 IT/OT 基础设施的复杂性——采用最少功能原则
- 将过渡到持续授权作为优先事项，并使用持续监控方法来降低安全和隐私计划的成本并提高效率

认识到 RMF 执行的准备可能因组织而异，实现上述目标可以减少组织的整体 IT/OT 足迹和攻击面，促进 IT 现代化目标，节约资源，优先考虑安全活动以将保护策略集中在最关键的资产和系统上，并促进对个人的隐私保护。

共同的安全和隐私风险基础

在制定标准和指南时，NIST 与联邦机构、州、地方和部落政府以及私营部门组织协商；避免不必要的和昂贵的重复工作；并确保其出版物与用于保护国家安全系统的标准和指南互补。除了对其出版物实施透明的公开审查流程外，NIST 还与管理和预算办公室、国家情报总监办公室、国防部和国家信息安全系统委员会合作，并为联邦政府建立了统一的风险管理框架。这一共同基础为联邦政府的民事、国防和情报界及其承包商提供了具有成本效益、灵活和一致的方法和技术，以管理对组织运营和资产、个人、其他组织和国家的安全和隐私风险。统一框架还为评估结果和授权决定的相互接受提供了坚实基础，并促进了信息共享和协作。NIST 继续与公共和私营部门实体合作，建立其安全和隐私标准与指南与外部组织开发的标准与指南之间的映射和关系。

接受安全和隐私风险

风险管理框架从两个角度解决安全和隐私风险——信息系统角度和公共控制角度。对于信息系统，授权官员发布系统运营授权或使用授权，接受对组织运营和资产、个人、其他组织和国家的安全和隐私风险。对于公共控制，授权官员发布特定控制集的公共控制授权，这些控制可由指定的组织系统继承，接受对组织运营和资产、个人、其他组织和国家的安全和隐私风险。授权官员在系统授权时也考虑继承公共控制的风险。附录 F 中描述了不同类型的授权。

RMF 与技术无关

RMF 被有意设计为与技术无关，因此该方法可以应用于任何类型的信息系统*而无需修改。虽然特定控制的选择、控制实施细节以及控制评估方法和对象可能因不同类型的 IT 资源而异，但无需调整 RMF 流程以适应特定技术。

所有信息系统都处理、存储或传输某种类型的信息。例如，由传感器收集并传输到监控站的远程设施温度信息、通过无线电传输到武器系统控制器的位置坐标、通过远程摄像头（陆地/卫星）传输到服务器的摄影图像，或通过医院网络传输患者信息的健康 IT 设备，都需要保护。可以通过以下方式保护这些信息：对信息进行分类以确定丢失的影响；评估信息处理是否可能影响个人隐私；以及选择并实施适用于所用 IT 资源的控制。因此，基于云的系统、工业/过程控制系统、武器系统、网络物理系统、应用程序、物联网设备或移动设备/系统不需要单独的风险管理流程，而是需要通过应用现有 RMF 流程确定的一组定制控制和具体实施细节。

RMF 在任何类型的系统开发方法（包括敏捷和 DevOps 方法）的系统开发生命周期内迭代应用（如适用）。随着整个生命周期的开发进展，实施、验证和确认安全和隐私要求和控制。这种灵活性使 RMF 能够支持快速技术周期、创新以及系统和系统组件开发中当前最佳实践的使用。

> *注意：本出版物涉及信息系统，这是为收集、处理、维护、使用、共享、传播或处置信息而组织的一组离散信息资源，无论此类信息是数字形式还是非数字形式。信息资源包括信息和相关资源，如人员、设备、资金和信息技术。因此，信息系统可能包括也可能不包括硬件、固件和软件。

自动化在 RMF 执行中的使用

组织应尽可能最大化使用自动化，以提高执行风险管理框架 (RMF) 步骤的速度、有效性和效率。自动化在控制和持续监控的评估、授权包的准备以进行及时决策以及持续授权方法的实施中特别有用——共同促进高级领导者的实时或近乎实时的基于风险的决策流程。组织在决定何时、何地以及如何在其安全和隐私计划中使用自动化或自动支持工具方面具有相当大的灵活性。在某些情况下，可能无法或不可行进行自动化评估和监控控制。

范围和适用性

本出版物旨在帮助组织管理安全和隐私风险，并满足《2014 年联邦信息安全现代化法案》(FISMA)、《1974 年隐私法案》、OMB 政策和联邦信息处理标准等法律、法规和政策中的要求。本出版物的范围涉及联邦信息系统，这是为收集、处理、维护、使用、共享、传播或处置信息而组织的一组离散信息资源，无论此类信息是数字形式还是非数字形式。信息资源包括信息和相关资源，如人员、设备、资金和信息技术。

虽然联邦政府使用是强制性的，但 RMF 可应用于任何类型的非联邦组织（例如，企业、工业、学术界）。因此，鼓励州、地方和部落政府以及私营部门组织酌情自愿使用这些指南。此外，采用并实施网络安全框架的非联邦组织可能会发现使用 RMF 作为框架执行的风险管理流程具有价值——为控制实施、评估和监控以及系统授权（用于基于风险的决策）提供基本任务。

管理风险

使用网络安全框架

行政命令 (E.O.) 13800 要求联邦机构现代化其 IT 基础设施和系统，并认识到联邦信息系统和网络的互联性日益增强。该行政命令还要求机构负责人使用改进关键基础设施网络安全框架（即网络安全框架）在机构层面和整个行政部门管理风险。最后，该行政命令通过要求机构负责人对其组织的网络安全风险管理负责和问责，加强了 2014 年《联邦信息安全现代化法案》(FISMA)。

网络安全框架具有适应性，可提供灵活和基于风险的实施，可与各种网络安全风险管理流程一起使用。因此，与 OMB 备忘录 M-17-25 一致，网络安全框架的联邦实施完全支持并符合 [SP 800-39] 和 NIST 特别出版物 800-37 中定义的风险管理流程和方法。这允许机构满足其同时遵守 FISMA 和 E.O. 13800 要求的义务。

RMF 中的每个任务都包含对网络安全框架中特定部分的引用。例如，任务 P-2（风险管理策略）与网络安全框架核心 [识别功能] 保持一致；任务 P-4（组织定制控制基线和网络安全框架配置文件）与网络安全框架配置文件结构保持一致；任务 R-5（授权报告）和任务 M-5（安全和隐私报告）通过使用网络安全框架的功能、类别和子类别结构，支持整个组织的 OMB 报告和风险管理要求。子类别与 [SP 800-53] 控制的映射可在以下网址获取：https://www.nist.gov/cyberframework/federal-resources。

RMF 中的安全与隐私

鼓励组织就安全与隐私问题的计划、评估以及行动计划和里程碑 (POAM) 进行协作，以最大限度地提高效率并减少重复工作。目标是确保充分解决源自法律、行政命令、指令、法规、政策、标准或任务和业务功能的安全和隐私要求，并持续选择、实施、评估和监控适当的控制。授权决策是 RMF 中的关键步骤，取决于为授权包生成的可信和可操作的安全与隐私证据。以具有成本效益和高效的方式创建此类证据非常重要。

将安全与隐私证据整合到单一授权包中的统一和协作方法将为授权官员提供来自安全和隐私专业人员的关键信息，以帮助告知授权决策。最终，这不是为了生成额外的文书工作、工件或文档。而是为了确保对实施安全和隐私控制有更大的可见性，这将促进更明智的、基于风险的授权决策。

目录

第一章 引言

- 1.1 背景
- 1.2 目的和适用性
- 1.3 目标受众
- 1.4 本出版物的组织

第二章 基础概念

- 2.1 组织范围风险管理
- 2.2 风险管理框架步骤和结构
- 2.3 RMF 中的信息安全与隐私
- 2.4 系统与系统元素
- 2.5 授权边界
- 2.6 要求与控制
- 2.7 安全与隐私态势
- 2.8 供应链风险管理

第三章 流程

- 3.1 准备
- 3.2 分类
- 3.3 选择
- 3.4 实施
- 3.5 评估
- 3.6 授权
- 3.7 监控

附录

- 附录 A 参考文献
- 附录 B 术语表
- 附录 C 缩写
- 附录 D 角色和职责
- 附录 E RMF 任务摘要
- 附录 F 系统和公共控制授权
- 附录 G 授权边界考虑
- 附录 H 系统生命周期考虑

第一章 引言

管理安全与隐私风险的必要性

组织依赖信息系统[1]来执行其任务和业务功能。任务和业务功能的成功取决于保护这些系统处理、存储和传输的信息的机密性、完整性和可用性，以及个人的隐私。对信息系统的威胁包括设备故障、环境干扰、人为或机器错误，以及通常复杂、有纪律、组织严密且资金充足的蓄意攻击。[2] 当攻击成功时，可能会对组织运营[3]和资产、个人、其他组织和国家造成严重或灾难性的损害。[4] 因此，组织必须保持警惕，整个组织的高级执行官、领导者和管理者必须了解其责任，并对保护组织资产和管理风险负责。[5]

除了保护组织资产免受当今环境中存在的威胁的责任外，组织还有责任在信息系统处理个人身份信息 (PII) 时考虑和管理对个人的风险。[6][7] 组织实施的信息安全和隐私计划在管理 PII 的机密性、完整性和可用性方面具有互补的目标。虽然许多隐私风险源于导致 PII 机密性、完整性或可用性丧失的未经授权活动，但其他隐私风险源于涉及创建、收集、使用、处理、存储、维护、传播、披露或处置 PII 的授权活动，使组织能够实现其任务或业务目标。例如，组织可能未能提供适当的 PII 处理通知，剥夺个人对此类处理的知情权，或者个人可能因 PII 的授权披露而感到尴尬或受到污名化。

---

[1] 信息系统是为收集、处理、维护、使用、共享、传播或处置信息而组织的一组离散信息资源 [44 USC 3502]。术语信息系统例如包括通用计算系统；工业/过程控制系统；网络物理系统；武器系统；超级计算机；指挥、控制和通信系统；智能手机和平板电脑等设备；环境控制系统；嵌入式设备/传感器；以及基于纸的系统。

[2] 国防科学委员会工作组报告，《弹性军事系统和高级网络威胁》[DSB 2013]。

[3] 组织运营包括任务、功能、形象和声誉。

[4] 不利影响包括例如对支持关键基础设施应用程序或对国土安全部定义的政府连续运营至关重要的系统的损害。

[5] 风险是衡量实体受潜在情况或事件威胁程度的指标。风险也是如果情况或事件发生所产生的不利影响和发生可能性的函数。风险类型包括项目风险；合规/监管风险；财务风险；法律风险；任务/业务风险；政治风险；安全和隐私风险（包括供应链风险）；项目风险；声誉风险；安全风险；战略规划风险。

[6] [OMB A-130] 将 PII 定义为"可用于区分或追踪个人身份的信息，无论是单独使用还是与其他链接到特定个人的信息结合使用。"

[7] 组织也可以考虑选择考虑个人与信息系统交互可能产生的风险，其中 PII 的处理可能影响较小，但系统对个人行为或活动的影响更大。此类影响将构成对个人自主权的风险，组织可能需要采取措施管理这些风险，以及信息和隐私风险。

虽然管理隐私风险需要信息安全计划和隐私计划之间的密切协调，因为计划目标在 PII 的机密性、完整性和可用性方面具有互补性，但隐私风险也提出了需要专业知识和方法的独特问题。因此，组织还必须建立和维护强大的隐私计划，以确保遵守适用的隐私要求并管理与 PII 处理相关的个人风险。

与安全和隐私风险密切相关且作为其一部分的供应链风险[8] 也是组织日益关注的问题。由于越来越依赖第三方或外部提供商以及商业现成产品、系统和服务，影响组织系统的供应链攻击或中断正在增加。此类攻击可能难以追踪或管理，并可能对组织系统造成严重、重大或灾难性后果。供应链风险管理 (SCRM) 与安全和隐私风险管理重叠并和谐运作。本出版物将 SCRM 相关的安全和隐私风险管理实践整合到 RMF 中，以帮助促进管理安全和隐私风险的综合方法。虽然本出版物主要关注管理信息安全和隐私风险，但在几个领域特别指出了支持安全和隐私风险管理的 SCRM 概念，以加强重点并澄清如何使用 RMF 解决它们。

---

[8] 供应链风险源于信息或信息系统的机密性、完整性或可用性丧失，并反映了对组织运营（包括任务、功能、形象或声誉）、组织资产、个人、其他组织和国家的潜在不利影响。

1.1 背景

NIST 与国防部、国家情报总监办公室和国家信息安全系统委员会合作，开发了风险管理框架 (RMF)，以改善信息安全、加强风险管理流程并鼓励组织之间的互惠。[9] 2016 年 7 月，管理和预算办公室 (OMB) 修订了 A-130 通告，将隐私计划的职责纳入 RMF。

RMF 强调风险管理，方法是在整个系统开发生命周期 (SDLC) 中将安全和隐私能力开发到信息系统中；[10] 通过持续监控流程持续维护对这些系统的安全和隐私态势的情境意识；并向高级领导者和高管提供信息，以促进就使用和操作其系统产生的对组织运营和资产、个人、其他组织和国家的风险接受做出决策。RMF：

- 提供旨在促进信息与信息系统保护的重复流程，与风险相称
- 强调管理安全和隐私风险所需的组织范围准备
- 促进信息和系统的分类，控制的选择、实施、评估和监控，以及信息系统和公共控制的授权[11]
- 促进使用自动化进行近乎实时的风险管理，并通过实施持续监控流程进行持续的系统和控制授权
- 鼓励使用正确和及时的指标，为高级领导者和管理者提供必要信息，使其能够为支持其任务和业务功能的信息系统做出具有成本效益、基于风险的决策
- 促进将安全和隐私要求[12] 和控制整合到企业架构、[13] SDLC、采购流程和系统工程流程中
- 通过高级问责官员进行风险管理，将组织和任务/业务流程层面的风险管理流程与信息系统层面的风险管理流程连接起来[14]
- 明确在信息系统内实施的控制以及这些系统继承的控制的责任和问责制

RMF 提供了一种动态和灵活的方法，以在具有复杂和复杂威胁、不断演变的任务和业务功能以及不断变化的系统和组织脆弱性的多样化环境中有效管理安全和隐私风险。该框架与政策和科技无关，这有助于 IT 资源[15] 的持续升级和 IT 现代化工作——在此类过渡期间支持和帮助确保提供基本任务和服务。

---

[9] 互惠是参与组织之间接受彼此安全评估以重用系统资源和/或接受彼此评估的安全态势以共享信息的协议。

[10] 系统开发生命周期 (SDLC) 是与系统相关的活动范围，包括系统的启动、开发和采购、实施、操作和维护，以及最终处置（引发另一个系统启动）。

[11] 公共控制是由多个信息系统或程序继承的安全或隐私控制。

[12] 要求是应用于系统时帮助确定系统所需特征（包括安全、隐私和保证）的表达。

[13] 企业架构是战略信息资产库，定义任务；执行任务所需的信息；执行任务所需的技术；以及响应不断变化的任务需求实施新技术的过渡流程；包括基线架构、目标架构和排序计划。

[14] 风险执行（功能）是组织内的个人或小组，由风险管理高级问责官员领导，确保系统的安全风险考虑（包括这些系统的授权决定）从组织角度考虑组织的战略目标和任务执行业务功能。

[15] IT 资源包括信息技术和相关资源，如人员、设备、资金和信息服务。

1.2 目的和适用性

本出版物描述了 RMF，并提供了管理安全和隐私风险及将 RMF 应用于信息系统和组织的指南。制定这些指南是为了：

- 确保管理系统相关的安全和隐私风险与组织的高级领导层通过风险执行（功能）建立的任务和业务目标及风险管理策略一致
- 通过实施适当的风险响应策略，实现对个人的隐私保护和对信息及信息系统的安全保护
- 支持一致、知情和持续的授权决策、互惠，以及安全和隐私信息的透明度和可追溯性
- 促进将安全和隐私要求和控制整合到企业架构、SDLC 流程、采购流程和系统工程流程中[17]
- 促进在联邦机构内实施改进关键基础设施网络安全框架 [NIST CSF][18]

本出版物旨在帮助组织[19] 管理安全和隐私风险，并满足《2014 年联邦信息安全现代化法案》[FISMA]、《1974 年隐私法案》[PRIVACT]、OMB 政策和指定的联邦信息处理标准等法律、法规和政策中的要求。

本出版物的范围涉及联邦信息系统，这是为收集、处理、维护、使用、共享、传播或处置信息而组织的一组离散信息资源，无论此类信息是数字形式还是非数字形式。信息资源包括信息和相关资源，如人员、设备、资金和信息技术。这些指南是从技术角度制定的，以补充国家安全系统的指南，经管理此类系统的适当联邦官员批准，可用于此类系统。鼓励州、地方和部落政府以及私营部门组织酌情使用这些指南。

---

[16] 授权是基于对组织运营和资产、个人、其他组织和国家的风险可接受的确定，对系统或公共控制的官方管理决定。

[17] 系统工程流程包括需求定义、架构定义和设计定义流程。

[18] 网络安全框架提供了基于风险的方法来降低网络安全风险，由三部分组成：框架核心、框架配置文件和框架实施层级。

[19] 组织是任何规模、复杂性或在组织结构内定位的实体（例如，联邦机构、私营企业、学术机构、州、地方或部落政府，或适当时，其任何运营元素）。

1.3 目标受众

本出版物服务于与信息系统的设计、开发、实施、评估、操作、维护和处置相关的个人，包括：

- 具有任务或业务所有权责任或信托责任的个人（例如，联邦机构负责人）
- 具有信息系统、信息安全或隐私管理、监督或治理责任的个人（例如，高级领导者、风险执行官、授权官员、首席信息官、高级机构信息安全官和高级机构隐私官）
- 负责进行安全或隐私评估和监控信息系统的个人，例如控制评估员、审计员和系统所有者
- 具有安全或隐私实施和操作责任的个人，例如系统所有者、公共控制提供者、信息所有者/管理者、任务或业务所有者、安全或隐私架构师，以及系统安全或隐私工程师
- 具有信息系统开发和采购责任的个人（例如，项目经理、采购官员、组件产品和系统开发人员、系统集成商和企业架构师）
- 具有后勤或处置相关责任的个人（例如，项目经理、采购官员、系统集成商和财产经理）

有关 RMF 相关角色和职责的综合列表和描述，请参见附录 D。

1.4 本出版物的组织

本特别出版物的其余部分组织如下：

- **第二章** 描述了管理信息系统相关安全和隐私风险的概念。这包括组织范围的风险管理视图；RMF 步骤和任务结构；信息安全计划和隐私计划之间的关系以及这些计划在 RMF 中如何解决；信息资源作为系统和系统元素；授权边界；安全和隐私态势；以及与供应链风险管理相关的安全和隐私考虑。
- **第三章** 描述了实施 RMF 步骤所需的任务，包括：组织级和信息系统级准备；信息和信息系统的分类；控制选择、定制和实施；控制有效性评估；信息系统和公共控制授权；控制的持续监控；以及保持对信息系统和组织的安全和隐私态势的认识。
- **支持性附录** 为 RMF 的应用提供额外信息和指导，包括：
  - 参考文献
  - 术语表
  - 缩写
  - 角色和职责
  - RMF 任务摘要
  - 系统和公共控制授权
  - 授权边界考虑
  - 系统生命周期考虑

第二章 基础概念

如何管理安全与隐私风险

本章描述了组织中管理信息系统相关安全和隐私风险的基本概念。这些概念包括 RMF 步骤和任务结构；RMF 中的信息安全计划和隐私计划；信息系统、系统元素，以及如何建立授权边界；安全和隐私态势；以及与供应链相关的安全和隐私风险管理实践。

2.1 组织范围风险管理

管理信息系统相关的安全和隐私风险是一项复杂的任务，需要整个组织的参与——从提供组织战略愿景和顶层目标的高级领导者，到规划、执行和管理项目的中层领导者，再到开发、实施、操作和维护支持组织任务和业务功能的系统的个人。风险管理是一项影响组织每个方面的整体活动，包括任务和业务规划活动、企业架构、SDLC 流程，以及这些系统生命周期流程中必不可少的系统工程活动。图 1 说明了 [SP 800-39] 中描述的风险管理多层方法，该方法在组织层面、任务/业务流程层面和信息系统层面解决安全和隐私风险。沟通和报告是跨三个层面的双向信息流，以确保整个组织解决风险。

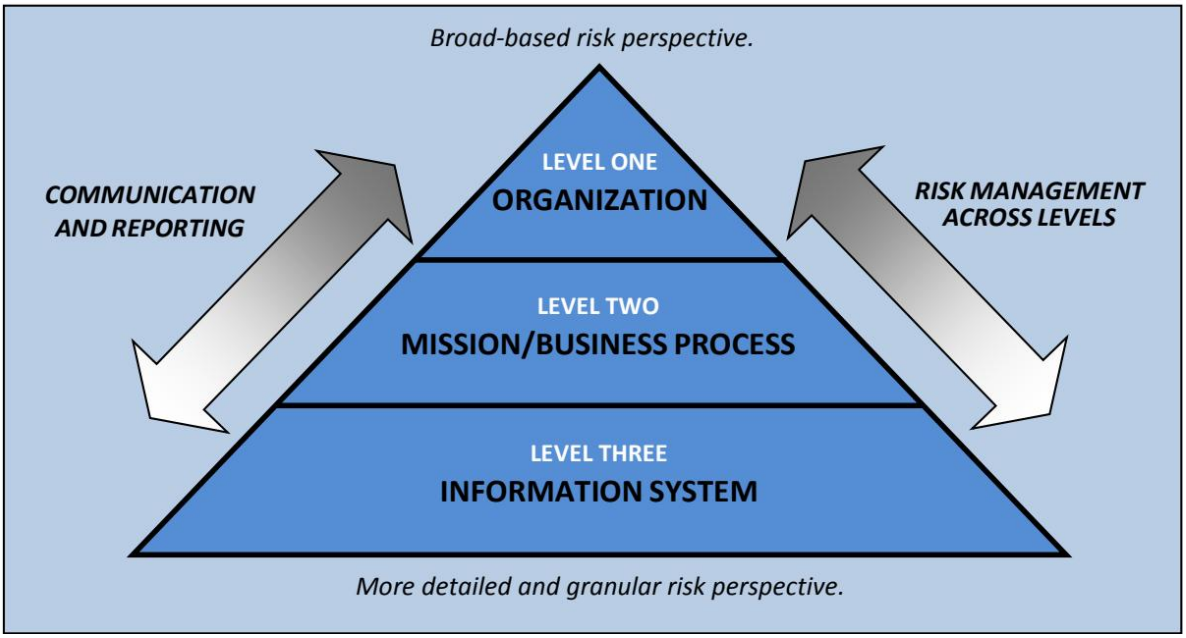

图 1：组织范围风险管理方法

在第 1 层和第 2 层进行的活动对于准备组织执行 RMF 至关重要。此类准备涉及广泛的活动，超越了简单地管理与操作或使用特定系统相关的安全和隐私风险，包括对整个组织适当管理安全和隐私风险至关重要的活动。关于如何在系统层面管理此类风险的决策不能孤立地做出。此类决策与以下方面密切相关：

- 组织的任务或业务目标
- 系统、组件和服务的现代化计划
- 企业架构以及通过整合、优化和标准化管理和降低系统复杂性的需求[20]
- 资源分配，以确保组织能够有效、高效和具有成本效益地执行其任务和业务运营[21]

---

[20] 企业架构是组织用来最大化任务/业务流程和信息技术资源有效性并实现任务和业务成功的管理实践。

[21] 资源分配包括为执行风险管理任务提供资金，并分配完成任务所需的合格人员。

准备组织执行 RMF 可以包括：

- 为组织风险管理流程分配角色和职责
- 建立风险管理策略和组织风险容忍度
- 识别信息系统旨在支持的任务、业务功能和任务/业务流程
- 识别对信息系统有兴趣的关键利益相关者（组织内部和外部）
- 识别和优先排序资产（包括信息资产）
- 了解对信息系统和组织的威胁
- 了解对个人的潜在不利影响
- 进行组织和系统级风险评估
- 识别和优先排序安全和隐私要求[22]
- 确定信息系统和公共控制的授权边界[23]
- 根据企业架构定义信息系统
- 开发包括适合信息系统继承的控制的安全和隐私架构
- 识别、协调和解决安全和隐私要求冲突
- 将安全和隐私要求分配给信息系统、系统元素和组织

---

[22] 要求是应用于系统时帮助确定系统所需特征（包括安全、隐私和保证）的表达。

[23] 授权边界包括授权官员授权操作的信息系统的所有组件。这不包括连接到信息系统的单独授权系统。

与准备组织执行 RMF 的第 1 层和第 2 层活动相比，第 3 层从信息系统角度解决风险，并由组织和任务/业务流程层面的风险决策指导和告知。第 1 层和第 2 层的风险决策可能影响系统层面的控制选择和实施。组织根据企业架构、安全或隐私架构以及组织开发的任何定制控制基线或覆盖层，将控制指定为系统特定、混合或公共（继承）控制。[24]

组织建立控制与旨在满足的安全和隐私要求的可追溯性。建立这种可追溯性确保所有要求在系统设计、开发、实施、操作、维护和处置期间得到解决。[25] 风险管理层次的每一层都是成功执行 RMF 的受益者——加强风险管理流程的迭代性质，在各种组织层面框架、评估、响应和监控安全和隐私风险。

---

[24] 控制基线是适用于信息或信息系统的一组控制，以满足法律、监管或政策要求，并解决管理风险的保护需求。

[25] 可追溯性是需求、设计、实现和测试之间关系的双向链接。

如果没有足够的组织级风险管理准备，安全和隐私活动可能变得过于昂贵，需要太多熟练的安全和隐私专业人员，并产生无效的解决方案。例如，未能实施有效企业架构的组织将难以整合、优化和标准化其信息技术基础设施。此外，架构和设计决策的影响可能对组织实施有效安全和隐私解决方案的能力产生不利影响。组织准备不足可能导致不必要的冗余，以及效率低下、成本高昂和脆弱的系统、服务和应用程序。

2.2 风险管理框架步骤和结构

RMF 有七个步骤：一个准备步骤确保组织准备好执行流程，以及六个主要步骤。所有七个步骤对于成功执行 RMF 都至关重要。这些步骤是：

1. **准备**：从组织和系统层面准备执行 RMF，建立管理安全和隐私风险的背景和优先级
2. **分类**：基于影响分析，对系统及其处理、存储和传输的信息进行分类[26]
3. **选择**：为系统选择初始控制集，并根据风险评估结果按需定制控制，将风险降低到可接受水平
4. **实施**：实施控制，并描述如何在系统及其操作环境中使用控制
5. **评估**：评估控制，确定控制是否正确实施、按预期运行，并在满足安全和隐私要求方面产生预期结果
6. **授权**：基于对组织运营和资产、个人、其他组织和国家的风险可接受的确定，授权系统或公共控制
7. **监控**：持续监控系统和相关控制，包括评估控制有效性、记录系统和操作环境的变化、进行风险评估和影响分析，以及报告系统的安全和隐私态势

---

[26] 安全分类是基于对机密性、完整性或可用性丧失的潜在影响分析，确定信息或系统安全类别的过程。

图 2 说明了 RMF 中的步骤。RMF 在图 1 说明的风险管理层次的所有层面运行。第三章提供了执行 RMF 步骤所需每个任务的详细描述。

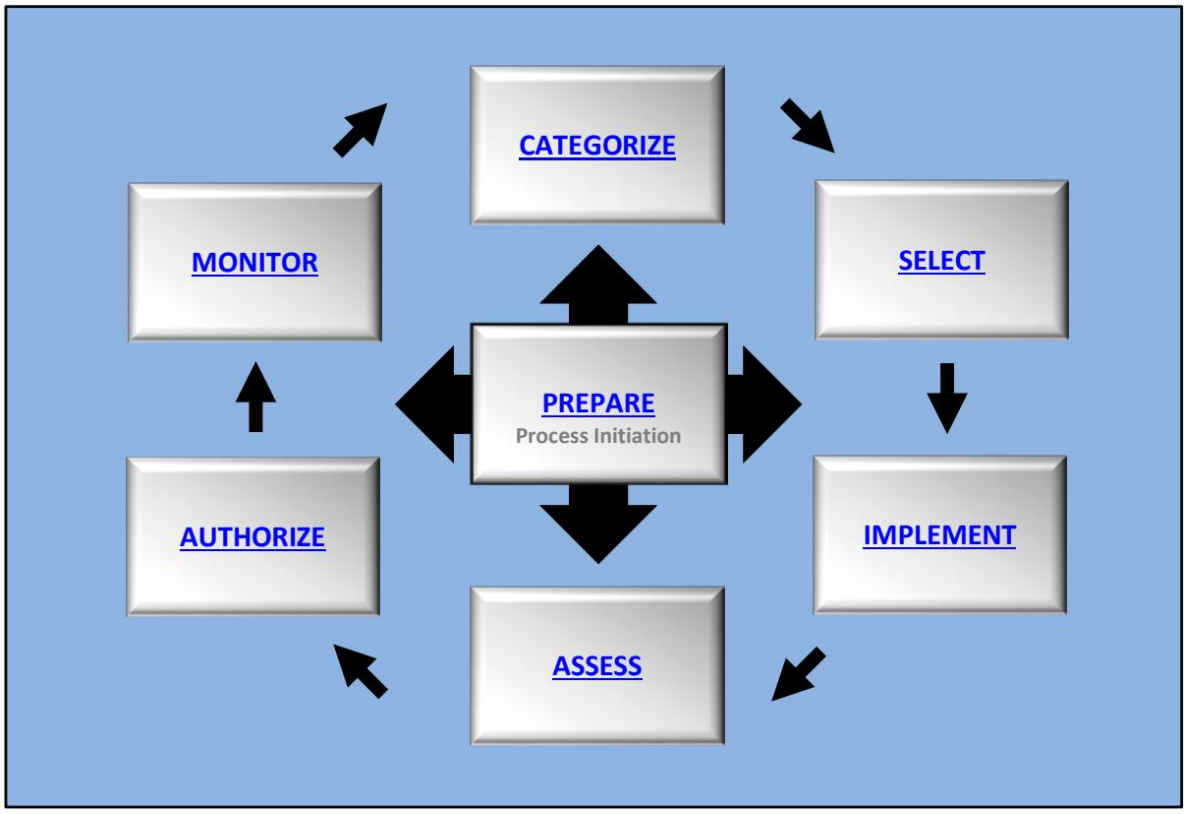

图 2：风险管理框架

虽然上述和第三章中 RMF 步骤按顺序列出，但准备步骤之后的步骤可以按非顺序顺序执行。完成准备步骤中的任务后，首次为系统或一组公共控制执行 RMF 的组织通常按顺序执行其余步骤。然而，在风险管理流程中可能有许多点需要偏离顺序，这是由于系统类型、高级领导层做出的风险决策，或允许任务之间迭代循环或重新访问任务（例如，在敏捷开发期间）。一旦组织进入监控步骤，事件可能需要非顺序执行步骤。例如，风险或系统功能的变化可能需要重新访问 RMF 中的一个或多个步骤以解决变化。

RMF 实施的灵活性

组织预计将执行 RMF 中的所有步骤和任务（标记为可选的任务除外）。然而，组织在如何执行每个 RMF 步骤和任务方面具有相当大的灵活性，只要组织满足所有适用要求并有效管理安全和隐私风险。其目的是允许组织以最高效、有效和具有成本效益的方式实施 RMF，以支持促进有效安全和隐私的任务和业务需求。灵活实施可能包括以不同（可能非顺序）顺序执行任务、强调某些任务超过其他任务，或在适当时组合某些任务。它还可以包括使用网络安全框架来增强 RMF 任务执行。

实施的灵活性也可以应用于控制选择、控制定制以满足组织安全和隐私需求，或在 SDLC 中进行控制评估。例如，随着系统开发，可以逐步进行控制的选择、定制、实施和评估。控制定制的实施有助于确保安全和隐私解决方案针对组织的特定任务、业务功能、风险和操作环境进行定制。最终，RMF 执行中固有的灵活性促进了有效的安全和隐私，有助于保护组织依赖的任务和业务成功系统，以及这些系统处理其信息的个人。

> 注意：由于 RMF 是强调持续授权的 SDLC 流程，组织可以根据风险评估和准备——系统层面步骤中描述的任务，确定进入（或重新进入）哪个 RMF 步骤。确定适当的 RMF 步骤需要评估系统的当前状态、审查系统已完成的活动、识别拟议的 RMF 步骤和任务进入、差距分析以确保风险可接受、记录决策、通知利益相关者，以及授权官员（或其他相关决策者）的批准。

虽然图 1 中的风险管理方法以层级方式传达，但项目和组织动态通常更为复杂。组织选择的风险管理方法可能在从自上而下的命令到同行之间分散共识的连续体上变化。然而，在所有情况下，组织使用一致的方法，从组织层面到信息系统层面，应用于整个组织范围的风险管理流程。组织官员识别并确保完成本出版物中描述的风险管理任务所需的资源，并确保这些资源可供适当人员使用。资源分配包括为执行

风险管理任务提供资金，并分配完成任务所需的合格人员。

RMF 中的每个步骤都有目的陈述、一组定义的结果，以及为实现这些结果而执行的一组任务。结果可以由不同的风险管理级别实现——即，一些结果对整个组织是普遍的，而其他结果则专注于系统或任务/业务部门。图 3 提供了 RMF 准备步骤——组织层面的目的陈述和结果示例。

3.1 准备

目的

准备步骤的目的是在组织的组织、任务和业务流程以及信息系统层面执行基本活动，以帮助组织准备使用风险管理框架管理其安全和隐私风险。

准备任务——组织层面

表 1 提供了组织层面 RMF 准备步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 1：准备任务和结果——组织层面

任务	结果
任务 P-1 风险管理角色	· 识别并分配关键角色以执行风险管理框架 [网络安全框架：ID.AM-6; ID.GV-2]
任务 P-2 风险管理策略	· 建立包括组织风险容忍度确定和表达的组织风险管理策略 [网络安全框架：ID.RM; ID.SC]
任务 P-3 风险评估——组织	· 完成组织范围风险评估或更新现有风险评估 [网络安全框架：ID.RA; ID.SC-2]
任务 P-4 组织定制控制基线和网络安全框架配置文件（可选）	· 建立并提供组织定制控制基线和/或网络安全框架配置文件 [网络安全框架：配置文件]
任务 P-5 公共控制识别	· 识别、记录和发布组织系统可继承的公共控制
任务 P-6 影响级别优先排序（可选）	· 对具有相同影响级别的组织系统进行优先排序 [网络安全框架：ID.AM-5]
任务 P-7 持续监控策略——组织	· 制定并实施监控控制有效性的组织范围策略 [网络安全框架：DE.CM; ID.SC-4]

快速链接到 RMF 任务、职责和支持角色的摘要表。

图 3：风险管理框架任务结构

每个任务包含执行任务所需的一组潜在输入和从任务执行生成的一组预期输出。[27] 此外，每个任务描述了与任务相关的风险管理角色和职责，以及任务执行发生的 SDLC 阶段。[28] 讨论部分提供与任务相关的信息，以促进理解并促进有效任务执行。最后，完成 RMF 任务描述，有一份参考文献列表，为组织提供每个任务的补充信息。在适用的情况下，参考文献还识别与 RMF 任务相关的系统安全工程任务。[29] 图 4 说明了典型 RMF 任务的结构。

---

[27] 输入是执行任务所需的信息、文档或材料。输出是任务执行后产生的工件、结果或条件。

[28] SDLC 阶段包括启动、开发/采购、实施/评估、操作/维护和处置。

[29] 系统工程任务在 [SP 800-160 v1] 中描述。

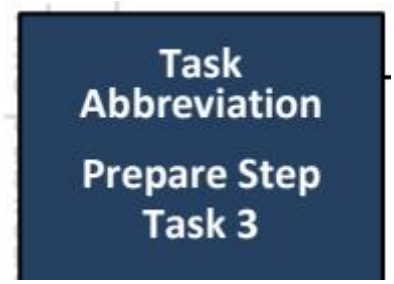

图 4：风险管理框架任务结构

风险评估——组织

任务 P-3 评估组织范围的安全和隐私风险，并持续更新风险评估结果。

潜在输入： 风险管理策略；任务或业务目标；当前威胁信息；系统级安全和隐私风险评估结果；供应链风险评估结果；先前的组织级安全和隐私风险评估结果；信息共享协议或谅解备忘录；持续监控的安全和隐私信息。

预期输出： 组织级风险评估结果。

主要责任： 风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官。

支持角色： 首席信息官；任务或业务所有者；授权官员或授权官员指定代表。

讨论： 组织层面的风险评估利用来自系统级风险评估结果、持续监控以及对组织相关的任何战略风险考虑的综合信息。组织考虑其信息系统操作和使用产生的全部风险，与其他内部和外部拥有系统的信息交换和连接，以及使用外部提供商。例如，组织可以审查与其企业架构相关的风险，以及同一网络上驻留的不同影响级别的信息系统，以及是否将高影响系统与低影响系统或由外部提供商操作和维护的系统隔离。组织还可以考虑组织内可能存在的环境可变性（例如，服务于不同任务/业务流程的不同位置），以及需要在风险评估中考虑这种可变性。也可以进行组织供应链的风险评估。风险评估结果可用于帮助组织建立网络安全框架配置文件。

参考文献： [SP 800-30]；[SP 800-39]（组织层面，任务/业务流程层面）；[SP 800-161]；[IR 8062]

2.3 RMF 中的信息安全与隐私

OMB 通告 A-130：信息安全与隐私的整合

2016 年，OMB 修订了通告 A-130，该通告建立了联邦信息、人员、设备、资金、信息技术资源和支持基础设施及服务的规划、预算、治理、采购和管理的总体政策。该通告涉及保护联邦信息资源和管理个人身份信息 (PII) 的职责。在建立信息安全计划和隐私计划的要求时，该通告强调两个计划需要就共同目标进行协作：

> 虽然安全和隐私是独立且不同的学科，但它们密切相关，机构必须采取协调方法来识别和管理安全和隐私风险并遵守适用要求。

[OMB A-130] 要求组织实施本指南中描述的 RMF。随着 2016 年对该通告的修订，OMB 还要求组织将隐私整合到 RMF 流程中：

> RMF 提供了一个严谨和结构化的流程，将信息安全、隐私和风险管理活动整合到 SDLC 中。本通告要求组织使用 RMF 管理通常包含在术语"信息安全""机密性"目标之外的隐私风险。虽然许多隐私风险与 PII 的未经授权访问或披露有关，但隐私风险也可能来自其他活动，包括 PII 的创建、收集、使用和保留；PII 的质量或完整性不足；以及缺乏适当的通知、透明度或参与。

本节描述了 RMF 下信息安全计划和隐私计划之间的关系。然而，根据 OMB 政策，组织保留以最有效的方式将隐私整合到 RMF 中的灵活性，考虑组织的任务和情况。

执行 RMF 需要信息安全计划和隐私计划之间的密切协作。虽然信息安全计划和隐私计划有不同的目标，但这些目标是重叠和互补的。信息安全计划负责保护信息和信息系统免受未经授权的访问、使用、披露、破坏、修改或销毁（即未经授权的系统活动或行为），以提供机密性、完整性和可用性。隐私计划负责确保遵守适用的隐私要求，并管理与创建、收集、使用、处理、传播、存储、维护、披露或处置（统称为"处理"）PII 相关的个人风险。[30] 在准备执行 RMF 步骤时，组织考虑如何最好地促进和制度化两个计划之间的协作，以确保两个学科的目标在流程的每一步都得到满足。

---

[30] 隐私风险是个人可能因机构创建、收集、使用、处理、存储、维护、传播、披露和处置其 PII 而遭受的不利影响。

当信息系统处理 PII 时，组织的信息安全计划和隐私计划对管理可能由未经授权的系统活动或行为引起的个人风险负有共同责任。这需要两个计划在选择、实施、评估和监控安全控制时进行协作。[31] 然而，虽然信息安全计划和隐私计划在管理 PII 的机密性、完整性和可用性方面具有互补的目标，但保护个人隐私不能仅通过保护 PII 来实现。

---

[31] 控制是为信息系统或组织规定的保护系统及其信息的机密性、完整性和可用性的保障措施或对策。

并非所有隐私风险都源于未经授权的系统活动或行为，例如未经授权的 PII 访问或披露。一些隐私风险可能源于超出信息安全范围的授权活动。例如，隐私计划负责管理可能由 PII 的创建、收集、使用和保留；PII 的质量或完整性不足；以及缺乏适当的通知、透明度或参与而对个人产生的风险。因此，为了帮助确保遵守适用的隐私要求并管理来自授权和未经授权 PII 处理的隐私风险，组织的隐私计划还选择、实施、评估和监控隐私控制。[32]

---

[32] 隐私控制是机构内采用的行政、技术或物理保障措施，以确保遵守适用的隐私要求并管理隐私风险。

[OMB A-130] 将隐私控制定义为机构内采用的行政、技术或物理保障措施，以确保遵守适用的隐私要求并管理隐私风险。隐私控制不同于安全控制，该通告将安全控制定义为信息系统或组织规定的保护系统及其信息的机密性、完整性和可用性的保障措施或对策。由于组织的信息安全计划和隐私计划对管理由未经授权的系统活动或行为引起的个人风险负有共同责任，实现安全和隐私目标的控制既是隐私控制也是安全控制。本指南将实现这两组目标的控制简称为"控制"。当本指南使用描述词"隐私"和"安全"与控制术语一起使用时，指的是为特定目标选择、实施和评估这些控制的情况。

本出版物中描述的风险管理流程同样适用于安全和隐私计划。然而，安全和隐私计划需要管理的风险在某些领域重叠，但在其他领域则不重叠。因此，重要的是组织了解隐私和安全之间的相互作用，以促进组织各层面隐私和安全官员之间的有效协作。

2.4 系统与系统元素

本出版物使用法定定义的信息系统进行 RMF 执行。然而，重要的是在 SDLC 流程的背景下描述信息系统，以及如何在这些系统的组件内实施安全和隐私能力。因此，执行 RMF 的组织对信息系统开发生命周期采取广义观点，以提供与架构和工程概念的背景关系和联系，使安全和隐私风险（包括供应链风险）能够在整个生命周期内并在适当的详细级别得到解决，以帮助确保实现此类能力。[ISO 15288] 提供了信息系统及其在操作环境中交互的实体的工程视图。[33]

---

[33] ISO/IEC/IEEE 15288:2015，系统和软件工程——系统生命周期流程。

类似于联邦法律将信息系统定义为一组离散信息资源，为收集、处理、维护、使用、共享、传播或处置信息而组织，[ISO 15288] 将系统定义为组织起来实现一个或多个既定目的的交互元素集。正如构成信息系统的信息资源包括信息和其他资源（例如，人员、设备、资金和信息技术），系统元素包括技术或机器元素、人类元素，以及物理或环境元素。系统内的每个系统元素[34] 履行指定的要求，可以通过硬件、软件或固件实现；[35] 物理结构或设备；或人员、流程、政策和程序。单个系统元素或系统元素的组合可以满足既定的系统要求。系统元素之间的互连允许这些元素根据需要交互，以产生系统要求指定的能力。最后，每个系统都在影响系统及其操作的环境中运行。

[34] 系统元素是构成系统的元素集的成员。系统元素可以是离散组件、产品、服务、子系统、系统、基础设施或企业。

[35] 固件是存储在硬件中的计算机程序和数据——通常在只读存储器 (ROM) 或可编程只读存储器 (PROM) 中——使程序和数据在程序执行期间不能动态写入或修改。

授权边界定义了 RMF 执行的系统[36]，以促进风险管理和问责。系统可以由一个或多个启用系统在系统生命周期内提供支持。启用系统不包含在系统的授权边界内，不一定存在于系统的操作环境中。启用系统可以为系统提供公共（即继承）控制，或者可以包括系统使用的任何类型的服务或功能，如身份验证和认证服务、网络服务或监控功能。最后，系统在操作环境中与其他系统交互。其他系统也在授权边界之外，可能是系统提供服务的受益者，或者可能只有一般交互。[37]

[36] 系统是组织起来实现一个或多个既定目的的交互元素集。

[37] 其他系统是系统在操作环境中交互的系统，但在系统授权范围之外。

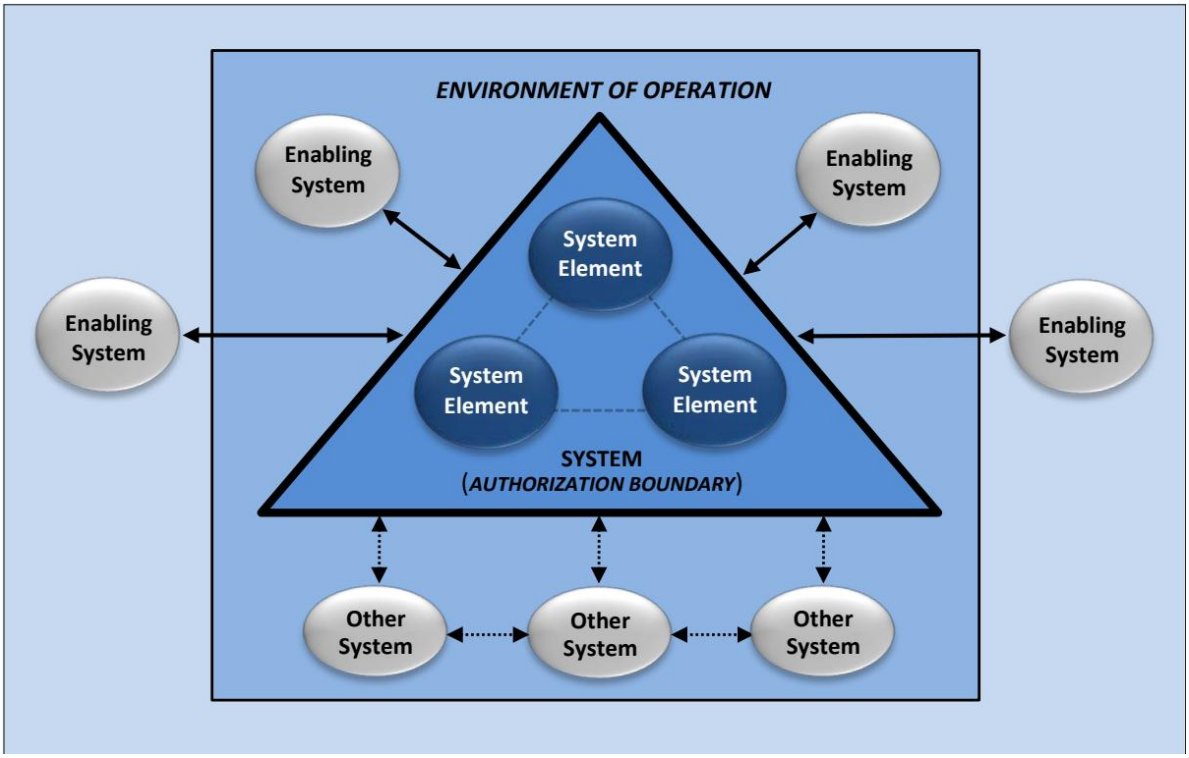

图 5：系统的概念视图

图 5 说明了系统的概念视图，以及系统、系统元素、启用系统、其他系统和操作环境之间的关系。[38]

[38] 操作环境是信息系统处理、存储和传输信息的物理周围环境。

操作环境的某些部分可以包括在授权边界内（即确定为授权的"范围内"），而其他部分可能被排除。例如，如果为系统元素提供保护的设施（即操作环境）被确定为系统授权范围内，则物理和环境保护控制（例如，入口点的物理访问控制、周边保护设备）包括在授权边界内，因此包括在系统安全计划中。如果设施提供物理和环境保护作为系统继承的公共控制，则操作环境在系统范围之外，不包括在系统的授权边界内。[39]

---

[39] 如果设施提供物理和环境保护作为公共控制，则环境在系统授权边界之外。

系统还可以与作为扩展操作环境一部分但在系统授权范围之外的启用系统和其他系统通信或有其他交互。[40] 组织确定操作环境的哪些部分在授权边界内。这些确定通常是特定于系统的，由上下文驱动。

---

[40] 扩展操作环境包括启用系统和其他系统，它们在系统授权范围之外，但与系统有交互。

2.5 授权边界

授权边界建立了信息系统的保护范围（即组织同意在其直接管理下或在其责任范围内保护的内容）。[41] 授权边界包括作为支持组织任务和业务功能的每个系统一部分的人员、流程和技术（即系统元素）。过于宽泛的授权边界（即包括太多系统元素或组件）会使风险管理流程不必要地复杂化。相反，过于有限的授权边界（即包括太少系统元素或组件）会增加必须单独管理的系统数量，因此可能不必要地增加组织的信息安全和隐私成本。

---

[41] 授权边界包括授权官员授权操作的信息系统的所有组件。这不包括连接到信息系统的单独授权系统。

系统的授权边界在 RMF 准备任务——系统层面，任务 P-11 期间建立。组织在确定什么构成系统的授权边界方面具有灵活性。授权边界内包含的一组系统元素定义了系统（即授权范围）。当一组系统元素被识别为系统的授权边界时这些元素通常在相同的直接管理下。[42] 确定授权边界的其他考虑因素包括识别：

- 支持相同任务或业务功能的系统元素
- 具有类似操作特征和安全和隐私要求的系统元素
- 处理、存储和传输类似类型信息的系统元素（例如，在相同影响级别分类）[43]
- 驻留在相同操作环境中的系统元素（或者在分布式系统的情况下，驻留在具有类似操作环境的不同位置）

---

[42] 直接管理意味着系统元素在相同的组织控制下，具有相同的预算、人员和管理监督。

[43] 影响级别是基于对机密性、完整性或可用性丧失的潜在影响分析，确定为低、中或高。

作为组织执行的持续监控流程的一部分，定期重新访问授权边界的范围。虽然上述考虑因素可能对组织确定授权边界以管理风险有用，但这些考虑因素无意限制组织在建立促进有效安全和隐私的组织可用资源的授权边界方面的灵活性。

建立授权边界的流程具有重大的风险管理影响，因此是一项需要关键参与者之间协调的组织范围活动。该流程考虑任务和业务要求、安全和隐私要求，以及组织的成本。附录 G 提供了确定授权边界的额外信息和考虑因素，包括复杂系统和软件应用程序的边界。

有效的授权边界

为系统和公共控制建立有意义的授权边界是组织执行的最重要的风险管理活动之一。授权边界定义了授权官员保护信息资源和个人隐私的责任和问责的具体范围——包括使用来自外部提供商的系统、组件和服务。建立有意义的授权边界是确保组织任务和业务成功的基础。

2.6 要求与控制

在执行 RMF 之前，重要的是了解安全和隐私要求的概念，以及要求与控制之间的关系。术语"要求"可以在不同的上下文中使用。在联邦信息安全和隐私政策的上下文中，该术语通常用于指组织施加的信息安全和隐私义务。例如，OMB 通告 A-130 施加了一系列信息安全和隐私要求，联邦机构在管理信息资源时必须遵守这些要求。除了联邦政策上下文中使用的术语要求外，本指南中使用的术语要求在更广泛的意义上指特定系统或组织的利益相关者保护需求的表达。利益相关者保护需求和相应的安全和隐私要求可能来自许多来源（例如，法律、行政命令、指令、法规、政策、标准、任务和业务需求，或风险评估）。本指南中使用的术语要求包括法律和政策要求，以及可能来自其他来源的更广泛利益相关者保护需求的表达。当应用于系统时，所有这些要求帮助确定系统的所需特征——包括安全、隐私和保证。

组织可以选择将安全和隐私要求划分为更细粒度的类别，具体取决于要求在 SDLC 中的使用位置和使用目的。组织可以使用术语**能力要求**来描述系统或组织必须提供以满足利益相关者保护需求的能力。此外，组织可以将适用于系统特定硬件、软件和固件组件的要求称为**规范要求**——即实现全部或部分控制并可评估（即作为验证、确认、测试和评估流程的一部分）的能力。最后，组织可以使用术语**工作说明要求**来指必须在操作期间或系统开发期间执行的操作。

控制可以被视为描述适合实现组织特定安全和隐私目标并反映组织利益相关者保护需求的保障措施和保护能力。组织选择并实施控制以满足系统要求。控制可以包括技术方面、管理方面和物理方面。在某些情况下，控制的选择和实施可能需要组织以派生要求或实例化控制参数值的形式进行额外规范。派生要求和控制参数值可能需要在 SDLC 内为特定控制提供适当的实施详细级别。

上下文相关要求

组织识别的安全和隐私要求和风险，导致需要安全和隐私控制来响应风险。组织选择的控制随后在系统工程上下文中导致规范要求和工作说明要求。这是系统工程师作为 SDLC 流程一部分开发、派生和分解要求的重要方面。因此，组织在系统生命周期内管理不同粒度和特异性级别的安全和隐私要求。控制在生命周期中发挥重要作用，提供保护能力的高级陈述，组织可以对其进行细化和扩展。

2.7 安全与隐私态势

RMF 的目的是帮助确保在整个 SDLC 中，信息系统、组织和个人得到充分保护，授权官员拥有必要的信息，以就系统或公共控制的操作或使用做出可信的、基于风险的决策。授权官员基于风险的决策的一个关键方面是了解信息系统和系统可继承的公共控制的安全和隐私态势。安全和隐私态势代表组织内信息系统和信息资源（例如，人员、设备、资金和信息技术）的状态，基于信息保证资源（例如，人员、硬件、软件、政策、程序）到位的管理组织在系统操作或使用中的防御能力；遵守适用的隐私要求并管理隐私风险；以及随着情况变化做出反应。

信息系统和组织的安全和隐私态势通过评估和持续监控系统特定、混合和公共控制持续确定。[44] 控制评估和监控活动提供证据，证明组织选择的控制正确实施、按预期运行，并满足响应法律、行政命令、法规、指令、政策、标准或任务和业务要求的安全和隐私要求。授权官员使用安全和隐私态势，基于组织的风险管理策略和组织风险容忍度，确定对组织运营和资产、个人、其他组织或国家的风险是否可接受。[45]

[44] 持续监控是维护持续意识以支持组织风险决策。

[45] 风险容忍度是组织可接受的风险或不确定性程度。

2.8 供应链风险管理

组织越来越依赖外部提供商提供的产品、系统和服务来执行任务和业务功能。组织对使用此类组件产品、系统和服务时产生的风险负责和问责。[46] 与外部提供商的关系可以通过多种方式建立，例如通过合资企业、业务合作伙伴关系、各种类型的正式协议（例如，合同、机构间协议、业务线安排、许可协议），或外包安排。

---

[46] 组织对使用外部提供商的产品、系统和服务时产生的风险负责和问责。

对来自外部提供商的产品、系统和服务的日益依赖，以及与这些提供商的关系性质，给组织带来了越来越多的风险。基于威胁事件（如假冒产品的插入、未经授权的生产、篡改、盗窃、恶意软件和硬件的插入，以及供应链中糟糕的制造和开发实践，包括未能构建使组织能够更好地管理其环境风险的安全或隐私能力）的发生可能性和不利影响，风险可能会增加。

供应链风险在系统元素、系统、组织、部门或国家内可能是地方性或系统性的。虽然系统元素或服务在系统内的单一使用可能对组织呈现可接受的风险，但其在系统、组织、部门或国家内的常见或扩展使用可能将风险提高到不可接受的水平。这些风险通常与产品和服务供应链的全球和分布式性质以及组织对其获取的技术如何开发、集成和部署的可见性和理解降低有关。这包括用于确保所获取产品、系统和服务的完整性、安全性、弹性、隐私能力和质量的过程、程序和实践。

为了解决供应链风险，组织制定 SCRM 政策，这是指导 SCRM 活动的重要工具。在法律、行政命令、指令、政策和法规的指导和告知下，SCRM 政策支持适用的组织政策（例如，采购和采购、信息安全和隐私、物流、质量和供应链）。该政策支持组织战略计划、任务和业务功能中的目标和目的，以及内部和外部客户要求。它还定义了 SCRM 与组织的风险管理和 SDLC 流程的整合点。最后，SCRM 政策定义了组织内的 SCRM 角色和职责、这些角色之间的任何依赖关系，以及角色之间的交互。SCRM 角色指定采购、进行风险评估、收集供应链威胁情报、识别和实施基于风险的缓解措施，以及执行监控功能的职责。

[FISMA] 和 [OMB A-130] 要求处理联邦信息或代表联邦政府操作系统的提供商满足与联邦机构相同的安全和隐私要求。外部提供商的安全和隐私要求（包括处理、存储或传输联邦信息的系统的控制）在合同或其他正式协议中表达。RMF 可有效用于管理供应链风险。[47] 图 5 中系统的概念视图可以指导和告知供应链所有元素的安全、隐私和风险管理活动。RMF 中的每个步骤都可以由非联邦外部提供商执行，除了授权步骤——即，接受风险是高级高管负责和问责的固有联邦责任。授权决策直接与从外部提供商采购和使用组件产品、系统和服务相关的风险管理联系起来。[48] [OMB A-130] 还要求组织制定和实施 SCRM 计划。[49]

---

[47] RMF 可用于管理供应链风险，因为 RMF 步骤和任务可应用于外部提供商。

[48] 授权决策直接与从外部提供商采购和使用组件产品、系统和服务相关的风险管理联系起来。

[49] SCRM 计划是组织用于记录所选缓解措施并监控 SCRM 计划绩效的文档。

管理供应链风险是一项复杂、多层面的任务，需要整个组织的协调努力——建立信任关系并与内部和外部利益相关者沟通。SCRM 活动涉及识别和评估适用的风险、确定适当的缓解行动、制定适当的 SCRM 计划以记录所选缓解行动，以及监控 SCRM 计划的绩效。由于组织之间和组织内的供应链不同，SCRM 计划针对单个项目、组织和操作环境进行定制。定制计划为确定系统是否"适合目的"提供基础，因此需

要相应定制控制。定制的 SCRM 计划帮助组织根据任务和业务要求及其风险环境，将资源集中在最关键的任务和业务功能上。

确定从外部提供商采购产品、系统或服务的风险是否可接受，取决于组织可以从提供商获得的保证级别。[50] 保证级别基于组织可以对提供商施加的控制程度，以保护产品、系统或服务，以及提供商提供的关于这些控制有效性的证据。

---

[50] 保证是对安全或隐私声明已实现或将实现的合理信心的依据。

控制程度由合同或服务级别协议的具体条款和条件建立。一些组织通过指定外部提供商安全和隐私要求的合同工具或其他协议拥有广泛控制。其他组织则控制有限，因为它们正在购买商品服务或商业现成产品。保证级别还可以基于许多其他因素，使组织确信已实施必要的控制，并且存在对控制有效性的可信确定。例如，通过成熟的业务线关系提供给组织的授权外部云服务可能提供组织风险容忍度内的服务信任级别。最终，响应来自使用外部提供商的组件产品、系统和服务的风险的责任仍由组织和授权官员承担。组织要求与外部提供商建立适当的信任链，以处理系统安全或隐私风险相关的问题。

供应链风险管理策略和计划

组织在 SCRM 策略和计划的详细信息记录方式上具有灵活性。第 1 层和第 2 层（组织和任务/业务流程层面）的 SCRM 策略详细信息可以记录在组织的信息安全计划计划中，或单独的组织级和/或任务/业务流程级 SCRM 策略中。第 3 层（信息系统层面）的 SCRM 计划详细信息可以记录在信息系统安全计划中，或单独的系统级 SCRM 计划中。[SP 800-161] 中提供了 SCRM 策略模板。

第三章 流程

执行风险管理框架任务

本章描述了构成 RMF 的步骤和相关任务，以及执行这些任务的选定个人或小组（定义的组织角色）。组织尽可能将风险管理角色与 SDLC 定义的互补或相似角色保持一致，并与任务和业务功能一致。RMF 任务与组织中的 SDLC 流程同时执行，或作为其一部分执行。与 SDLC 流程同时执行 RMF 任务有助于确保组织有效地将管理信息安全性和隐私风险的过程整合到 SDLC 流程中。此外，RMF 所需的预期输出（例如，安全和隐私计划、评估报告、行动计划和里程碑）可以从组织内到位的 SDLC 流程常规获得，可能不需要仅为 RMF 实施而开发。

RMF 与 SDLC 的对齐

最佳的 RMF 实施是与组织执行的常规 SDLC 流程无法区分的那个。也就是说，RMF 任务与 SDLC 流程中的持续活动紧密对齐，确保将安全和隐私保护无缝整合到组织系统中——并充分利用 SDLC 流程生成的工件在授权包中产生必要的证据，以促进组织高级领导者的可信、基于风险的决策。

实施 RMF 任务的过程可能因组织而异。虽然任务按顺序出现，但在风险管理流程中可能有许多点需要偏离顺序，包括初始任务执行和重新访问任务之间的迭代循环需求。例如，控制评估结果可能触发系统所有者和公共控制提供者的一组补救行动，这反过来可能需要重新评估选定的控制。监控控制可以生成跟踪系统及其操作环境变化的循环；评估信息安全和隐私影响；重新评估控制；采取补救行动；以及报告系统和组织的安全和隐私态势。

当更有效、高效或具有成本效益时，可能还有其他机会偏离任务的顺序性质。例如，虽然控制评估任务列在控制实施任务之后，但组织可以在控制实施后尽快开始评估控制，但在系统安全计划和隐私计划中描述的所有控制完全实施之前。尽快评估控制可能导致组织在评估系统的硬件、固件或软件组件中实施的控制之前，先评估设施内的物理和环境保护控制。无论任务顺序如何，系统投入运行前的最终行动是

授权官员明确接受风险。

RMF 步骤和相关任务可应用于 SDLC 适当阶段的新开发系统和现有系统。对于新系统和现有系统，组织确保已完成指定任务以准备执行 RMF。对于现有系统，组织确认已完成安全分类和（对于处理 PII 的信息系统）隐私风险评估，并且是适当的；并且已选择、定制和实施所需的控制。

将 RMF 步骤和相关任务应用于现有系统可以作为差距分析，以确定组织的安全和隐私风险是否得到有效管理。控制中的缺陷可以以与新开发系统相同的方式在 RMF 实施、评估、授权和监控步骤中解决。如果在差距分析期间未发现缺陷且当前授权有效，组织可以直接进入 RMF 中的持续监控步骤。如果当前授权无效，组织按通常顺序继续评估、授权和监控步骤。

任务委托

每个 RMF 任务的主要责任部分中指定的角色负责确保任务完成。具有主要责任的角色可以完成任务，或者可以将任务完成委托给一个或多个支持角色，除非任务讨论部分或附录 D 中明确禁止或不允许委托。如果任务完成被委托，对该任务负有主要责任的角色仍对任务完成负责。

简化 RMF 实施的提示

- 使用组织级和系统级准备步骤的任务和输出，在组织内促进一致的开始点来执行 RMF
- 最大化使用公共控制，促进标准化、一致和具有成本效益的安全和隐私能力继承
- 最大化使用共享或基于云的系统、服务和应用程序（如适用），以减少组织授权数量
- 采用组织定制的控制基线，提高安全和隐私计划开发的速度，促进安全和隐私计划内容的一致性，并解决组织范围的威胁
- 采用基于从系统安全工程流程生成的安全和隐私要求的组织定义控制
- 最大化使用自动化工具来管理安全分类；控制选择、评估和监控；以及授权流程
- 减少低影响系统的工作量和资源支出（如果这些系统无法通过系统连接对更高影响系统产生不利影响）
- 最大化重复使用 RMF 工件（例如，安全和隐私评估结果），用于标准化硬件/软件部署，包括配置设置
- 通过消除不必要的系统、系统元素和服务来减少 IT/OT 基础设施的复杂性——采用最少功能原则
- 将过渡到持续授权作为优先事项，并使用持续监控方法来降低安全和隐私计划的成本并提高效率

开发明确定义的安全和隐私要求

RMF 是基于 SDLC 的流程，可有效用于帮助确保信息系统或组织的安全和隐私要求得到满足。定义清晰、一致和明确的安全和隐私要求是成功执行 RMF 的重要元素。要求在 SDLC 早期与高级领导者协作定义，并整合到采购和采购流程中。例如，组织可以使用 [SP 800-160 v1] 基于生命周期的系统工程流程来定义初始安全和隐私要求集，这反过来可用于选择一组控制*来满足要求。当组织采购系统、系统组件或服务时，要求可以在建议书请求或其他合同协议中说明。要求也可以在整个生命周期中添加，例如在敏捷开发方法中持续部署新功能时。

NIST 网络安全框架 [NIST CSF]（即核心、配置文件）也可用于识别、协调和解决安全要求，并随后告知组织的安全控制选择。网络安全框架配置文件可以在网络安全活动和组织任务/业务目标之间提供联系，这支持整个 RMF 的基于风险的决策。虽然配置文件可用作告知控制选择和定制活动的起点，但需要进一步评估以确保选择适当的控制。一些组织可能选择与 NIST 系统安全工程出版物一起使用网络安全框架——在整个部门、行业或组织内识别、协调和解决要求——随后采用系统工程方法进一步完善要求并获得可信的安全解决方案，以帮助保护组织的运营、资产和个人。

---

*见第 2.3 节关于隐私控制选择和管理隐私风险的具体指导。

组织和系统准备

准备可以实现有效、高效和具有成本效益的风险管理流程执行。准备步骤的主要目标包括：

- **促进高级领导者和高管与系统所有者和操作人员之间更好的沟通**
  - 将组织优先级与系统层面的资源分配和优先排序保持一致
  - 传达在既定组织风险容忍度内选择和实施控制的可接受限制
- **促进组织范围内公共控制的识别和组织定制控制基线的开发**，以减少单个系统所有者的工作量和系统开发及保护成本
- **通过应用企业架构概念和模型整合、标准化和优化系统、应用程序和服务**，减少 IT 基础设施的复杂性
- **识别、优先排序和集中资源于高价值资产**（如 [OMB M-19-03] 中定义），需要增加保护级别
- **促进系统就绪以进行系统特定任务**

如果实现这些目标，可以显著减少组织的信息技术足迹和攻击面，促进 IT 现代化目标，并优先排序安全和隐私活动以将保护策略集中在最关键的资产和系统上。

最后，组织层面准备步骤中的某些任务被指定为可选。这些任务包括为组织提供额外选项，以帮助使其 RMF 实施更有效、高效和具有成本效益。

3.1 准备[52]

目的

准备步骤的目的是在组织的组织、任务和业务流程以及信息系统层面执行基本活动，以帮助组织准备使用风险管理框架管理其安全和隐私风险。

---

[52] 准备步骤是 RMF 中的新步骤，旨在提高 RMF 执行的有效性、效率和成本效益。

准备任务——组织层面[53]

表 1 提供了组织层面 RMF 准备步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 1：准备任务和结果——组织层面

任务	结果
任务 P-1 风险管理角色	· 识别并分配关键角色以执行风险管理框架 [网络安全框架：ID.AM-6; ID.GV-2]
任务 P-2 风险管理策略	· 建立包括组织风险容忍度确定和表达的组织风险管理策略 [网络安全框架：ID.RM; ID.SC]
任务 P-3 风险评估——组织	· 完成组织范围风险评估或更新现有风险评估 [网络安全框架：ID.RA; ID.SC-2]
任务 P-4 组织定制控制基线和网络安全框架配置文件（可选）	· 建立并提供组织定制控制基线和/或网络安全框架配置文件 [网络安全框架：配置文件]
任务 P-5 公共控制识别	· 识别、记录和发布组织系统可继承的公共控制
任务 P-6 影响级别优先排序（可选）	· 对具有相同影响级别的组织系统进行优先排序 [网络安全框架：ID.AM-5]
任务 P-7 持续监控策略——组织	· 制定并实施监控控制有效性的组织范围策略 [网络安全框架：DE.CM; ID.SC-4]

快速链接到 RMF 任务、职责和支持角色的摘要表。

---

[53] 组织层面准备任务由组织级角色执行，例如高级机构信息安全官、高级机构隐私官、风险执行（功能）和任务/业务所有者。

风险管理角色

任务 P-1 识别并分配个人到与安全和隐私风险管理相关的特定角色。

潜在输入： 组织安全和隐私政策和程序；组织图表。

预期输出： 记录的风险管理框架角色分配。

主要责任： 机构负责人；首席信息官；高级机构隐私官。

支持角色： 授权官员或授权官员指定代表；风险管理高级问责官员或风险执行（功能）；高级机构信息安全官。

讨论： 风险管理流程中关键参与者的角色和职责在附录 D 中描述。角色和职责可以包括组织内部或外部的个人（如适用）。由于组织有不同的任务、功能和组织结构，风险管理角色的命名约定以及如何将特定职责分配给组织人员可能存在差异（例如，多人担任单个角色或一人担任多个角色）。在这两种情况下，基本风险管理功能保持不变。组织在将同一个人分配给多个风险管理角色时确保没有利益冲突。例如，授权官员不能为其授权的系统或公共控制担任系统所有者或公共控制提供者的角色。此外，为安全和隐私组合多个角色需要谨慎，因为这两个学科可能需要不同的专业知识，在某些情况下，优先级可能是竞争的。一些角色可以分配给小组或办公室而不是个人，例如控制评估员、风险执行（功能）或系统管理员。

参考文献： [SP 800-160 v1]（人力资源管理流程）；[SP 800-181]；[NIST CSF]（核心 [识别功能]）。

风险管理策略

任务 P-2 为组织建立风险管理策略，包括风险容忍度的确定。

潜在输入： 组织使命宣言；组织政策；组织风险假设、约束、优先级和权衡。

预期输出： 风险管理策略和风险容忍度声明，包括信息安全和隐私风险。

主要责任： 机构负责人。

支持角色： 风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官。

讨论： 风险容忍度是组织可接受的风险或不确定性程度。风险容忍度影响组织风险管理流程的所有部分，对高级领导者或高管在整个组织内做出的风险管理决策产生直接影响，并为这些决策提供重要约束。风险管理策略指导和告知基于风险的决策，包括如何框架、评估、响应和监控安全和隐私风险。风险管理策略可以由单个文档组成，或单独的安全和隐私风险管理文档。[54] 风险管理策略明确了用于做出投资和运营决策的威胁、假设、约束、优先级、权衡和风险容忍度。该策略包括高级领导者和高管如何管理对组织运营、组织资产、个人、其他组织和国家的安全和隐私风险（包括供应链风险）的战略级决策和考虑。风险管理策略包括组织风险容忍度的表达；可接受的风险评估方法和风险响应策略；一致评估组织范围安全和隐私风险的流程；以及随时间监控风险的方法。随着组织定义和实施风险管理策略、政策、程序和流程，重要的是包括 SCRM 考虑。安全和隐私的风险管理策略将安全和隐私计划与组织企业风险管理策略中建立的管理控制系统联系起来。[55]

---

[54] 风险管理策略可以是单个文档，或单独的安全和隐私风险管理文档。

[55] 企业风险管理策略是组织用于管理可能影响其任务执行业务功能实现的风险的流程和方法。

参考文献： [SP 800-30]；[SP 800-39]（组织层面）；[SP 800-160 v1]（风险管理、决策管理、质量保证、质量管理、项目评估和控制流程）；[SP 800-161]；[IR 8062]；[IR 8179]（关键性分析流程 B）；[NIST CSF]（核心 [识别功能]）。

风险评估——组织

任务 P-3 评估组织范围的安全和隐私风险，并持续更新风险评估结果。

潜在输入： 风险管理策略；任务或业务目标；当前威胁信息；系统级安全和隐私风险评估结果；供应链风险评估结果；先前的组织级安全和隐私风险评估结果；信息共享协议或谅解备忘录；持续监控的安全和隐私信息。

预期输出： 组织级风险评估结果。

主要责任： 风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官。

支持角色： 首席信息官；任务或业务所有者；授权官员或授权官员指定代表。

讨论： 组织层面的风险评估利用来自系统级风险评估结果、持续监控以及对组织相关的任何战略风险考虑的综合信息。组织考虑其信息系统操作和使用产生的全部风险，与其他内部和外部拥有系统的信息交换和连接，以及使用外部提供商。例如，组织可以审查与其企业架构相关的风险，以及同一网络上驻留的不同影响级别的信息系统，以及是否将高影响系统与低影响系统或由外部提供商操作和维护的系统隔离。组织还可以考虑组织内可能存在的环境可变性（例如，服务于不同任务/业务流程的不同位置），以及需要在风险评估中考虑这种可变性。也可以进行组织供应链的风险评估。风险评估结果可用于帮助组织建立网络安全框架配置文件。

参考文献： [SP 800-30]；[SP 800-39]（组织层面，任务/业务流程层面）；[SP 800-161]；[IR 8062]。

组织定制控制基线和网络安全框架配置文件（可选）

任务 P-4 建立、记录和发布组织定制控制基线和/或网络安全框架配置文件。

潜在输入： 记录的安全和隐私要求指示使用组织定制控制基线；任务或业务目标；企业架构；安全架构；隐私架构；组织和系统级风险评估结果；公共控制提供者列表和可继承的公共控制；NIST 特别出版物 800-53B 控制基线。[56]

预期输出： 批准或指示的组织定制控制基线列表；[NIST CSF] 配置文件。

主要责任： 任务或业务所有者；风险管理高级问责官员或风险执行（功能）。

支持角色： 首席信息官；授权官员或授权官员指定代表；高级机构信息安全官；高级机构隐私官。

讨论： 为了解决组织任务或业务对 specialized 控制集以减少风险的需求，可以为组织范围使用开发组织定制控制基线。[57] 组织定制基线提供从 [SP 800-53B] 中描述的既定控制基线派生的完全指定的控制、控制增强和补充指导集。定制流程也可以由 [SP 800-160 v1] 中描述的需求工程流程指导和告知。当偏离 [SP 800-53B] 中创建初始控制基线所使用的特定假设时，组织可以使用定制控制基线概念。例如，当组织有特定安全或隐私风险、特定任务或业务需求，或计划在未在初始基线中解决的环境中操作时。

---

[56] [SP 800-53B] 提供了联邦信息系统的控制基线。

[57] 组织定制控制基线是为定义的名义（类型）信息系统定制的控制基线，使用覆盖层和/或系统特定控制定制，旨在用于在一个或多个组织内为多个系统选择控制。

组织定制基线和覆盖层通过提供添加或消除控制以适应组织要求的机会，同时继续保护与风险相称的信息，来补充 NIST 控制基线。组织可以使用定制基线和覆盖层通过描述控制适用性和为特定技术提供解释来定制控制基线；任务或业务功能类型、操作、系统、操作环境和操作模式；以及法定或监管要求。多个定制基线可能对具有异构系统的组织有用（例如，维护具有不同操作或处理特征，或任务或业务特征的系统）。

组织定制基线可以为分配或选择语句中的控制和控制增强建立组织定义的控制参数值，这些值同意特定利益共同体，并在必要时扩展补充指导。定制基线可能比 [SP 800-53B] 中识别的基线更严格或较不严格，并应用于多个系统。

组织外部开发的定制基线也可能被某些法律、行政命令、指令、法规、政策或标准强制使用。在某些情况下，定制行动可能受到定制基线开发者或定制基线发布机构的限制或限制。利益共同体已为云和共享系统、服务和应用程序；工业控制系统；隐私；国家安全系统；武器和天基系统；高价值资产；[58] 移动设备管理；联邦公钥基础设施；以及隐私风险开发了定制基线（或覆盖层）。

---

[58] 高价值资产是对组织使命至关重要的资产，需要增加保护级别。

组织也可以从开发一个或多个网络安全框架配置文件中受益。网络安全框架配置文件使用框架核心中的子类别将网络安全结果与组织的任务或业务要求、风险容忍度和资源保持一致。在组织和任务/业务流程层面开发的优先网络安全结果列表可以帮助促进系统层面的一致、基于风险的决策。 applicable 网络安全框架配置文件中识别的子类别也可用于指导和告知上述定制控制基线的开发。

参考文献： [SP 800-53]；[SP 800-53B]；[SP 800-160 v1]（业务或任务分析和利益相关者需求和需求定义流程）；[NIST CSF]（核心，配置文件）。

公共控制识别

任务 P-5 识别、记录和发布组织范围公共控制，这些控制可由组织系统继承。

潜在输入： 记录的安全和隐私要求；现有公共控制提供者和相关的安全和隐私计划；信息安全和隐私计划计划；组织和系统级安全和隐私风险评估结果。

预期输出： 公共控制提供者列表和可继承的公共控制；安全和隐私计划（或等效文档），提供公共控制实施的描述（包括输入、预期行为和预期输出）。

主要责任： 高级机构信息安全官；高级机构隐私官。

支持角色： 任务或业务所有者；风险管理高级问责官员或风险执行（功能）；首席信息官；授权官员或授权官员指定代表；公共控制提供者；系统所有者。

讨论： 公共控制是可以由一个或多个信息系统继承的控制。[60] 公共控制可以来自任何 [SP 800-53] 控制族，例如物理和环境保护控制、系统边界和监控控制、人员安全控制、政策和程序、采购控制、账户和身份管理控制、审计日志和问责控制，或接收公众隐私查询的投诉管理控制。组织识别并选择一组公共控制，并将这些控制分配给指定为公共控制提供者的组织实体。公共控制可能因各种因素而异，例如托管位置、系统架构和组织结构。组织范围的公共控制列表考虑了这些因素。公共控制也可以在组织的不同层面识别（例如，公司、部门或机构层面；局或子组件层面；或单个项目层面）。组织可以建立一个或多个可由信息系统继承的公共控制列表。要求可能无法完全由公共控制满足。在这种情况下，控制被视为混合控制，组织如此注明，包括指定公共控制提供的哪些部分由公共控制提供者继承，哪些部分将在系统层面提供。

---

[60] 公共控制是可以由一个或多个信息系统继承的安全或隐私控制。

当有多个公共控制来源时，组织指定公共控制提供者（即，谁通过什么场所提供控制，例如共享服务、特定系统或特定类型的架构），以及哪些系统或哪些类型的系统可以继承控制。公共控制列表传达给系统所有者，因此他们了解组织通过继承可用的安全和隐私能力。系统所有者不需要评估其系统继承的公共控制或记录公共控制实施细节；这是公共控制提供者的责任。同样，公共控制提供者不需要了解继承其提供的公共控制的系统的系统级细节。

识别公共控制时可以使用风险评估结果，以确定可继承的控制是否满足组织系统及其操作环境（包括识别潜在单点故障）的安全和隐私要求。当组织提供的公共控制被确定为对继承这些控制的信息系统不足时，系统所有者可以用系统特定或混合控制补充公共控制，以实现其系统的所需保护，或在组织知晓和批准下接受更大风险。

公共控制提供者执行 RMF 步骤以实施、评估和监控指定为公共控制的控制。当公共控制驻留在信息系统内时，公共控制提供者也可以是系统所有者。组织选择高级官员或高管担任公共控制的授权官员。高级机构隐私官负责指定公共隐私控制，并将其记录在组织的隐私计划计划中。授权官员负责接受组织系统继承的公共控制使用产生的安全和隐私风险。

公共控制提供者负责在安全和隐私计划（或组织规定的等效文档）中记录公共控制；确保公共控制由合格评估员实施和评估有效性，并将评估结果记录在评估报告中；为确定为有不可接受缺陷并针对补救的公共控制产生行动计划和里程碑；从指定授权官员获得公共控制的授权；并持续监控控制有效性。公共控制的计划、评估报告和行动计划和里程碑（或此类信息的摘要）提供给系统所有者，并可由授权官员用于指导和告知继承公共控制的系统的授权决策。有关公共控制授权的信息，请参见任务 R-4 和附录 F。

参考文献： [SP 800-53]。

影响级别优先排序（可选）[61]

任务 P-6 优先排序具有相同影响级别的组织系统。

潜在输入： 组织系统的安全分类信息；系统描述；组织和系统级风险评估结果；任务或业务目标；网络安全框架配置文件。

预期输出： 优先排序为低、中和高影响子类别的组织系统。

主要责任： 风险管理高级问责官员或风险执行（功能）。

支持角色： 高级机构信息安全官；高级机构隐私官；任务或业务所有者；系统所有者；首席信息官；授权官员或授权官员指定代表。

讨论： 此任务仅在组织系统已分类后执行（见任务 C-1）。此任务要求组织首先将高水位标记概念应用于根据 [FIPS 199] 和 [FIPS 200] 分类的每个信息系统。[62] 高水位标记概念的应用导致系统指定为低影响、中影响或高影响。

---

[61] 影响级别优先排序是可选任务，为组织提供额外的粒度以进行基于风险的决策。

[62] 高水位标记概念是基于信息类型影响级别的最高值确定系统影响级别的方法。

希望对影响指定有额外粒度以进行基于风险决策的组织可以使用此任务在其影响级别内优先排序系统。[63] 例如，组织可以决定通过将每个中等系统分配给三个新子类别之一来优先排序其中等影响系统：低 - 中系统、中 - 中系统和高 - 中系统。高 - 中系统假设比中 - 中系统更高的优先级，低 - 中系统假设比中 - 中系统更低的优先级。中等系统的优先排序使组织有机会在选择控制和定制控制基线以响应识别的风险时做出更明智的决策。

---

[63] 影响级别优先排序可以用于确定对组织任务和业务运营至关重要或基本的系统，因此组织可以专注于复杂性、聚合和系统互连的因素。

影响级别优先排序也可用于确定对组织任务和业务运营至关重要或基本的系统，因此组织可以专注于复杂性、聚合和系统互连的因素。例如，此类系统可以通过将高影响系统优先排序为低 - 高系统、中 - 高系统和高 - 高系统来识别。影响级别优先排序可以在组织的任何层面进行，并基于单个系统所有者报告的安全分类数据。影响级别优先排序可能需要开发组织定制基线，以指定额外的、更细粒度影响级别的适当控制集。

网络安全框架配置文件可以被组织用于支持影响级别优先排序任务。适用网络安全框架配置文件中定义的任务和业务目标及优先结果可以帮助区分具有相同影响级别的系统之间的相对优先级。网络安全框架配置文件可以围绕组织的任务/业务目标的优先级组织，这些目标在其中分配相对优先级。例如，人类和环境安全目标可能是与配置文件的上下文相关的两个最重要目标。在此示例中，当执行任务 P-6 时，与人类安全目标相关的系统可能比具有相同影响级别但与人类安全目标无关的系统优先排序更高。

参考文献： [FIPS 199]；[FIPS 200]；[SP 800-30]；[SP 800-39]（组织和系统层面）；[SP 800-59]；[SP 800-60 v1]；[SP 800-60 v2]；[SP 800-160 v1]（系统需求定义流程）；[IR 8179]（关键性分析流程 B）；[CNSSI 1253]；[NIST CSF]（核心 [识别功能]；配置文件）。

持续监控策略——组织

任务 P-7 制定并实施持续监控控制有效性的组织范围策略。

潜在输入： 风险管理策略；组织和系统级风险评估结果；组织安全和隐私政策。

预期输出： 已实施的组织持续监控策略。

主要责任： 风险管理高级问责官员或风险执行（功能）。

支持角色： 首席信息官；高级机构信息安全官；高级机构隐私官；任务或业务所有者；系统所有者；授权官员或授权官员指定代表。

讨论： 风险管理的一个重要方面是能够在整个组织内监控安全和隐私态势，以及在组织系统内或继承的控制的有效性。[64] 有效的组织范围持续监控策略对于高效和具有成本效益地执行此类监控至关重要。持续监控策略还可以包括供应链风险考虑，例如定期审查供应商外国所有权、控制或影响 (FOCI)、监控库存预测，或要求对供应商进行持续审计。实施强大和全面的持续监控计划帮助组织了解其信息系统的安全和隐私态势。它还促进了初始系统或公共控制授权后的持续授权。这可能包括任务或业务功能、利益相关者、技术、漏洞、威胁、风险和系统、组件或服务供应商的潜在变化。

---

[64] 持续监控是维护持续意识以支持组织风险决策。

组织持续监控策略解决组织、任务/业务流程和信息系统层面的监控要求。持续监控策略识别整个组织实施控制的最小监控频率；定义持续控制评估方法；并描述如何进行持续评估（例如，解决自动化工具的使用和管理，以及无法自动化的控制持续评估说明）。持续监控策略还可以定义安全和隐私报告要求，包括报告接收者。确定控制监控最小频率的标准与组织官员协作建立（例如，风险管理高级问责官员或风险执行 [功能]；高级机构信息安全官；高级机构隐私官；首席信息官；系统所有者；公共控制提供者；以及授权官员或其指定代表）。组织风险评估可用于指导和告知监控频率。

自动化的使用促进了监控流程中更大频率和体积的控制评估。使用自动化工具和支持数据库持续监控控制促进了信息系统的近乎实时风险管理，并支持持续授权和资源的有效使用。风险管理高级问责官员或风险执行（功能）批准持续监控策略，包括控制监控的最小频率。

参考文献： [SP 800-30]；[SP 800-39]（组织、任务或业务流程、系统层面）；[SP 800-53]；[SP 800-53A]；[SP 800-137]；[SP 800-161]；[IR 8011 v1]；[IR 8062]；[NIST CSF]（核心 [识别、检测功能]）；[CNSSI 1253]。

任务/业务流程（第 2 层）考虑

任务/业务流程考虑在 RMF 准备 - 组织层面步骤和 RMF 准备 - 系统层面步骤中解决，通过指定任务/业务流程关注点；识别主要或支持角色中的任务或业务所有者；以及识别任务或业务目标。来自 RMF 准备 - 系统层面步骤的任务 P-8 和任务 P-9 是具有系统层面特定焦点的任务/业务流程层面任务。

准备任务——系统层面

表 2 提供了系统层面 RMF 准备步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 2：准备任务和结果——系统层面

任务	结果
任务 P-8 任务或业务焦点	· 识别系统旨在支持的任务、业务功能和任务/业务流程 [网络安全框架：配置文件；实施层级；ID.BE]
任务 P-9 系统利益相关者	· 识别对系统有兴趣的利益相关者 [网络安全框架：ID.AM; ID.BE]
任务 P-10 资产识别	· 识别并优先排序利益相关者资产 [网络安全框架：ID.AM]
任务 P-11 授权边界	· 确定授权边界（即系统）
任务 P-12 信息类型	· 识别系统处理、存储和传输的信息类型 [网络安全框架：ID.AM-5]
任务 P-13 信息生命周期	· 识别并理解系统处理、存储或传输的每个信息类型的信息生命周期的所有阶段 [网络安全框架：ID.AM-3; ID.AM-4]
任务 P-14 风险评估——系统	· 完成系统级风险评估或更新现有风险评估 [网络安全框架：ID.RA; ID.SC-2]
任务 P-15 需求定义	· 定义并优先排序安全和隐私要求 [网络安全框架：ID.GV; PR.IP]
任务 P-16 企业架构	· 确定系统在企业架构中的位置
任务 P-17 需求分配	· 将安全和隐私要求分配给系统和系统操作的环境 [网络安全框架：ID.GV]
任务 P-18 系统注册	· 为管理、问责、协调和监督目的注册系统 [网络安全框架：ID.GV]

快速链接到 RMF 任务、职责和支持角色的摘要表。

任务或业务焦点

任务 P-8 识别系统旨在支持的任务、业务功能和任务/业务流程。

潜在输入： 组织使命宣言；组织政策；任务/业务流程信息；系统利益相关者信息；网络安全框架配置文件；建议书请求或其他采购文档；操作概念。

预期输出： 系统将支持的任务、业务功能和任务/业务流程。

主要责任： 任务或业务所有者。

支持角色： 授权官员或授权官员指定代表；系统所有者；信息所有者或管理者；首席信息官；高级机构信息安全官；高级机构隐私官。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 组织任务和业务功能影响为执行这些任务和业务功能而创建的任务或业务流程的设计和发展。任务和业务功能的优先排序驱动投资策略、资金决策、资源优先排序和风险决策——因此影响现有企业架构和相关安全和隐私架构的发展。从利益相关者收集信息，从系统安全和隐私角度更深入地了解组织的任务、业务功能和任务/业务流程。

参考文献： [SP 800-39]（组织和任务/业务流程层面）；[SP 800-64]；[SP 800-160 v1]（业务或任务分析、投资组合管理和项目规划流程）；[NIST CSF]（核心 [识别功能]）；[IR 8179]（关键性分析流程 B）。

系统利益相关者

任务 P-9 识别对系统的设计、开发、实施、评估、操作、维护或处置有兴趣的利益相关者。

潜在输入： 组织使命宣言；任务或业务目标；系统将支持的任务、业务功能和任务/业务流程；其他任务/业务流程信息；组织安全和隐私政策和程序；组织图表；对系统有兴趣和决策责任的个人或群体（内部和外部）的信息。

预期输出： 系统利益相关者列表。

主要责任： 任务或业务所有者；系统所有者。

支持角色： 首席信息官；授权官员或授权官员指定代表；信息所有者或管理者；高级机构信息安全官；高级机构隐私官；首席采购官。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 利益相关者包括在整个系统生命周期内对系统有兴趣的个人、组织或代表——用于系统的设计、开发、实施、交付、操作和维持。它还包括供应链的所有方面。利益相关者可能驻留在同一组织内，或者当这些组织对信息系统有共同利益时，他们可能驻留在不同组织内。例如，这可能发生在基于云的系统、共享服务系统或任何系统的开发、操作和维护期间，组织可能因系统泄露或妥协而受到不利影响，或因供应链相关的各种考虑。利益相关者之间的沟通在 RMF 的每个步骤和整个 SDLC 中都很重要，以确保满足安全和隐私要求，迅速解决关注点和问题，并有效执行风险管理流程。

参考文献： [SP 800-39]（组织层面）；[SP 800-64]；[SP 800-160 v1]（利益相关者需求和需求定义及投资组合管理流程）；[SP 800-161]；[NIST CSF]（核心 [识别功能]）。

资产识别

任务 P-10 识别需要保护的资产。

潜在输入： 信息系统将支持的任务、业务功能和任务/业务流程；业务影响分析；内部利益相关者；系统利益相关者信息；系统信息；与系统交互的其他系统的信息。

预期输出： 要保护的资产集。

主要责任： 系统所有者。

支持角色： 授权官员或授权官员指定代表；任务或业务所有者；信息所有者或管理者；高级机构信息安全官；高级机构隐私官；系统管理员。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 资产是对实现任务或业务目标有价值的有形和无形资产。有形资产本质上是物理的，包括物理/环境元素（例如，非数字信息、结构、设施）、人类元素，以及技术/机器元素（例如，硬件元素、机制和网络）。相比之下，无形资产本质上不是物理的，包括任务和业务流程、功能、数字信息和数据、固件、软件和服务。信息资产可以是有形或无形资产，可以包括执行任务或业务功能、交付服务和系统管理/操作所需的信息；受控非机密信息和机密信息；以及与信息系统相关的所有形式的文档。无形资产还可以包括组织的形象或声誉，以及其信息将由系统处理的个人的隐私利益。组织定义要考虑保护的利益相关者资产范围。需要保护的资产基于利益相关者关注点和资产使用的上下文进行识别。这包括组织的任务或业务功能；与系统交互的其他系统；其资产由任务或业务功能或系统使用的利益相关者。资产可以记录在系统安全和隐私计划中。

参考文献： [SP 800-39]（组织层面）；[SP 800-64]；[SP 800-160 v1]（利益相关者需求和需求定义流程）；[IR 8179]（关键性分析流程 C）；[NIST CSF]（核心 [识别功能]）；[NARA CUI]。

授权边界

任务 P-11 确定系统的授权边界。

潜在输入： 系统设计文档；网络图；系统利益相关者信息；资产信息；网络和/或企业架构图；组织结构（图表、信息）。

预期输出： 记录的授权边界。

主要责任： 授权官员。

支持角色： 首席信息官；系统所有者；任务或业务所有者；高级机构信息安全官；高级机构隐私官；企业架构师。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 授权边界建立了信息系统的保护范围（即组织同意在其管理控制下或在其责任范围内保护的内容）。授权边界由授权官员确定，系统所有者基于任务、管理或预算责任提供输入（见附录 F）。明确划分授权边界对于问责制和安全分类很重要，特别是在低影响系统连接到高影响系统，或外部提供商负责系统操作或维护的情况下。每个系统包括一组元素（即信息资源）[65] 组织起来实现一个或多个目的，并支持组织的任务和业务流程。每个系统元素的实施方式使组织能够满足指定的安全和隐私要求。系统元素包括人类元素、技术/机器元素，以及物理/环境元素。

---

[65] 信息资源包括信息和相关资源，如人员、设备、资金和信息技术。

术语"系统"用于定义系统元素集、系统元素互连，以及 RMF 实施焦点的环境（见图 5）。系统包含在单个授权边界内以确保问责制。对于处理 PII 的系统，隐私和安全计划协作以开发对授权边界的共同理解。为了进行有效的风险评估和选择适当的控制，隐私和安全计划提供对构成授权边界的清晰和一致理解。了解授权边界及其之外将发生什么可能影响选择的控制及其实施方式。例如，如果系统的功能包括 externally 共享 PII，则可以为从系统传输的 PII 选择强大的加密控制。

同样，对于由外部提供商部分或全部管理、维护或操作的系统，明确描述授权边界的协议确保问责制。隐私和安全计划与提供商协作以开发对授权边界的共同理解。与外部提供商的正式协议（例如合同）可用于描绘构成授权边界的内容。了解此类边界有助于选择适当的控制来管理供应链风险。

参考文献： [SP 800-18]；[SP 800-39]（系统层面）；[SP 800-47]；[SP 800-64]；[SP 800-160 v1]（系统需求定义流程）；[NIST CSF]（核心 [识别功能]）。

信息类型

任务 P-12 识别系统要处理、存储和传输的信息类型。

潜在输入： 系统设计文档；要保护的资产；任务/业务流程信息；系统设计文档。

预期输出： 系统的信息类型列表。

主要责任： 系统所有者；信息所有者或管理者。

支持角色： 任务或业务所有者；系统安全官；系统隐私官。[66]

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 识别支持组织任务、业务功能和任务/业务流程所需的信息类型是开发系统安全和隐私计划的重要步骤，也是确定安全分类的先决条件。[NARA CUI] 定义了根据其受控非机密信息 (CUI) 计划，按照法律、法规或政府范围政策需要保护的信息类型。组织可以定义支持组织任务、业务功能和任务/业务流程所需的额外信息类型，这些信息类型未在 CUI 注册表或 [SP 800-60 v2] 中定义。识别的信息类型由信息所有者或管理者确认，并记录在系统安全和隐私计划中。

---

[66] 系统隐私官是负责维护系统或程序的适当操作隐私态势的个人。

参考文献： [OMB A-130]；[NARA CUI]；[SP 800-39]（系统层面）；[SP 800-60 v1]；[SP 800-60 v2]；[NIST CSF]（核心 [识别功能]）。

信息生命周期

任务 P-13 识别并理解系统处理、存储或传输的每个信息类型的信息生命周期的所有阶段。

潜在输入： 系统将支持的任务、业务功能和任务/业务流程；系统利益相关者信息；授权边界信息；与系统交互的其他系统的信息（例如，信息交换/连接协议）；系统设计文档；系统元素信息；系统信息类型列表。

预期输出： 记录信息在系统中通过的阶段的文档，例如数据映射或模型，说明信息在其生命周期内如何结构化或由系统处理。此类文档包括例如数据流图、实体关系图、数据库模式和数据字典。

主要责任： 高级机构隐私官；系统所有者；信息所有者或管理者。

支持角色： 首席信息官；任务或业务所有者；安全架构师；隐私架构师；企业架构师；系统安全工程师；隐私工程师。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 信息生命周期描述了信息通过的阶段，通常特征为创建或收集、处理、传播、使用、存储和处置，包括销毁和删除 [OMB A-130]。识别和理解每个信息类型在生命周期所有阶段如何处理，帮助组织识别保护信息的考虑因素，告知组织的安全和隐私风险评估，并告知选择和实施控制。识别和理解信息生命周期有助于采用实践，以帮助确保例如组织有权收集或创建信息，根据其影响级别制定与信息处理相关的规则，创建信息共享协议，并遵循信息存储和处置的保留时间表。

使用数据映射等工具使组织能够了解信息如何处理，以便组织可以更好地评估安全和隐私风险可能出现的位置，以及可以最有效应用控制的位置。重要的是组织考虑授权边界的适当划分和信息系统与其他系统的交互，因为信息进入和离开系统的方式会影响安全和隐私风险评估。系统元素的识别具有足够的粒度以支持此类风险评估。

识别和理解信息生命周期对于评估安全和隐私风险特别相关，因为信息可能在任何 SDLC 阶段由系统处理。例如，在 SDLC 的测试和集成阶段，处理实际（即实时）数据可能会提高安全和隐私风险，但使用替代（即合成）数据可能允许在系统测试方面获得同等好处，同时降低风险。

参考文献： [OMB A-130]；[OMB M-13-13]；[NARA RECM]；[NIST CSF]（核心 [识别功能]）；[IR 8062]。

风险评估——系统

任务 P-14 进行系统级风险评估，并持续更新风险评估结果。

潜在输入： 要保护的资产；系统将支持的任务、业务功能和任务/业务流程；业务影响分析或关键性分析；系统利益相关者信息；与系统交互的其他系统的信息；提供商信息；威胁信息；数据映射；系统设计文档；网络安全框架配置文件；风险管理策略；组织级风险评估结果。

预期输出： 安全和隐私风险评估报告。

主要责任： 系统所有者；系统安全官；系统隐私官。

支持角色： 风险管理高级问责官员或风险执行（功能）；授权官员或授权官员指定代表；任务或业务所有者；信息所有者或管理者；控制评估员。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 此任务可能要求组织进行安全和隐私风险评估，以确保每种风险类型得到充分评估。安全风险评估包括识别影响资产的威胁源[67] 和威胁事件、资产是否以及如何易受威胁、资产漏洞被威胁利用的可能性，以及资产丢失的影响（或后果）。作为风险评估的关键部分，基于资产丢失的不利影响或后果对资产进行优先排序。为每种资产类型定义丢失的含义，以确定丢失后果（即丢失的不利影响）。丢失后果可以是有形的（例如，金钱、工业伤亡）或无形的（例如，声誉），并构成相对于资产从部分丢失到完全丢失的连续体。信息丢失的解释可能包括例如丢失占有、销毁，或丢失精度或准确性。功能或服务的丢失可以解释为丢失控制、丢失可访问性、丢失提供正常功能、性能或行为的能力，或导致功能、性能或行为降级水平的有限能力丢失。妥协的物理后果可能包括计划外生产停机、工业设备损坏、现场伤亡、环境灾难和公共安全威胁。资产优先排序基于资产价值、物理后果、更换成本、关键性、对形象或声誉的影响，或用户、协作组织或任务或业务合作伙伴的信任。资产优先级转化为分配资源、确定机制强度和定义保证级别的优先顺序。

---

[67] 威胁源是意图和方法针对漏洞的故意利用，或可能意外触发漏洞的情况和方法。

进行隐私风险评估以确定系统在 PII 处理时采取的给定操作可能对个人产生不利后果的可能性——以及对个人的潜在影响。[68] 这些不利后果可能源于导致处理 PII 的信息系统中机密性、完整性或可用性丧失的未经授权活动，或可能作为授权活动的副产品产生。隐私风险评估受上下文因素影响。上下文因素可以包括但不限于 PII 的敏感度级别，包括特定元素或汇总；使用或与系统交互的组织类型以及个人对组织的隐私感知；个人对处理性质和目的的理解；以及影响个人理解或行为的个人隐私利益、技术专业知识或人口统计特征。对个人的隐私风险可能影响个人与系统交互的决策，从而影响任务或业务目标，或为组织造成法律责任、声誉风险或其他类型的风险。对组织的影响不是隐私风险。然而，这些影响可以指导和告知组织决策，并影响风险响应的优先排序和资源分配。

---

[68] 隐私风险是个人可能因机构创建、收集、使用、处理、存储、维护、传播、披露和处置其 PII 而遭受的不利影响。

还进行风险评估以确定使用外部提供商进行系统、系统元素或服务的开发、实施、维护、管理、操作或处置可能造成丢失的潜力，以及该丢失的潜在影响。影响可能是即时的（例如，物理盗窃）或持续的（例如，由于盗窃对手复制关键设备的能力）。影响可能是地方性的（例如，限于单个系统）或系统性的（例如，包括使用特定类型系统组件的任何系统）。供应链风险评估考虑与系统或系统元素处置相关的漏洞，以及使用外部提供商。供应链中的漏洞可能包括缺乏可追溯性或问责制，导致潜在使用假冒产品、插入恶意软件或低质量系统。使用外部提供商可能导致对系统、系统元素和服务如何开发、部署和维护的可见性和控制丧失。清楚了解威胁、漏洞和不利供应链事件的潜在影响可以帮助组织适当平衡供应链风险与风险容忍度。供应链风险评估可以包括来自供应商审计、审查和供应链情报的信息。组织制定收集信息的策略，包括与提供商协作进行供应链风险评估的策略。此类协作帮助组织利用来自提供商的信息、减少冗余、识别风险响应的潜在行动方案，并减少对提供商的负担。

在整个 SDLC 中进行风险评估，并支持各种 RMF 步骤和任务。风险评估结果用于告知安全和隐私需求定义；分类决策；控制的选择、定制、实施和评估；授权决策；风险响应的潜在行动方案及优先排序；以及持续监控策略。组织确定进行的风险评估形式（包括此类评估的范围、严格性和正式性）和报告结果的方法。

参考文献： [FIPS 199]；[FIPS 200]；[SP 800-30]；[SP 800-39]（组织层面）；[SP 800-59]；[SP 800-60 v1]；[SP 800-60 v2]；[SP 800-64]；[SP 800-160 v1]（利益相关者需求和需求定义及风险管理流程）；[SP 800-161]（评估）；[IR 8062]；[IR 8179]；[NIST CSF]（核心 [识别功能]）；[CNSSI 1253]。

需求定义

任务 P-15 为系统和操作环境定义安全和隐私要求。

潜在输入： 系统设计文档；组织和系统级风险评估结果；已知要保护的利益相关者资产集；系统将支持的任务、业务功能和任务/业务流程；业务影响分析或关键性分析；系统利益相关者信息；PII 信息生命周期的数据映射；网络安全框架配置文件；与系统交互的其他系统的信息；供应链信息；威胁信息；适用于系统的法律、行政命令、指令、法规或政策；风险管理策略。

预期输出： 记录的安全和隐私要求。

主要责任： 任务或业务所有者；系统所有者；信息所有者或管理者；系统隐私官。[69]

支持角色： 授权官员或授权官员指定代表；系统安全官；高级机构信息安全官；高级机构隐私官；首席采购官；安全架构师；隐私架构师；企业架构师。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 保护需求是系统所需保护能力的表达，以将安全和隐私风险降低到可接受水平，同时支持任务或业务需求。保护需求包括系统的安全特征[70] 和系统在其预期操作环境中和跨所有系统生命周期阶段的安全行为。保护需求反映利益相关者的优先级、利益相关者之间谈判的结果以响应冲突、相反优先级、矛盾和既定目标，因此本质上是主观的。记录保护需求以帮助确保与这些需求相关的推理、假设和约束可用于将来参考，并提供对安全和隐私要求的可追溯性。安全和隐私要求[71] 构成跨所有 SDLC 阶段、相关生命周期流程和与系统相关资产的保护的保护需求的正式、更细粒度表达。安全和隐私要求来自许多来源（例如，法律、行政命令、指令、法规、政策、标准、任务和业务需求，或风险评估）。安全和隐私要求是系统所需特征的正式表达的重要组成部分。[72] 安全和隐私要求指导和告知系统控制的选择及与这些控制相关的定制活动。

---

[69] 系统隐私官是负责维护系统或程序的适当操作隐私态势的个人。

[70] 安全特征是系统的内在属性，有助于其安全行为。

[71] 要求是应用于系统时帮助确定系统所需特征（包括安全、隐私和保证）的表达。

[72] 所需特征包括安全、隐私和保证。

组织可以使用网络安全框架来管理安全和隐私要求，并在为组织定义的网络安全框架配置文件中表达这些要求。例如，可以使用框架核心的功能 - 类别 - 子类别结构来协调甚至解决多个要求的冲突。然后配置文件可用于告知 RMF 准备 - 组织层面步骤（任务 P-4）中描述的组织定制控制基线的开发。

参考文献： [SP 800-39]（组织层面）；[SP 800-64]；[SP 800-160 v1]（利益相关者需求和需求定义流程）；[SP 800-161]（多层风险管理）；[IR 8179]；[NIST CSF]（核心 [保护、检测、响应、恢复功能]；配置文件）。

企业架构

任务 P-16 确定系统在企业架构中的位置。

潜在输入： 安全和隐私要求；组织和系统级风险评估结果；企业架构信息；安全架构信息；隐私架构信息；资产信息。

预期输出： 更新的企业架构；更新的安全架构；更新的隐私架构；使用基于云的系统和共享系统、服务或应用程序的计划。

主要责任： 任务或业务所有者；企业架构师；安全架构师；隐私架构师。

支持角色： 首席信息官；授权官员或授权官员指定代表；高级机构信息安全官；高级机构隐私官；系统所有者；信息所有者或管理者。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 企业架构是用于最大化任务/业务流程和信息技术资源有效性并实现任务和业务成功的管理实践。企业架构可以提供对信息系统初始设计和开发中包含的信息和运营技术的更好理解，是在日益复杂威胁环境中实现这些系统的弹性和生存能力的先决条件。企业架构还为组织提供了整合、标准化和优化信息和技术资产的机会。有效实施的架构产生更透明的系统，因此更容易理解和保护。企业架构还建立了从投资到可衡量性能改进的明确联系。系统在企业架构中的位置很重要，因为它提供了对其他连接到系统的系统（内部和外部）的更好可见性和理解，也可用于为系统建立安全域以增加保护级别。

安全架构和隐私架构是企业架构的组成部分。这些架构代表与企业架构中与安全和隐私要求实施相关的部分。安全架构和隐私架构的主要目的是确保安全和隐私要求在组织系统中一致且符合成本效益地得到满足，并与风险管理策略保持一致。安全架构和隐私架构提供了促进可追溯性的路线图，从组织的战略目标和目的，通过保护需求和安全和隐私要求，到由人员、流程和技术提供的特定安全和隐私解决方案。

参考文献： [SP 800-39]（任务/业务流程层面）；[SP 800-64]；[SP 800-160 v1]（系统需求定义流程）；[NIST CSF]（核心 [识别功能]；配置文件）；[OMB FEA]。

需求分配

任务 P-17 将安全和隐私要求分配给系统和操作环境。

潜在输入： 组织和系统级风险评估结果；记录的安全和隐私要求；组织和系统级风险评估结果；公共控制提供者列表和可继承的公共控制；系统描述；系统元素信息；系统组件库存；相关法律、行政命令、指令、法规和政策。

预期输出： 分配给系统、系统元素和操作环境的安全和隐私要求列表。

主要责任： 安全架构师；隐私架构师；系统安全官；系统隐私官。

支持角色： 首席信息官；授权官员或授权官员指定代表；任务或业务所有者；高级机构信息安全官；高级机构隐私官；系统所有者。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 分配安全和隐私要求以指导和告知组织、系统、系统元素和/或操作环境的控制选择和实施。[73] 需求分配识别控制将在哪里实施。需求分配通过确保当在特定系统元素上实施公共控制或系统级控制提供所需保护能力时，不在多个系统或系统元素上实施要求，从而节约资源并帮助简化风险管理流程。

---

[73] 要求分配是组织用于将安全或隐私要求分配给信息系统或其操作环境的流程；或将控制分配给负责提供安全或隐私能力的特定系统元素（例如，路由器、服务器、远程传感器）。

参考文献： [SP 800-39]（组织、任务/业务流程和系统层面）；[SP 800-64]；[SP 800-160 v1]（系统需求定义流程）；[NIST CSF]（核心 [识别功能]；配置文件）；[OMB FEA]。

系统注册

任务 P-18 向组织项目或管理办公室注册系统。

潜在输入： 组织关于系统注册的政策；系统信息。

预期输出： 根据组织政策注册的系统。

主要责任： 系统所有者。

支持角色： 任务或业务所有者；首席信息官；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 根据组织政策，系统注册服务于告知治理组织开发系统的计划或系统的存在；系统的关键特征；以及由于系统操作和使用对组织的预期安全和隐私影响。系统注册为组织提供管理和跟踪工具，以促进将系统纳入企业架构、实施与风险相称的保护，以及根据适用法律、行政命令、指令、法规、政策或标准进行安全和隐私态势报告。作为系统注册流程的一部分，组织将系统添加到组织范围的系统库存中。系统注册信息在完成分类步骤后用安全分类和系统特征信息更新。

参考文献： 无。

3.2 分类[74]

目的

分类步骤的目的是通过确定对组织运营和资产、个人、其他组织和国家的不利影响（关于组织系统及其处理、存储和传输的信息的机密性、完整性、可用性丧失），为组织风险管理流程和信息提供依据。

---

[74] 分类是确定信息或系统安全类别的过程。安全分类方法论在 CNSS 指令 1253（国家安全系统）和 FIPS 出版物 199（非国家安全系统）中描述。

分类任务

表 3 提供了 RMF 分类步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 3：分类任务和结果

任务	结果
任务 C-1 系统描述	· 描述并记录系统的特征 [网络安全框架：配置文件]
任务 C-2 安全分类	· 完成系统的安全分类，包括系统处理的信息（由组织识别的信息类型表示）[网络安全框架：ID.AM-1; ID.AM-2; ID.AM-3; ID.AM-4; ID.AM-5] · 在安全、隐私和 SCRM 计划中记录安全分类结果 [网络安全框架：配置文件] · 安全分类结果与企业架构一致，并致力于保护组织任务、业务功能和任务/业务流程 [网络安全框架：配置文件] · 安全分类结果反映组织的风险管理策略
任务 C-3 安全分类审查和批准	· 安全分类结果经审查，分类决定由组织高级领导者批准

快速链接到 RMF 任务、职责和支持角色的摘要表。

系统描述

任务 C-1 记录系统的特征。

潜在输入： 系统设计和需求文档；授权边界信息；分配给系统、系统元素和操作环境的安全和隐私要求列表；系统元素控制的物理或其他流程；系统元素信息；系统组件库存；系统元素供应链信息，包括库存和供应商信息；安全分类；系统处理、存储和传输的信息类型的信息生命周期数据映射；系统使用、用户和角色信息。

预期输出： 记录的系统描述。

主要责任： 系统所有者。

支持角色： 授权官员或授权官员指定代表；信息所有者或管理者；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 系统特征的描述记录在安全和隐私计划中，包括在计划的附件中，或引用为 SDLC 生成的信息的其他标准来源。尽可能避免信息重复。安全和隐私计划中的详细级别由组织确定，与系统的安全分类和安全和隐私风险评估相称。在系统生命周期期间、RMF 步骤执行期间以及任何系统特征变化时，随着信息变得可用，可以将其添加或更新到系统描述中。

组织可以在安全和隐私计划中包含的不同类型描述性信息示例包括：系统的描述性名称和系统标识符；系统版本或发布号；制造商和供应商信息；系统负责人；系统联系信息；管理、拥有或控制系统的组织；系统位置；系统目的和支持的任务/业务流程；系统如何整合到企业架构中；SDLC 阶段；分类流程和隐私风险评估的结果；授权边界；影响个人隐私和系统安全的法律、指令、政策、法规或标准；系统架构描述（包括网络拓扑）；信息类型；系统包含的硬件、固件和软件组件；硬件、软件和系统接口（内部和外部）；系统内的信息流；与外部系统通信的网络连接规则；互连系统及其标识符；系统元素控制的物理或其他流程、组件和设备；系统用户（包括隶属关系、访问权限、特权、公民身份）；供应链中的系统来源；维护或其他相关协议；系统替换组件的潜在供应商；替代兼容系统组件；库存中替换系统组件的数量和位置；系统所有权或运营（政府所有、政府运营；政府所有、承包商运营；承包商所有、承包商运营；非联邦 [州和地方政府、受赠者]）；事件响应联系人；授权日期和授权终止日期；以及持续授权状态。系统注册信息用系统特征信息更新（见任务 P-18）。

参考文献： [SP 800-18]；[NIST CSF]（核心 [识别功能]）。

安全分类

任务 C-2 对系统进行分类并记录安全分类结果。

潜在输入： 风险管理策略；组织风险容忍度；授权边界（即系统）信息；组织和系统级风险评估结果；系统处理、存储或传输的信息类型；分配给系统、系统元素和操作环境的安全和隐私要求列表；运营系统的组织授权或目的；业务影响分析或关键性分析；系统支持的任务、业务功能和任务/业务流程信息。

预期输出： 为每个信息类型和每个安全目标（机密性、完整性、可用性）确定的影响级别；基于信息类型影响级别高水位标记的安全分类。

主要责任： 系统所有者；信息所有者或管理者。

支持角色： 风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员或授权官员指定代表；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 安全分类决定考虑对组织运营、组织资产、个人、其他组织和国家的潜在不利影响，源于信息的机密性、完整性或可用性丧失。组织在使用 [FIPS 200] 建立基于高水位标记概念的系统单一影响级别（非国家安全系统），或使用 [CNSSI 1253] 为机密性、完整性和可用性每个安全目标建立三个可能不同的影响值（国家安全系统）方面具有灵活性。安全分类流程由系统所有者和信息所有者或管理者与具有任务、业务功能或风险管理职责的高级领导者和高管协作进行。协作有助于确保基于组织的任务和业务目标对单个系统进行分类。系统所有者和信息所有者或管理者考虑安全风险评估结果（当系统处理 PII 时还包括隐私风险评估）作为安全分类决定的一部分。决定与风险管理策略一致。分类流程的结果影响系统安全控制的选择。安全分类信息记录在系统安全计划中或作为计划附件包括，当系统处理 PII 时可以在隐私计划中交叉引用。

系统的安全分类结果可以由组织进一步细化，以促进具有相同影响级别的系统的影响级别优先排序（见任务 P-6）。组织进行的影响级别优先排序结果可用于帮助系统所有者进行控制选择和定制决策。

参考文献： [FIPS 199]；[FIPS 200]；[SP 800-30]；[SP 800-39]（系统层面）；[SP 800-59]；[SP 800-60 v1]；[SP 800-60 v2]；[SP 800-160 v1]（利益相关者需求和需求定义及系统需求定义流程）；[IR 8179]；[CNSSI 1253]；[NIST CSF]（核心 [识别功能]）。

安全分类审查和批准

任务 C-3 审查并批准安全分类结果和决定。

潜在输入： 为每个信息类型和每个安全目标（机密性、完整性、可用性）确定的影响级别；基于信息类型影响级别高水位标记的安全分类；组织高价值资产列表。

预期输出： 系统安全分类批准。

主要责任： 授权官员或授权官员指定代表；高级机构隐私官。[75]

支持角色： 风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 对于处理 PII 的信息系统，高级机构隐私官在授权官员审查之前审查并批准安全分类结果和决定。[76] 安全分类结果和决定由授权官员或指定代表审查，以确保为信息系统选择的安全类别与组织的任务和业务功能一致，并需要充分保护这些任务和功能。授权官员或指定代表从组织范围角度审查分类结果和决定，包括决定如何与所有其他组织系统的分类决定保持一致。授权官员与风险管理高级问责官员或风险执行（功能）协作，以确保系统分类决定与组织风险管理策略一致，并满足高价值资产的要求。作为批准流程的一部分，授权官员可以就 RMF 选择步骤中发生的系统基线定制活动的任何限制向系统所有者提供具体指导（见任务 S-2）。如果安全分类决定未获批准，系统所有者启动步骤重复分类流程，

并将调整后的结果重新提交给授权官员或指定代表。系统注册信息随后用批准的安全分类信息更新（见任务 P-18）。

---

[75] 对于处理 PII 的系统，高级机构隐私官在授权官员之前审查和批准安全分类。

[76] 高级机构隐私官负责审查和批准处理 PII 的系统的安全分类。

参考文献： [FIPS 199]；[SP 800-30]；[SP 800-39]（组织层面）；[SP 800-160 v1]（利益相关者需求和需求定义流程）；[CNSSI 1253]；[NIST CSF]（核心 [识别功能]）。

3.3 选择

目的

选择步骤的目的是选择、定制和记录必要的控制，以保护信息系统和组织与对组织运营和资产、个人、其他组织和国家的风险相称。

选择任务

表 4 提供了 RMF 选择步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 4：选择任务和结果

任务	结果
任务 S-1 控制选择	· 选择保护系统与风险相称所需的控制基线 [网络安全框架：配置文件]
任务 S-2 控制定制	· 定制控制产生定制控制基线 [网络安全框架：配置文件]
任务 S-3 控制分配	· 控制指定为系统特定、混合或公共控制 · 控制分配给特定系统元素（即机器、物理或人类元素）[网络安全框架：配置文件；PR.IP]
任务 S-4 计划控制实施的文档	· 控制和相关的定制行动记录在安全和隐私计划或等效文档中 [网络安全框架：配置文件]
任务 S-5 持续监控策略——系统	· 开发反映组织风险管理策略的系统持续监控策略 [网络安全框架：ID.GV; DE.CM]
任务 S-6 计划审查和批准	· 反映选择保护系统和操作环境与风险相称所需的控制的安全和隐私计划由授权官员审查和批准

快速链接到 RMF 任务、职责和支持角色的摘要表。

控制选择

任务 S-1 为系统和操作环境选择控制。

潜在输入： 安全分类；组织和系统级风险评估结果；系统元素信息；系统组件库存；分配给系统、系统元素和操作环境的安全和隐私要求列表；分配给系统或系统元素外部提供商的合同要求列表；业务影响分析或关键性分析；风险管理策略；组织安全和隐私政策；联邦或组织批准或强制的基线或覆盖层；网络安全框架配置文件。

预期输出： 为系统和操作环境选择的控制。

主要责任： 系统所有者；公共控制提供者。

支持角色： 授权官员或授权官员指定代表；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购。现有系统——操作/维护。

讨论： 有两种方法可用于初始控制选择：基线控制选择方法，或组织生成的控制选择方法。基线控制选择方法使用控制基线，这是专门为解决组、组织或利益共同体的保护需求而组装的预定义控制集。控制基线作为保护个人隐私、信息和信息系统的起点。联邦控制基线在 [SP 800-53B] 中提供。系统安全分类（见任务 C-2）和从利益相关者保护需求、法律、行政命令、法规、政策、指令、说明和标准派生的安全要求（见任务 P-15）有助于告知安全控制基线的选择。隐私风险评估（见任务 P-14）和从利益相关者保护需求、法律、行政命令、法规、政策、指令、说明和标准派生的隐私要求（见任务 P-15）有助于告知隐私控制基线的选择。隐私计划使用安全和隐私控制基线来管理来自未经授权系统活动或行为的隐私风险，以及来自授权活动的隐私风险。选择预定义控制基线后，组织根据提供的指导定制基线（见任务 S-2）。基线控制选择方法可以提供跨广泛利益共同体的一致性。

组织生成的控制选择方法与基线选择方法不同，因为组织不从预定义控制集开始。相反，组织使用自己的选择流程来选择控制。当系统高度专业化（例如，武器系统或医疗设备）或目的或范围有限（例如，智能电表）时，这可能是必要的。在这些情况下，对组织来说，为系统选择特定控制集（即自下而上方法）可能比从广泛基础控制基线的预定义控制集开始并通过定制流程随后消除控制（即自上而下方法）更高效和具有成本效益。

在基线控制选择方法和组织生成的控制选择方法中，组织都使用基于生命周期的系统工程流程（例如，[ISO 15288] 和 [SP 800-160 v1]）开发明确定义的安全和隐私要求集，如 RMF 准备 - 系统层面步骤（任务 P-15）中描述。此流程生成一组要求，可用于指导和告知选择一组控制来满足要求（无论组织是从控制基线开始还是从其自己的选择流程生成控制集）。同样，组织可以使用 [NIST CSF] 开发网络安全框架配置文件，代表一组组织特定的安全和隐私要求——因此，指导和告知从 [SP 800-53] 选择控制。在组织生成的控制选择方法中也可能需要定制（见任务 S-2）。组织不需要为每个系统的控制选择选择一种方法，而是可以根据情况使用不同的方法。

参考文献： [FIPS 199]；[FIPS 200]；[SP 800-30]；[SP 800-53]；[SP 800-53B]；[SP 800-160 v1]（系统需求定义、架构定义和设计定义流程）；[SP 800-161]（响应和第 3 章）；[IR 8062]；[IR 8179]；[CNSSI 1253]；[NIST CSF]（核心 [识别、保护、检测、响应、恢复功能]；配置文件）。

控制定制

任务 S-2 为系统和操作环境定制选择的控制。

潜在输入： 初始控制基线；组织和系统级风险评估结果；系统元素信息；系统组件库存；分配给系统、系统元素和操作环境的安全和隐私要求列表；业务影响分析或关键性分析；风险管理策略；组织安全和隐私政策；联邦或组织批准或强制的覆盖层。

预期输出： 系统和操作环境的定制控制列表（即定制控制基线）。

主要责任： 系统所有者；公共控制提供者。

支持角色： 授权官员或授权官员指定代表；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购。现有系统——操作/维护。

讨论： 选择适用的控制基线后，组织基于各种因素（例如，任务或业务功能、威胁、安全和隐私风险（包括供应链风险）、系统类型或风险容忍度）定制控制。定制流程包括识别和指定控制基线中的公共控制（见任务 P-5）；将范围考虑应用于剩余基线控制；选择补偿控制（如需要）；使用分配或选择语句为组织定义的控制参数赋值；用额外控制补充基线；以及提供控制实施的规范信息。[77] 组织确定定制决策所需的理由或支持原理的详细程度。例如，与高影响系统或高价值资产[78] 相关的范围决策的理由或支持原理可能需要比低影响系统的类似决策更大的特异性。此类决定与组织的任务和业务功能；利益相关者需求；以及任何相关法律、行政命令、法规、指令或政策一致。与 SDLC 和 SCRM 相关的控制为确定信息系统是否适合目的[79] 提供基础，需要相应定制。

---

[77] 定制是组织通过识别和指定公共控制、应用范围考虑、选择补偿控制、为组织定义的控制参数赋值、用额外控制或控制增强补充基线，以及为控制实施提供额外规范信息来修改安全控制基线的流程。

[78] 高价值资产是对组织使命至关重要的资产，需要增加保护级别。

[79] 适合目的是系统满足其预期目的的能力。

组织使用风险评估来告知和指导定制流程。来自安全风险评估的威胁信息提供有关对手能力、意图和 targeting 的信息，这些信息可能影响组织关于安全控制选择的决策，包括相关成本和收益。隐私风险评估（包括其中的上下文因素）也会在信息系统处理 PII 时影响定制。[80] 识别公共控制时也会利用风险评估结果，以确定可继承的控制是否满足系统及其操作环境的安全和隐私要求。当组织提供的公共控制未能为继承控制的系统提供充分保护时，系统所有者可以用系统特定或混合控制补充公共控制以实现所需的保护级别，或向授权官员建议更大程度地接受风险。组织在定制控制时还可以考虑联邦或组织指导或批准的覆盖层、定制基线或网络安全框架配置文件（见任务 P-4）。

---

[80] 隐私风险评估受上下文因素影响，包括 PII 的敏感度级别、使用或与系统交互的组织类型，以及个人的隐私利益。

参考文献： [FIPS 199]；[FIPS 200]；[SP 800-30]；[SP 800-53]；[SP 800-53B]；[SP 800-160 v1]（系统需求定义、架构定义和设计定义流程）；[SP 800-161]（响应和第 3 章）；[IR 8179]；[CNSSI 1253]；[NIST CSF]（核心 [识别、保护、检测、响应、恢复功能]；配置文件）。

控制分配

任务 S-3 将安全和隐私控制分配给系统和操作环境。

潜在输入： 安全分类；组织和系统级风险评估结果；组织关于系统注册的政策；企业架构；安全和隐私架构；安全和隐私要求；分配给系统、系统元素和操作环境的安全和隐私要求列表；公共控制提供者列表和可继承的公共控制；系统描述；系统元素信息；系统组件库存；相关法律、行政命令、指令、法规和政策。

预期输出： 分配给系统、系统元素和操作环境的安全和隐私控制列表。

主要责任： 安全架构师；隐私架构师；系统安全官；系统隐私官。

支持角色： 首席信息官；授权官员或授权官员指定代表；任务或业务所有者；高级机构信息安全官；高级机构隐私官；系统所有者。

系统开发生命周期阶段： 新系统——启动（概念/需求定义）。现有系统——操作/维护。

讨论： 组织将控制指定为系统特定、混合或公共，并将控制分配给负责提供安全或隐私能力的系统元素（即机器、物理或人类元素）。控制分配给系统或组织与组织的企业架构和安全或隐私架构一致，并与分配的安全和隐私要求一致。并非所有控制都需要分配给每个系统元素。提供特定安全或隐私能力的控制仅分配给需要该能力的系统元素。安全分类、隐私风险评估、安全和隐私架构，以及控制分配共同帮助实现安全与隐私保护和系统任务功能之间的适当平衡。

分配给系统、系统元素和操作环境的安全和隐私要求（见任务 P-17）指导和告知控制分配给系统元素。在 RMF 准备 - 组织层面步骤（见任务 P-5）期间由组织提供的可继承公共控制被选择继承；也选择混合控制。公共控制满足分配给组织的安全和隐私要求，并提供由一个或多个系统继承的保护能力。混合控制满足分配给系统和组织的安全和隐私要求，并提供由一个或多个系统部分继承的保护能力。最后，系统特定控制满足分配给系统的安全和隐私要求，并为该系统提供保护能力。控制可以分配给特定系统元素，而不是系统内的每个元素。例如，与审计日志管理相关的系统特定控制可以分配给日志管理服务器，不需要在每个系统元素上实施。

参考文献： [SP 800-39]（组织、任务/业务流程和系统层面）；[SP 800-64]；[SP 800-160 v1]（系统需求定义、架构定义和设计定义流程）；[NIST CSF]（核心 [识别功能]；配置文件）；[OMB FEA]。

计划控制实施的文档

任务 S-4 在安全和隐私计划中记录系统和操作环境的控制。

潜在输入： 安全分类；组织和系统级风险评估结果（安全、隐私和/或供应链）；系统元素信息；系统组件库存；业务影响或关键性分析；分配给系统、系统元素和操作环境的安全和隐私要求列表；风险管理策略；为系统和操作环境选择的控制列表；组织安全、隐私和 SCRM 政策。

预期输出： 系统的安全和隐私计划。

主要责任： 系统所有者；公共控制提供者。

支持角色： 授权官员或授权官员指定代表；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购。现有系统——操作/维护。

讨论： 安全和隐私计划包含系统安全和隐私要求的概述，以及为满足要求而选择的控制。计划描述每个选定控制在系统上下文中的预期应用，具有足够的详细级别以正确实施控制并随后评估控制的有效性。控制文档描述如何实施系统特定和混合控制，以及计划和对系统功能的期望。描述包括计划的输入、预期行为和预期输出（如适用），通常针对系统硬件、软件或固件组件中实施的控制。计划中还识别公共控制。不需要为继承的公共控制提供实施细节。相反，这些细节在公共控制提供者的计划中提供，并提供给系统所有者。对于混合控制，组织在系统级计划中指定由公共控制提供者提供的控制部分和在系统层面实施的控制部分。

组织可以开发整合安全和隐私计划的综合计划，或维护单独的计划。如果开发综合计划，隐私计划与安全计划协作，以确保计划反映选择的控制在管理 PII 的机密性、完整性和可用性方面提供保护；并 delineate 控制实施、评估和监控的角色和职责。对于单独的系统安全计划和隐私计划，组织在所有计划中交叉引用控制以帮助保持问责和意识。高级机构隐私官在计划提供给授权官员或指定代表审查之前审查并批准隐私计划（或综合计划）（见任务 S-6）。

组织可以在相当于安全和隐私计划的文档中记录控制选择和定制信息，例如在系统工程或系统生命周期工件或文档中。

计划控制实施的文档允许在系统部署之前和之后决策的可追溯性。组织尽可能参考现有文档（由供应商或其他采用相同或类似系统或系统元素的组织），使用自动支持工具，并在整个组织内协调以减少冗余并提高控制文档的效率和成本效益。文档还解决平台依赖性，并包括任何额外信息，以描述如何在足够详细的级别实现所需能力，以支持控制实施和评估。控制实施的文档遵循硬件和软件开发以及系统安全

和隐私工程学科的最佳实践，也与记录 SDLC 中活动的既定政策和程序一致。在某些情况下，安全控制的实施方式可能产生隐私风险。隐私计划支持记录隐私风险考虑和旨在缓解它们的实施。

对于基于机制的控制，组织利用制造商、供应商和系统集成商提供的或可获得的功能规范。这包括可能在控制开发、实施、评估和监控期间协助组织的任何文档。对于某些控制，组织从适当的组织实体（例如，物理安全办公室、设施办公室、记录管理办公室和人力资源办公室）获取控制实施信息。由于组织建立的企业架构以及安全和隐私架构指导和告知组织用于规划和实施控制的方法，记录流程有助于确保满足安全和隐私要求的可追溯性。

参考文献： [FIPS 199]；[FIPS 200]；[SP 800-18]；[SP 800-30]；[SP 800-53]；[SP 800-64]；[SP 800-160 v1]（系统需求定义、架构定义和设计定义流程）；[SP 800-161]（响应和第 3 章）；[IR 8179]；[CNSSI 1253]；[NIST CSF]（核心 [识别、保护、检测、响应、恢复功能]；配置文件）。

持续监控策略——系统

任务 S-5 制定并实施系统级策略以监控控制有效性，该策略与组织持续监控策略一致并补充该策略。

潜在输入： 组织风险管理策略；组织持续监控策略；组织和系统级风险评估结果；安全和隐私计划；组织安全和隐私政策。

预期输出： 系统的持续监控策略，包括持续授权的时间触发器。

主要责任： 系统所有者；公共控制提供者。

支持角色： 风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员或授权官员指定代表；信息所有者或管理者；安全架构师；隐私架构师；系统安全工程师；隐私工程师；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购。现有系统——操作/维护。

讨论： 风险管理的一个重要方面是持续监控信息系统内实施或继承的控制。在 SDLC 早期（即初始系统设计或采购决策期间）与组织持续监控策略协调制定和实施有效的系统级持续监控策略。系统级持续监控策略与组织的持续监控策略一致并补充该策略。系统级策略解决监控那些未作为组织持续监控策略和实施一部分提供监控的控制。系统级策略识别组织级策略未解决的控制的监控频率，并定义用于评估这些控制的方法。与组织监控策略一致的系统级持续监控策略定义如何监控系统和操作环境的变化[81]；如何进行风险评估；以及安全和隐私态势报告要求（包括报告接收者）。系统级持续监控策略可以包括在安全和隐私计划中。[82]

---

[81] 操作环境的变化包括技术、人类元素，以及物理或环境元素的变化。

[82] 系统级持续监控策略可以包括在安全和隐私计划中。

对于组织持续监控策略未解决的控制，系统级持续监控策略识别确定控制实施后监控频率的标准，以及持续评估这些控制的计划。标准由系统所有者或公共控制提供者与其他组织官员协作建立（例如，授权官员或指定代表；风险管理高级问责官员或风险执行 [功能]；高级机构信息安全官；高级机构隐私官；以及首席信息官）。系统级频率标准反映组织优先级以及系统对组织运营和资产、个人、其他组织和国家的重要性。易变的控制（即控制或控制实施最可能随时间变化的控制）、[83] 对组织某些保护需求方面至关重要的控制，或在行动计划和里程碑中识别的控制，可能需要更频繁的评估。持续监控期间的控制评估方法可以包括重用支持初始授权决策的评估程序和结果；检测系统元素的状态；以及分析历史和运营数据。

---

[83] 易变控制是控制或控制实施最可能随时间变化的控制。

授权官员或指定代表批准持续监控策略和每个控制监控的最小频率。策略的批准可以与安全和隐私计划批准一起获得。控制监控从 SDLC 的操作阶段开始，并持续到处置阶段。

参考文献： [SP 800-30]；[SP 800-39]（组织、任务或业务流程、系统层面）；[SP 800-53]；[SP 800-53A]；[SP 800-137]；[SP 800-161]；[IR 8011 v1]；[CNSSI 1253]；[NIST CSF]（核心 [检测功能]）。

计划审查和批准

任务 S-6 审查并批准系统和操作环境的安全和隐私计划。

潜在输入： 安全和隐私计划；组织和系统级风险评估结果。

预期输出： 授权官员批准的安全和隐私计划。

主要责任： 授权官员或授权官员指定代表。

支持角色： 风险管理高级问责官员或风险执行（功能）；首席信息官；首席采购官；高级机构信息安全官；高级机构隐私官。

系统开发生命周期阶段： 新系统——开发/采购。现有系统——操作/维护。

讨论： 授权官员或指定代表在风险管理高级问责官员或风险执行（功能）、首席信息官、高级机构信息安全官和高级机构隐私官的支持下审查安全和隐私计划，确定计划是否完整、一致，并满足系统的既定安全和隐私要求。基于此审查的结果，授权官员或指定代表可以建议对安全和隐私计划进行更改。如果计划不可接受，系统所有者或公共控制提供者对计划进行适当更改。如果计划可接受，授权官员或指定代表批准计划。

接受安全和隐私计划代表 SDLC 和风险管理流程中的重要里程碑。授权官员或指定代表通过批准计划，同意一组控制（即系统特定、混合或公共控制）以及控制的拟议实施描述，以满足系统和系统操作环境的安全和隐私要求。[84] 计划批准允许风险管理流程进入 RMF 实施步骤。计划批准还建立了成功完成 RMF 剩余步骤所需的工作量级别，并为系统或单个系统元素采购的安全和隐私规范提供基础。

[84] 接受安全和隐私计划是 SDLC 和风险管理流程中的重要里程碑。

参考文献： [SP 800-30]；[SP 800-53]；[SP 800-160 v1]（系统需求定义、架构定义和设计定义流程）。

3.4 实施

目的

实施步骤的目的是在系统和组织的安全和隐私计划中实施控制，并在基线配置中记录控制实施的具体细节。

实施任务

表 5 提供了 RMF 实施步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 5：实施任务和结果

任务	结果
任务 I-1 控制实施	· 实施安全和隐私计划中指定的控制 [网络安全框架：PR.IP-1] · 使用系统安全和隐私工程方法论在系统安全和隐私计划中实施控制 [网络安全框架：PR.IP-2]
任务 I-2 更新控制实施信息	· 记录计划控制实施的变更 [网络安全框架：PR.IP-1] · 基于控制实施期间获得的信息更新安全和隐私计划 [网络安全框架：配置文件]

快速链接到 RMF 任务、职责和支持角色的摘要表。

控制实施

任务 I-1 实施安全和隐私计划中的控制。

潜在输入： 批准的安全和隐私计划；系统设计文档；组织安全和隐私政策和程序；业务影响或关键性分析；企业架构信息；安全架构信息；隐私架构信息；分配给系统、系统元素和操作环境的安全和隐私要求列表；系统元素信息；系统组件库存；组织和系统级风险评估结果。

预期输出： 已实施的控制。

主要责任： 系统所有者；公共控制提供者。

支持角色： 信息所有者或管理者；安全架构师；隐私架构师；系统安全工程师；隐私工程师；系统安全官；系统隐私官；企业架构师；系统管理员。

系统开发生命周期阶段： 新系统——开发/采购；实施/评估。现有系统——操作/维护。

讨论： 组织实施安全和隐私计划中描述的控制。控制实施与组织的企业架构和相关安全和隐私架构一致。组织实施控制时使用最佳实践，包括系统安全和隐私工程方法论、概念和原则。风险评估指导和告知关于使用不同技术或政策进行控制实施的成本、效益和风险权衡的决策。组织还确保根据联邦和组织政策在系统元素上建立和实施强制配置设置。当组织对系统元素中实施的控制没有直接控制时（例如，在商业现成产品中），组织考虑使用已由批准的独立第三方评估设施测试、评估或验证的系统元素（例如，NIST 加密模块验证计划测试实验室、国家信息保证合作伙伴共同标准测试实验室）。测试、评估和验证考虑特定配置和隔离状态下的产品；控制实施解决产品如何整合到系统中，同时保留安全功能和保证。

组织在实施控制时还解决保证要求（如适用）。保证要求针对控制开发者和实施者执行的活动，以增加对控制正确实施、按预期运行并产生满足系统安全和隐私要求的预期结果的信心级别。保证要求解决控制设计、开发和实施的质量。[85]

---

[85] 保证要求解决控制设计、开发和实施的质量。

对于系统继承的公共控制，系统安全和隐私工程师在系统安全和隐私官的支持下，与公共控制提供者协调以确定实施公共控制的最适当方式。系统所有者可以参考公共控制提供者准备的授权包，在确定其系统继承的公共控制充分性时进行决策。在实施期间，可能确定先前选择由系统继承的公共控制未满足系统的指定安全或隐私要求。对于未满足继承控制系统要求的公共控制或当公共控制有不可接受的缺陷时，系统所有者识别要实施的补偿或补充控制。系统所有者可以用系统特定或混合控制补充公共控制，以实现其系统的所需保护，或者他们可以在组织知晓和批准下接受更大风险。风险评估可以确定系统和公共控制之间的安全或隐私要求差距如何影响与系统相关的风险，以及如何优先排序需要补偿或补充控制以缓解特定风险的需求。

与 RMF 中应用任务的灵活性一致，组织在系统开发和实施期间进行初始控制评估。在 SDLC 的开发和实施阶段并行进行此类评估有助于早期识别缺陷，并提供启动纠正措施的具有成本效益的方法。在这些评估期间发现的问题可以提交给授权官员解决。初始控制评估的结果也可以在授权步骤期间使用，以避免延迟或昂贵的评估重复。随后在 SDLC 其他阶段重用的评估结果满足组织建立的重用要求。[86]

---

[86] 重用要求是组织建立的关于在什么情况下评估结果可以在 SDLC 的不同阶段重用。

参考文献： [FIPS 200]；[SP 800-30]；[SP 800-53]；[SP 800-53A]；[SP 800-160 v1]（实施、集成、验证和过渡流程）；[SP 800-161]；[IR 8062]；[IR 8179]。

更新控制实施信息

任务 I-2 根据控制的"已实施"状态记录计划控制实施的变更。

潜在输入： 安全和隐私计划；来自控制实施工作的信息。

预期输出： 用足够详细的实施信息更新的安全和隐私计划以供评估员使用；系统配置基线。

主要责任： 系统所有者；公共控制提供者。

支持角色： 信息所有者或管理者；安全架构师；隐私架构师；系统安全工程师；隐私工程师；系统安全官；系统隐私官；企业架构师；系统管理员。

系统开发生命周期阶段： 新系统——开发/采购；实施/评估。现有系统——操作/维护。

讨论： 尽管安全和隐私计划以及系统设计文档中有控制实施细节，但按计划实施控制并不总是可行的。因此，随着控制实施的执行，用已实施控制实施细节更新安全和隐私计划。更新包括已实施控制的修订描述，包括对计划输入、预期行为和预期输出的变更，具有支持控制评估的足够详细信息。记录"已实施"控制信息对于确定控制何时发生变化、这些变化是否授权，以及对系统和组织的安全和隐私态势的影响的能力至关重要。

参考文献： [SP 800-53]；[SP 800-128]；[SP 800-160 v1]（实施、集成、验证和过渡、配置管理流程）。

3.5 评估

目的

评估步骤的目的是确定为实施选择的控制是否正确实施、按预期运行，并在满足系统和组织的安全和隐私要求方面产生预期结果。

评估任务

表 6 提供了 RMF 评估步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 6：评估任务和结果

任务	结果
任务 A-1 评估员选择	· 选择评估员或评估团队进行控制评估 · 为选定的评估员或评估团队实现适当的独立性级别
任务 A-2 评估计划	· 向评估员或评估团队提供进行评估所需的文档 · 制定并记录安全和隐私评估计划 · 审查并批准安全和隐私评估计划，以建立控制评估的预期和所需工作量
任务 A-3 控制评估	· 根据安全和隐私评估计划进行控制评估 · 考虑重用先前评估结果的机会，使风险管理流程及时和具有成本效益 · 最大化使用自动化进行控制评估，以提高评估的速度、有效性和效率
任务 A-4 评估报告	· 完成提供发现和建议的安全和隐私评估报告
任务 A-5 补救行动	· 采取补救行动以解决系统和操作环境中实施的控制的缺陷 · 更新安全和隐私计划以反映基于评估和后续补救行动的控制实施变更 [网络安全框架：配置文件]
任务 A-6 行动计划和里程碑	· 制定行动计划和里程碑，详细说明安全和隐私评估报告中识别的不可接受风险的补救计划 [网络安全框架：ID.RA-6]

快速链接到 RMF 任务、职责和支持角色的摘要表。

评估员选择

任务 A-1 为要进行控制评估的类型选择适当的评估员或评估团队。

潜在输入： 安全、隐私和 SCRM 计划；项目管理控制信息；公共控制文档；组织安全和隐私计划计划；SCRM 策略；系统设计文档；企业、安全和隐私架构信息；适用于系统的安全、隐私和 SCRM 政策和程序。

预期输出： 选择负责进行控制评估的评估员或评估团队。

主要责任： 授权官员或授权官员指定代表。

支持角色： 首席信息官；高级机构信息安全官；高级机构隐私官。

系统开发生命周期阶段： 新系统——开发/采购；实施/评估。现有系统——操作/维护。

讨论： 组织在选择控制评估员时考虑所需的技术专业知识和独立性级别。[87] 组织确保控制评估员具备所需的技能和技术专业知识，以制定有效的评估计划，并对项目管理、系统特定、混合和公共控制进行适当评估。这包括对风险管理概念和方法的一般知识，以及对实施的硬件、软件和固件组件的全面知识和经验。在集中管理评估能力的组织中，高级机构信息安全官可能负责为组织系统选择和管理安全控制评估员或评估团队。由于控制可能实施以实现安全和隐私目标，组织考虑安全控制和隐私控制评估员之间必要的协作程度。

---

[87] 独立性意味着评估员在确定控制有效性或系统、公共控制或项目管理控制的开发、操作或管理方面没有感知或实际的利益冲突。

组织可以进行控制自我评估，或获得独立控制评估员的服务。独立评估员是可以进行公正评估的个人或小组。公正意味着评估员在确定控制有效性或系统、公共控制或项目管理控制的开发、操作或管理方面没有感知或实际的利益冲突。授权官员根据适用法律、行政命令、指令、法规、政策或标准确定评估员独立性级别。授权官员与监察长办公室、首席信息官、高级机构隐私官和高级机构信息安全官协商，以帮助指导和告知关于评估员独立性的决策。

系统隐私官负责识别评估方法论和指标，以确定隐私控制是否正确实施、按预期运行，并足以确保遵守适用的隐私要求和管理隐私风险。高级机构隐私官负责进行隐私控制评估并记录评估结果。由组织自行决定，隐私控制可以由独立评估员评估。然而，在所有情况下，高级机构隐私官对组织的隐私计划负责和问责，包括独立评估员执行的任何隐私功能。高级机构隐私官负责向授权官员提供隐私信息。

参考文献： [FIPS 199]；[SP 800-30]；[SP 800-53A]；[SP 800-55]。

评估计划

任务 A-2 制定、审查和批准评估已实施控制的计划。

潜在输入： 安全、隐私和 SCRM 计划；项目管理控制信息；公共控制文档；组织安全和隐私计划计划；SCRM 策略；系统设计文档；供应链信息；企业、安全和隐私架构信息；适用于系统的安全、隐私和 SCRM 政策和程序。

预期输出： 授权官员批准的安全和隐私评估计划。

主要责任： 授权官员或授权官员指定代表；控制评估员。

支持角色： 高级机构信息安全官；高级机构隐私官；系统所有者；公共控制提供者；信息所有者或管理者；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购；实施/评估。现有系统——操作/维护。

讨论： 控制评估员根据安全和隐私计划、项目管理控制文档和公共控制文档中包含的实施信息制定安全和隐私评估计划。组织可以选择为系统或组织开发单个综合安全和隐私评估计划。综合评估计划 delineate 控制评估的角色和职责。评估计划还提供控制评估的目标和每个控制的具体评估程序。评估计划反映组织正在进行的评估类型，包括例如：开发测试和评估；独立验证和确认；审计（包括供应链）；支持系统和公共控制授权或再授权的评估；项目管理控制评估；持续监控；以及补救行动后进行的评估。

评估计划由授权官员或授权官员的指定代表审查和批准，以帮助确保计划与组织的安全和隐私目标一致；采用支持持续监控和近乎实时风险管理的程序、方法、技术、工具和自动化；并且具有成本效益。批准的评估计划建立控制评估的预期和评估工作量级别。批准的评估计划有助于确保将适当的资源应用于确定控制有效性，同时在做出此类确定时提供必要的保证级别。当控制通过合同、机构间协议、业务线安排、许可协议或供应链安排由外部提供商提供时，组织可以请求提供商的安全和隐私评估计划和评估结果或证据。

参考文献： [SP 800-53A]；[SP 800-160 v1]（验证和确认流程）；[SP 800-161]；[IR 8011 v1]。

控制评估

任务 A-3 根据评估计划中描述的评估程序评估控制。

潜在输入： 安全和隐私评估计划；安全和隐私计划；外部评估或审计结果（如适用）。

预期输出： 完成的控制评估和相关评估证据。

主要责任： 控制评估员。

支持角色： 授权官员或授权官员指定代表；系统所有者；公共控制提供者；信息所有者或管理者；高级机构信息安全官；高级机构隐私官；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购；实施/评估。现有系统——操作/维护。

讨论： 控制评估确定选定控制在多大程度上正确实施、按预期运行，并在满足系统和组织的安全和隐私要求方面产生预期结果。系统所有者、公共控制提供者和/或组织依赖评估员的技术技能和专业知识，使用评估计划中指定的评估程序评估已实施的控制，并就如何响应控制缺陷以减少或消除识别的漏洞或不可接受风险提供建议。高级机构隐私官担任隐私控制的控制评估员，负责在系统操作之前进行隐私控制的初始评估，并在此后以足以确保遵守隐私要求和管理隐私风险的频率定期评估控制。[88] 实施以实现安全和隐私目标的控制可能需要安全和隐私控制评估员之间一定程度的协作。评估员发现是对控制是否按预期运行的事实报告，以及在评估期间是否发现控制的任何缺陷。[89]

---

[88] 高级机构隐私官负责进行隐私控制评估并记录评估结果。

[89] 缺陷是控制中的弱点，可能导致安全或隐私风险。

控制评估在 SDLC 中尽早进行，最好在开发阶段。这些类型的评估称为开发测试和评估，验证控制是否正确实施并与既定的信息安全和隐私架构一致。开发测试和评估活动包括例如设计和代码审查、回归测试和应用程序扫描。SDLC 早期识别的缺陷可以以更具成本效益的方式解决。在采购流程中的源选择之前可能需要进行评估，以在组织进入协议或合同开始开发阶段之前评估潜在供应商或提供商。SDLC 期间进行的控制评估结果也可以在授权流程中使用（与组织建立的重用标准一致），以避免不必要的延迟或昂贵的评估重复。组织可以最大化使用自动化进行控制评估，以提高评估的速度、有效性和效率，并支持持续监控组织系统的安全和隐私态势。

对迭代开发流程可能适合在整个开发过程中应用和评估控制。当采用迭代开发流程（例如，敏捷开发）时，可以在每个周期完成时进行迭代评估。对系统中使用的商业 IT 产品评估控制也采用类似流程。组织可以选择在安全和隐私计划中的所有控制完全实施之前开始评估控制。如果更高效或具有成本效益，这种增量评估是适当的。

公共控制（即由系统继承的控制）单独评估（由公共控制提供者或组织选择的评估员），不需要作为系统级评估的一部分进行评估。

组织确保评估员可以访问实施控制的操作系统和操作环境，以及评估控制所需的文档、记录、工件、测试结果和其他材料。这包括外部提供商通过合同、机构间协议、业务线安排、许可协议或供应链安排实施的控制。评估员具有授权官员确定的所需独立性级别。[90] 持续监控流程期间的评估员独立性促进评估结果的重用，以支持持续授权和再授权。

---

[90] 评估员独立性是授权官员确定的因素，以保留公正和公正的评估流程。

为了使风险管理流程更高效和具有成本效益，组织可以选择建立合理和适当的标准，作为组织范围评估政策或安全和隐私计划计划的一部分重用评估结果。例如，最近对系统的审计可能产生了关于选定控制有效性的信息。重用先前评估结果的另一个机会可能来自测试和评估商业信息技术产品的安全和隐私功能的外部程序（例如，共同标准评估和验证计划以及 NIST 加密模块验证计划）。如果有来自系统开发者或供应商的先前评估结果，控制评估员在适当情况下可以将这些结果纳入评估。此外，如果在 SDLC 的其他阶段的其他形式评估期间评估了控制实施（例如，单元测试、功能测试、验收测试），组织可以考虑重用这些结果的潜力以减少重复工作。最后，评估结果可以重用以支持互惠，例如支持使用授权（见附录 F）的评估结果。关于评估结果重用的额外信息可在 [SP 800-53A] 中获得。

参考文献： [SP 800-53A]；[SP 800-160 v1]（验证和确认流程）；[IR 8011 v1]。

评估报告

任务 A-4 准备记录控制评估发现和建议的评估报告。

潜在输入： 完成的控制评估和相关评估证据。

预期输出： 完成的安全和隐私评估报告，详细说明评估员发现和建议。

主要责任： 控制评估员。

支持角色： 系统所有者；公共控制提供者；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购；实施/评估。现有系统——操作/维护。

讨论： 安全和隐私控制评估的结果（包括纠正已实施控制缺陷的建议）由控制评估员记录在评估报告[92]中。组织可以开发单个综合安全和隐私评估报告。评估报告是为授权官员开发的系统或公共控制授权包中的关键文档。评估报告包括基于评估员发现的信息，对于确定信息系统内或继承的控制的有效性是必要的。评估报告是授权官员确定对组织运营和资产、个人、其他组织和国家的风险的重要因素。评估报告中提供的格式和详细级别适用于进行的控制评估类型，例如开发测试和评估；独立验证和确认；支持信息系统或公共控制授权或再授权的独立评估；自我评估；补救行动后的评估；独立评估或审计；以及持续监控期间的评估。报告格式也可以由组织规定。

---

[92] 评估报告是记录控制评估结果和建议的关键文档。

系统开发生命周期期间获得的控制评估结果记录在临时报告中，并包括在最终安全和隐私评估报告中。记录 SDLC 相关阶段评估结果的临时报告的开发加强了评估报告是演变文档的概念。临时报告在适当时用于告知最终评估报告。组织可以选择从控制评估结果开发执行摘要。执行摘要为授权官员和组织内的其他感兴趣个人提供评估报告的缩写版本，包括评估、发现和建议的概要，以解决控制中的缺陷。

参考文献： [SP 800-53A]；[SP 800-160 v1]（验证和确认流程）。

补救行动

任务 A-5 对控制进行初始补救行动，并重新评估补救的控制。

潜在输入： 完成的安全和隐私评估报告（包含发现和建议）；安全和隐私计划；安全和隐私评估计划；组织和系统级风险评估结果。

预期输出： 基于安全和隐私评估报告完成的初始补救行动；评估团队重新评估的变更实施；更新的安全和隐私评估报告；更新的安全和隐私计划（包括控制实施的变更）。

主要责任： 系统所有者；公共控制提供者；控制评估员。

支持角色： 授权官员或授权官员指定代表；高级机构信息安全官；高级机构隐私官；风险管理高级问责官员或风险执行（功能）；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——开发/采购；实施/评估。现有系统——操作/维护。

讨论： 安全和隐私评估报告描述系统开发期间无法解决的控制缺陷，或开发后发现的缺陷。此类控制缺陷可能导致安全和隐私风险（包括供应链风险）。控制评估期间生成的发现提供信息，促进基于组织风险容忍度和优先级的风险响应。授权官员与系统所有者和其他组织官员协商和协调，可以决定某些发现代表重大的、不可接受的风险，需要立即补救行动。此外，对于可以快速轻松地用现有资源补救的评估发现，可能可行和实用进行初始补救行动。

如果采取初始补救行动，评估员重新评估控制。控制重新评估确定补救控制在多大程度上正确实施、按预期运行，并在满足系统和组织的安全和隐私要求方面产生预期结果。评估员用重新评估的发现更新评估报告，但不更改原始评估结果。基于控制评估的发现和采取的任何补救行动更新安全和隐私计划。更新后的计划反映初始评估后的控制状态，以及系统所有者或公共控制提供者在解决纠正行动建议方面进行的任何修改。在控制评估完成时，安全和隐私计划包含已实施控制的准确描述，包括补偿控制。

组织可以准备安全和隐私评估报告的附录，为系统所有者和公共控制提供者提供响应初始评估发现的机会。附录可以包括例如关于系统所有者或公共控制提供者响应评估员发现采取的初始补救行动的信息。附录还可以提供系统所有者或公共控制提供者对发现的观点。这可能包括提供额外的解释材料、反驳某些发现，以及纠正记录。附录不更改或影响报告中提供的初始评估员发现。授权官员在做出基于风险的授权决策时考虑附录中提供的信息。组织实施流程以确定评估期间识别的控制缺陷的初始行动。此流程可以解决漏洞和风险、误报，以及其他为授权官员提供有关系统和组织安全和隐私态势（包括系统特定、混合和公共控制的持续有效性）的有用信息的因素。问题解决流程还可以确保只有实质性项目被识别并转移到行动计划和里程碑。

系统级控制评估的发现可能需要更新系统风险评估和组织风险评估。[93] 更新的风险评估和来自风险管理高级问责官员或风险执行（功能）的任何输入确定初始补救行动和这些行动的优先排序。系统所有者和公共控制提供者可以基于系统或组织风险评估决定某些发现无关紧要且不构成重大安全或隐私风险。此类发现保留在安全和隐私评估报告中，并在监控步骤期间监控。授权官员负责审查和理解评估员发现，并接受因系统操作或使用公共控制而产生的安全和隐私风险（包括任何供应链风险）。

---

[93] 系统级控制评估的发现可能需要更新系统风险评估和组织风险评估。

在所有情况下，组织审查评估员发现以确定发现的重要性，以及发现是否需要任何进一步调查或补救。高级领导层参与补救流程是必要的，以确保组织的资源根据组织优先级有效分配——将资源提供给支持最关键任务和业务功能的系统，或纠正构成最大风险的缺陷。

参考文献： [SP 800-53A]；[SP 800-160 v1]（验证和确认流程）。

行动计划和里程碑

任务 A-6 基于评估报告的发现和建议准备行动计划和里程碑。

潜在输入： 更新的安全和隐私评估报告；更新的安全和隐私计划；组织和系统级风险评估结果；组织风险管理策略和风险容忍度。

预期输出： 行动计划和里程碑，详细说明安全和隐私评估报告中要补救的发现。

主要责任： 系统所有者；公共控制提供者。

支持角色： 信息所有者或管理者；系统安全官；系统隐私官；高级机构信息安全官；高级机构隐私官；控制评估员；首席采购官。

系统开发生命周期阶段： 新系统——实施/评估。现有系统——操作/维护。

讨论： 行动计划和里程碑包括在授权包中。行动计划和里程碑描述计划采取的行动，以纠正控制评估期间和持续监控期间识别的控制缺陷。行动计划和里程碑包括要完成的任务，并建议在系统授权之前或之后完成；完成任务所需的资源；为完成任务建立的里程碑；以及里程碑和任务的预定完成日期。授权官员审查行动计划和里程碑，以确保同意计划采取的补救行动以纠正识别的缺陷。随后用于监控完成行动的进展。缺陷由授权官员接受为残余风险，或在评估期间或在提交授权包给授权官员之前补救。当缺陷由授权官员接受为残余风险时，不需要行动计划和里程碑条目。然而，评估和监控期间识别的缺陷记录在评估报告中，可以保留在自动化安全/隐私管理和报告工具中，以维护有效的审计跟踪。组织根据从控

制评估、审计和持续监控获得的评估结果，并按照适用法律、行政命令、指令、政策、法规、标准或指南，制定行动计划和里程碑。

组织实施一致的流程来制定行动计划和里程碑，该流程使用整个组织统一的优先排序方法进行风险缓解。风险评估指导行动计划和里程碑中包含项目的优先排序流程。该流程确保行动计划和里程碑由系统的安全分类以及安全、隐私和供应链风险评估告知；控制中的特定缺陷；识别的控制缺陷的关键性（即缺陷对系统和组织安全和隐私态势的直接或间接影响，因此对组织的风险暴露；或组织执行其任务或业务功能的能力）；以及解决控制中识别的缺陷的拟议风险缓解方法（例如，风险缓解行动的优先排序和风险缓解资源的分配）。风险缓解资源包括例如人员、新硬件或软件，以及工具。

参考文献： [SP 800-30]；[SP 800-53A]；[SP 800-160 v1]（验证和确认流程）；[IR 8062]。

3.6 授权

目的

授权步骤的目的是通过要求高级管理官员确定基于系统操作或使用公共控制对组织运营和资产、个人、其他组织或国家的安全和隐私风险（包括供应链风险）是否可接受，来提供组织问责。

授权任务

表 7 提供了 RMF 授权步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 7：授权任务和结果

任务	结果
任务 R-1 授权包	· 制定授权包并提交给授权官员进行授权决定
任务 R-2 风险分析和确定	· 授权官员反映风险管理策略（包括风险容忍度）的风险确定
任务 R-3 风险响应	· 为确定的风险提供风险响应 [网络安全框架：ID.RA-6]
任务 R-4 授权决定	· 系统或公共控制的授权批准或拒绝
任务 R-5 授权报告	· 向组织官员报告授权决定、重大漏洞和风险

快速链接到 RMF 任务、职责和支持角色的摘要表。

授权包

任务 R-1 组装授权包，并将包提交给授权官员进行授权决定。

潜在输入： 安全和隐私计划；安全和隐私评估报告；行动计划和里程碑；支持评估证据或其他文档（如需要）。

预期输出： 授权包（含执行摘要），可由安全或隐私管理工具[94] 生成以提交给授权官员。

---

[94] 安全或隐私管理工具是用于准备和管理授权包内容的自动化支持工具。

主要责任： 系统所有者；公共控制提供者；高级机构隐私官。[95]

支持角色： 系统安全官；系统隐私官；高级机构信息安全官；控制评估员。

系统开发生命周期阶段： 新系统——实施/评估。现有系统——操作/维护。

讨论： 授权包[96] 包括安全和隐私计划、安全和隐私评估报告、行动计划和里程碑，以及执行摘要。额外信息可以根据授权官员的请求包括在授权包中。随着授权包中信息的更新，组织维护版本和变更控制。对计划、评估报告和行动计划和里程碑的及时持续更新支持近乎实时风险管理和持续授权的概念，并可用于再授权行动（如需要）。

---

[95] 高级机构隐私官审查处理 PII 系统的授权包，以确保遵守适用的隐私要求并在授权官员做出风险确定和接受决定之前管理隐私风险。

[96] 授权包是授权官员用于确定是否授权信息系统操作或提供指定公共控制集的基本信息。

高级机构隐私官审查处理 PII 系统的授权包，以确保遵守适用的隐私要求并在授权官员做出风险确定和接受决定之前管理隐私风险。

授权包中的信息由授权官员用于做出知情、基于风险的决策。当控制通过合同、机构间协议、业务线安排、许可协议或供应链安排由外部提供商实施时，组织确保提供商提供做出基于风险决策所需的信息。

授权包可以硬拷贝或电子方式提供给授权官员，或使用自动化安全/隐私管理和报告工具生成。组织可以使用自动化支持工具准备和管理授权包的内容。自动化支持工具为维护更新授权官员关于组织内信息系统持续安全和隐私态势的信息提供有效载体。

当信息系统处于持续授权下时，授权包通过自动化报告呈现给授权官员，以尽可能最高效和及时的方式提供信息。[97] 呈现给授权官员的评估报告中的信息使用来自信息安全和隐私持续监控计划的信息，以组织确定的格式和频率生成。

---

[97] 当系统处于持续授权下时，授权包通过自动化报告呈现给授权官员。

呈现给授权官员的评估报告包括关于系统特定、混合和公共控制缺陷的信息（即评估员确定的满意发现除外）。授权官员使用自动化安全/隐私管理和报告工具或其他自动化方法（如可行）访问安全和隐私计划以及行动计划和里程碑。授权文档使用自动化或手动流程按组织定义的频率更新，符合组织的风险管理目标。[98]

---

[98] 授权文档使用自动化或手动流程按组织定义的频率更新。

参考文献： [OMB A-130]；[SP 800-18]；[SP 800-160 v1]（风险管理流程）；[SP 800-161]（SCRM 计划）。

风险分析和确定

任务 R-2 分析和确定来自系统或公共控制操作或使用的风险。

潜在输入： 授权包；支持评估证据或其他文档（如需要）；风险管理高级问责官员或风险执行（功能）提供的信息；组织风险管理策略和风险容忍度；组织和系统级风险评估结果。

预期输出： 风险确定。

主要责任： 授权官员或授权官员指定代表。

支持角色： 风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官。

系统开发生命周期阶段： 新系统——实施/评估。现有系统——操作/维护。

讨论： 授权官员或指定代表与高级机构信息安全官和高级机构隐私官（对于处理 PII 的信息系统）协作，分析控制评估员、系统所有者或公共控制提供者提供的授权包中的信息，并最终确定风险确定。与控制评估员、系统所有者或公共控制提供者的进一步讨论可能是必要的，以帮助确保授权官员对风险的透彻理解。

风险评估用于提供可能影响风险分析和确定的信息。[99] 风险管理高级问责官员或风险执行（功能）可以向授权官员提供额外信息，这些信息在最终确定对组织运营和资产、个人、其他组织和国家的风险确定时考虑，源于系统或公共控制的操作或使用。额外信息可以包括例如组织风险容忍度、系统和控制之间的依赖关系、任务和业务要求、系统支持的任务或业务功能的关键性，或风险管理策略。

---

[99] 风险评估用于提供可能影响风险分析和确定的信息。

授权官员在做出风险确定时分析风险管理高级问责官员或风险执行（功能）提供的信息，以及系统所有者或公共控制提供者在授权包中提供的信息。风险管理高级问责官员或风险执行（功能）提供的任何额外信息都记录下来，并在相关程度上作为授权决定的一部分包括（见任务 R-4）。授权官员还可以使用自动化安全/隐私管理和报告工具注释风险管理高级问责官员或风险执行（功能）的输入。

当系统在持续授权下操作时，风险确定任务实际上保持不变。授权官员分析自动化安全/隐私管理和报告工具提供的相关安全和隐私信息，以确定系统的当前安全和隐私态势。

参考文献： [OMB A-130]；[SP 800-30]；[SP 800-39]（组织、任务/业务流程和系统层面）；[SP 800-137]；[SP 800-160 v1]（风险管理流程）；[IR 8062]。

风险响应

任务 R-3 识别并实施响应确定风险的首选行动方案。

潜在输入： 授权包；风险确定；组织和系统级风险评估结果。

预期输出： 为确定的风险提供风险响应。

主要责任： 授权官员或授权官员指定代表。

支持角色： 风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官；系统所有者或公共控制提供者；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——实施/评估。现有系统——操作/维护。

讨论： 分析并确定风险后，组织可以以各种方式响应风险，包括接受风险和缓解风险。现有风险评估结果和风险评估技术可用于帮助确定风险响应的首选行动方案。[100] 当对风险的响应是缓解时，计划的缓解行动包括在行动计划和里程碑中并使用其跟踪。一旦缓解，评估员重新评估控制。控制重新评估确定补救控制在多大程度上正确实施、按预期运行，并在满足系统和组织的安全和隐私要求方面产生预期结果。评估员用重新评估的发现更新评估报告，但不更改原始评估结果。基于控制评估的发现和采取的任何补救行动更新安全和隐私计划。更新后的计划反映初始评估后的控制状态，以及系统所有者或公共控制提供者在解决纠正行动建议方面进行的任何修改。

---

[100] 现有风险评估结果和风险评估技术可用于帮助确定风险响应的首选行动方案。

在控制重新评估完成时，安全和隐私计划包含已实施控制的准确描述，包括补偿控制。当对风险的响应是接受时，评估流程期间发现的缺陷保留在安全和隐私评估报告中，并监控风险因素的变化。[101] 因为授权官员是唯一可以接受风险的人，授权官员负责审查评估报告和行动计划和里程碑，并确定识别的风险是否需要在授权之前缓解。关于响应风险的最适当行动方案的决策可能包括某种形式的优先排序。一些

风险可能比其他风险对组织更受关注。在这种情况下，可能需要将更多资源用于解决更高优先级的风险与更低优先级的风险。优先排序风险响应并不一定意味着更低优先级的风险被忽略。相反，它可能意味着将较少资源用于解决更低优先级的风险，或更低优先级的风险稍后解决。基于风险的决策流程的关键部分是认识到无论风险响应如何，仍存在一定程度的残余风险。组织基于组织风险容忍度确定可接受程度的残余风险。

---

[101] 当对风险的响应是接受时，评估流程期间发现的缺陷保留在安全和隐私评估报告中，并监控风险因素的变化。

参考文献： [SP 800-30]；[SP 800-39]（组织、任务/业务流程和系统层面）；[SP 800-160 v1]（风险管理流程）；[IR 8062]；[IR 8179]；[NIST CSF]（核心 [识别功能]）。

授权决定

任务 R-4 确定来自信息系统操作或使用或公共控制提供或使用的风险是否可接受。

潜在输入： 为确定的风险提供的风险响应。

预期输出： 运营授权、使用授权、公共控制授权；拒绝运营授权、拒绝使用授权、拒绝公共控制授权。

主要责任： 授权官员。

支持角色： 风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员指定代表。

系统开发生命周期阶段： 新系统——实施/评估。现有系统——操作/维护。

讨论： 明确接受风险是授权官员的责任，不能委托给组织内的其他官员。授权官员在决定对组织的运营（包括任务、功能、形象和声誉）和资产、个人、其他组织或国家的风险是否可接受时考虑许多因素。平衡安全和隐私考虑与任务和业务需求对于实现可接受的基于风险的授权决定至关重要。[102] 授权官员在审查授权包中的信息、其他组织官员的输入（见任务 R-2）以及其他可能影响授权决定的相关信息后，为系统或组织指定的公共控制发布授权决定。授权包提供系统或公共控制安全和隐私态势的最新信息。

---

[102] 平衡安全和隐私考虑与任务和业务需求对于实现可接受的基于风险的授权决定至关重要。

授权官员在为信息系统或公共控制做出最终授权决定之前与风险管理高级问责官员或风险执行（功能）协商。由于组织系统之间以及与外部系统之间可能存在重大依赖关系，单个系统的授权决定考虑当前残余风险、组织行动计划和里程碑，以及组织的风险容忍度。

授权决定由授权官员传达给系统所有者或公共控制提供者，以及其他组织官员（如适用）。[103] 授权决定还传达运营授权的条款和条件；授权终止日期或时间驱动的授权频率；风险管理高级问责官员或风险执行（功能）的输入（如提供）；以及对于公共控制授权，公共控制支持的系统影响级别。

---

[103] 授权决定由授权官员传达给系统所有者或公共控制提供者，以及其他组织官员（如适用）。

对于系统，授权决定向系统所有者指示系统是授权运营还是授权使用，或未授权运营或未授权使用。对于公共控制，授权决定向公共控制提供者和继承系统的系统所有者指示公共控制是否授权提供或未授权提供。公共控制授权的条款和条件提供对系统或控制操作施加的任何特定限制或约束的描述，系统所有者或公共控制提供者必须遵循。

授权终止日期由授权官员建立，指示授权何时到期。如果系统在持续授权下操作，组织可以消除授权终止日期——即，持续监控计划足够强大和成熟，可以向授权官员提供所需信息，以进行关于系统安全和隐私态势及系统和系统继承的控制持续有效性的持续风险确定和风险接受活动。

授权决定包括在授权包中，并传输给系统所有者或公共控制提供者。收到授权决定和授权包后，系统所有者或公共控制提供者确认并实施授权的条款和条件。组织确保系统授权包（包括系统和公共控制的授权决定）提供给组织官员（例如，继承公共控制的系统所有者；首席信息官；风险管理高级问责官员或风险执行 [功能]；高级机构信息安全官；高级机构隐私官；以及系统安全和隐私官）。授权官员作为持续监控的一部分（见任务 M-2）持续验证系统所有者或公共控制提供者是否遵循既定的授权条款和条件。

当系统在持续授权下操作时，授权官员继续负责和问责，明确理解和接受继续操作或使用系统或继续提供公共控制继承的风险。对于持续授权，指定授权频率代替授权终止日期。授权官员审查组织作为持续监控策略一部分定义的具体时间驱动授权频率的信息，并确定继续系统操作或提供公共控制的风险是否仍然可接受。如果风险仍然可接受，授权官员根据组织流程确认接受。如果不可接受，授权官员指示风险不再可接受，需要进一步风险响应或完全拒绝授权。

组织确定授权官员传达和确认继续风险接受的流程的正式级别。授权官员可以继续建立和传达系统所有者或公共控制提供者要遵循的具体条款和条件，以继续运营授权、继续公共控制授权或继续使用授权。授权的条款和条件可以通过自动化管理和报告工具作为自动化授权决定的一部分传达。

如果控制评估由具有所需独立性级别[104] 的合格评估员进行，评估结果支持持续授权，并可应用于再授权。关于持续授权和再授权的组织政策与法律、行政命令、指令、法规和政策一致。

---

[104] 如果控制评估由具有所需独立性级别的合格评估员进行，评估结果支持持续授权，并可应用于再授权。

附录 F 提供关于授权决定、授权类型和授权包准备的额外指导。

参考文献： [SP 800-39]（组织、任务/业务流程和系统层面）；[SP 800-160 v1]（风险管理流程）。

授权报告

任务 R-5 报告授权决定和控制中代表重大安全或隐私风险的任何缺陷。

潜在输入： 授权决定。

预期输出： 指示系统或一组公共控制授权决定的报告；组织系统注册表中的授权状态注释。

主要责任： 授权官员或授权官员指定代表。

支持角色： 系统所有者或公共控制提供者；信息所有者或管理者；系统安全官；系统隐私官；高级机构信息安全官；高级机构隐私官。

系统开发生命周期阶段： 新系统——实施/评估。现有系统——操作/维护。

讨论： 授权官员向指定的组织官员报告系统和公共控制的授权决定，以便可以在对组织运营和资产、个人、其他组织和国家的组织范围安全和隐私风险的背景下查看单个风险决策。仅在组织将授权功能委托给机构负责人以下的组织层面时发生报告。授权官员还报告评估和持续监控期间注意到的系统或控制中的可利用缺陷（即漏洞），这些缺陷代表重大安全或隐私风险。组织确定（组织政策反映）什么构成报告的重大安全或隐私风险。代表重大漏洞和风险的缺陷可以使用 [NIST CSF] 中的子类别、类别和功能报告。授权决定可以根据组织的决定作为组织范围系统注册流程的一部分跟踪和反映（见任务 P-18）。

参考文献： [SP 800-39]（组织、任务/业务流程和系统层面）；[SP 800-160 v1]（决策管理和项目评估和控制流程）；[NIST CSF]（核心 [识别、保护、检测、响应、恢复功能]）。

3.7 监控

目的

监控步骤的目的是维护关于信息系统和组织的安全和隐私态势的持续情境意识，以支持风险管理决策。

监控任务

表 8 提供了 RMF 监控步骤的任务和预期结果摘要。还提供了适用的网络安全框架结构。

表 8：监控任务和结果

任务	结果
任务 M-1 系统和环境变化	· 根据持续监控策略监控信息系统和操作环境的变化 [网络安全框架：DE.CM; ID.GV]
任务 M-2 持续评估	· 根据持续监控策略进行控制有效性的持续评估 [网络安全框架：ID.SC-4]
任务 M-3 持续风险响应	· 分析并适当响应持续监控活动的输出 [网络安全框架：RS.AN]
任务 M-4 授权包更新	· 基于持续监控活动更新风险管理文档 [网络安全框架：RS.IM]
任务 M-5 安全和隐私报告	· 建立向授权官员和其他高级领导者及高管报告安全和隐私态势的流程
任务 M-6 持续授权	· 授权官员使用持续监控活动的结果进行持续授权，并传达风险确定和接受决定的变化
任务 M-7 系统处置	· 制定并实施系统处置策略（如需要）

快速链接到 RMF 任务、职责和支持角色的摘要表。

系统和环境变化

任务 M-1 监控信息系统及其操作环境的变化，这些变化影响系统的安全和隐私态势。

潜在输入： 组织持续监控策略；组织配置管理政策和程序；组织处理未经授权系统变更的政策和程序；安全和隐私计划；配置变更请求/批准；系统设计文档；安全和隐私评估报告；行动计划和里程碑；来自自动化和手动监控工具的信息。

预期输出： 更新的安全和隐私计划；更新的行动计划和里程碑；更新的安全和隐私评估报告。

主要责任： 系统所有者或公共控制提供者；高级机构信息安全官；高级机构隐私官。

支持角色： 风险管理高级问责官员或风险执行（功能）；授权官员或授权官员指定代表；信息所有者或管理者；系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——操作/维护。现有系统——操作/维护。

讨论： 系统和操作环境处于持续变化状态，技术或机器元素、人类元素，以及物理或环境元素都在发生变化。技术或机器元素的变化包括例如硬件、软件或固件的升级；人类元素的变化包括例如员工流动或裁员；周围物理和环境元素的修改包括例如设施位置的变化或保护设施的物理访问控制的变化。外部提供商进行的变化可能难以检测。对系统和操作环境的变更进行纪律和结构化的管理、控制和文档化方

法，以及遵守授权的条款和条件，是安全和隐私计划的基本要素。组织建立配置管理和控制流程以支持配置和变更管理。

组织内的常见活动可能导致系统或操作环境的变化，并对系统的安全和隐私态势产生重大影响。示例包括安装或处置硬件、进行配置变更，以及在既定的配置变更控制流程之外安装补丁。未经授权的变更可能因对手的蓄意攻击或授权人员的无意错误而发生。除了遵守既定的配置管理流程外，组织还监控系统的未经授权变更，并分析有关已发生未经授权变更的信息，以确定未经授权变更的根本原因。除了监控未经授权的变更外，组织还持续监控系统和操作环境的任何影响系统隐私态势的授权变更。

一旦确定未经授权变更（或影响系统隐私态势的授权变更）的根本原因，组织相应响应（见任务 M-3）。例如，如果未经授权变更的根本原因确定为敌对攻击，可以采取多种行动，如调用事件响应流程、调整入侵检测和预防工具及防火墙配置，或实施额外或更强的控制以减少未来攻击的风险。如果未经授权变更的根本原因确定为员工未能遵守既定的配置管理流程，可能需要对某些人员进行补救培训。

参考文献： [SP 800-30]；[SP 800-128]；[SP 800-137]；[IR 8062]。

持续评估

任务 M-2 根据持续监控策略评估系统内实施和继承的控制。

潜在输入： 组织持续监控策略和系统级持续监控策略（如适用）；安全和隐私计划；安全和隐私评估计划；安全和隐私评估报告；行动计划和里程碑；来自自动化和手动监控工具的信息；组织和系统级风险评估结果；外部评估或审计结果（如适用）。

预期输出： 更新的安全和隐私评估报告。

主要责任： 控制评估员。

支持角色： 授权官员或授权官员指定代表；系统所有者或公共控制提供者；信息所有者或管理者；系统安全官；系统隐私官；高级机构信息安全官；高级机构隐私官。

系统开发生命周期阶段： 新系统——操作/维护。现有系统——操作/维护。

讨论： 初始系统或公共控制授权后，组织持续评估所有控制。控制有效性的持续评估是组织持续监控活动的一部分。每个控制的监控频率基于组织持续监控策略（见任务 P-7），可以由系统级持续监控策略补充（见任务 S-5）。还监控遵守授权官员作为授权决定一部分指定的条款和条件（见任务 M-1）。随着持续监控生成的信息相互关联、分析并报告给高级领导者，控制评估继续进行。

对于持续控制评估，评估员具有授权官员确定的所需独立性级别。持续监控期间的评估员独立性为流程引入效率，并可能允许重用评估结果以支持持续授权和需要再授权时。

为满足年度 FISMA 安全评估要求，组织可以使用授权、持续授权或再授权期间进行的控制评估结果；持续监控期间；或作为 SDLC 一部分或审计的系统测试和评估期间（前提是评估结果是当前的、与控制有效性的确定相关，并由具有所需独立性级别的评估员获得）。现有评估结果的重用与组织建立的重用政策一致，并根据需要补充额外评估。评估结果的重用有助于实现具有成本效益的安全计划，能够产生确定信息系统和组织安全态势所需的证据。最后，使用自动化支持控制评估促进了更大频率、体积和覆盖范围的评估。

参考文献： [SP 800-53A]；[SP 800-137]；[SP 800-160 v1]（验证、确认、操作和维护流程）；[IR 8011 v1]。

持续风险响应

任务 M-3 基于持续监控活动、风险评估和行动计划和里程碑中的未决项目的结果响应风险。

潜在输入： 安全和隐私评估报告；组织和系统级风险评估结果；安全和隐私计划；行动计划和里程碑。

预期输出： 缓解行动或风险接受决定；更新的安全和隐私评估报告。

主要责任： 授权官员；系统所有者；公共控制提供者。

支持角色： 风险管理高级问责官员或风险执行（功能）；高级机构隐私官；授权官员指定代表；信息所有者或管理者；系统安全官；系统隐私官；系统安全工程师；隐私工程师；安全架构师；隐私架构师。

系统开发生命周期阶段： 新系统——操作/维护。现有系统——操作/维护。

讨论： 持续监控期间评估员生成的评估信息在更新的评估报告中或通过自动化安全/隐私管理和报告工具的报告提供给系统所有者和公共控制提供者。授权官员确定对评估发现的适当风险响应，或批准系统所有者和公共控制提供者提议的响应。系统所有者和公共控制提供者随后实施适当的风险响应。当风险响应是接受时，发现保留在安全和隐私评估报告中，并监控风险因素的变化。当风险响应是缓解时，计划的缓解行动包括在行动计划和里程碑中并使用其跟踪。如果授权官员请求，控制评估员可以提供补救行动的建议。补救行动的建议也可以由自动化安全/隐私管理和报告工具提供。组织风险评估（任务 P-3）和系统级风险评估结果（任务 P-14）指导和告知关于持续风险响应的决策。作为持续风险响应一部分修改、增强或添加的控制由评估员重新评估，以确保新的、修改的或增强的控制已正确实施、按预期运行，并在满足系统的安全和隐私要求方面产生预期结果。

参考文献： [SP 800-30]；[SP 800-53]；[SP 800-53A]；[SP 800-137]；[SP 800-160 v1]（风险管理流程）；[IR 8011 v1]；[IR 8062]；[NIST CSF]（核心 [响应功能]）。

授权包更新

任务 M-4 基于持续监控流程的结果更新计划、评估报告和行动计划和里程碑。

潜在输入： 安全和隐私评估报告；组织和系统级风险评估结果；安全和隐私计划；行动计划和里程碑。

预期输出： 更新的安全和隐私评估报告；更新的行动计划和里程碑；更新的风险评估结果；更新的安全和隐私计划。

主要责任： 系统所有者；公共控制提供者。

支持角色： 信息所有者或管理者；系统安全官；系统隐私官；高级机构隐私官；高级机构信息安全官。

系统开发生命周期阶段： 新系统——操作/维护。现有系统——操作/维护。

讨论： 为实现近乎实时的风险管理，组织持续更新安全和隐私计划、安全和隐私评估报告，以及行动计划和里程碑。对计划的更新反映系统所有者或公共控制提供者执行的风险缓解活动对控制的修改。对控制评估报告的更新反映为确定控制有效性基于计划中的实施细节进行的额外评估活动。行动计划和里程碑基于当前未决项目的进展进行更新；解决作为控制有效性监控一部分发现的安全和隐私风险；并描述系统所有者或公共控制提供者打算如何解决这些风险。更新的信息提高对系统和系统继承的公共控制的安全和隐私态势的认识，从而支持近乎实时的风险管理和持续授权流程。

更新风险管理信息的频率由系统所有者、公共控制提供者和授权官员自行决定，符合联邦和组织政策，并与组织和系统级持续监控策略一致。对系统和系统继承的公共控制的安全和隐私态势信息的更新准确及时，因为提供的信息影响授权官员和组织内其他高级领导者的持续行动和决策。使用自动化支持工具和组织范围的安全和隐私计划管理实践确保授权官员可以轻松访问系统的当前安全和隐私态势。随时访问当前安全和隐私态势支持持续监控和持续授权，并促进对组织运营和资产、个人、其他组织和国家的风险的近乎实时管理。

组织确保更新安全和隐私计划、评估报告和行动计划和里程碑时不修改或销毁监督和审计目的所需的信息。通过配置管理程序提供跟踪系统变更的有效方法对于实现组织安全和隐私活动的透明度和可追溯性是必要的；获得对任何安全或隐私行动的个人问责；并了解组织安全和隐私计划中出现的新趋势。

参考文献： [SP 800-30]；[SP 800-53A]。

安全和隐私报告

任务 M-5 根据组织持续监控策略，持续向授权官员和其他组织官员报告系统的安全和隐私态势。

潜在输入： 安全和隐私评估报告；行动计划和里程碑；组织和系统级风险评估结果；组织和系统级持续监控策略；安全和隐私计划；网络安全框架配置文件。

预期输出： 安全和隐私态势报告。

主要责任： 系统所有者；公共控制提供者；高级机构信息安全官；高级机构隐私官。

支持角色： 系统安全官；系统隐私官。

系统开发生命周期阶段： 新系统——操作/维护。现有系统——操作/维护。

讨论： 监控活动的结果根据组织持续监控策略持续记录并报告给授权官员和其他选定的组织官员。可能接收安全和隐私态势报告的其他组织官员包括例如首席信息官、高级机构信息安全官、高级机构隐私官、风险管理高级问责官员或风险执行（功能）、信息所有者或管理者、事件响应角色和应急计划角色。安全和隐私态势报告可以是事件驱动、时间驱动，或事件和时间驱动。报告向授权官员和其他组织官员提供关于系统安全和隐私态势的信息，包括已实施控制的有效性。安全和隐私态势报告描述系统所有者或公共控制提供者采用的持续监控活动。报告还包括有关在控制评估、审计和持续监控期间发现的系统和操作环境中的安全和隐私风险的信息，以及系统所有者或公共控制提供者计划如何解决这些风险。

组织在安全和隐私态势报告的广度、深度、正式性、形式和格式方面具有灵活性。目标是与授权官员和其他组织官员（如必要）进行有效的持续沟通，传达系统和操作环境的当前安全和隐私态势，以及当前态势如何影响个人、组织任务和业务功能。至少，安全和隐私态势报告总结自上次报告以来安全和隐私计划、安全和隐私评估报告，以及行动计划和里程碑发生的变化。组织使用自动化安全和隐私管理和报告工具（例如仪表板）促进安全和隐私态势报告的有效性和及时性。

安全和隐私态势报告的频率由组织自行决定，并符合联邦和组织政策。报告以适当的间隔进行，以传输有关系统或公共控制的安全和隐私信息，但不过于频繁以产生不必要的工作或费用。授权官员使用安全和隐私态势报告，并与风险管理高级问责官员或风险执行（功能）、高级机构信息安全官和高级机构隐私官协商，以确定是否需要再授权行动。

安全和隐私态势报告根据联邦和组织政策标记、保护和处理。安全和隐私态势报告可用于满足 FISMA 报告要求，记录安全和隐私弱点或缺陷的补救行动。安全和隐私态势报告旨在持续进行，不应解释为需要与初始授权提供的信息相关的时间、费用和正式性。相反，报告以符合实现报告目标的具有成本效益的方式进行。

参考文献： [SP 800-53A]；[SP 800-137]；[NIST CSF]（核心 [识别、保护、检测、响应、恢复功能]）。

持续授权

任务 M-6 持续审查系统的安全和隐私态势，以确定风险是否仍然可接受。

潜在输入： 风险容忍度；安全和隐私态势报告；行动计划和里程碑；组织和系统级风险评估结果；安全和隐私计划。

预期输出： 风险确定；持续运营授权、持续使用授权、持续公共控制授权；拒绝持续运营授权、拒绝持续使用授权、拒绝持续公共控制授权。

主要责任： 授权官员。

支持角色： 风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员指定代表。

系统开发生命周期阶段： 新系统——操作/维护。现有系统——操作/维护。

讨论： 为采用持续授权方法，组织到位组织级和系统级持续监控流程以持续评估已实施控制。持续监控流程的发现或结果为授权官员提供有用信息，以支持近乎实时的基于风险的决策。根据任务 R-4 中的指导，授权官员或指定代表持续审查系统的安全和隐私态势（包括已实施控制的有效性），以确定对组织运营和资产、个人、其他组织和国家的当前风险。授权官员确定当前风险是否可接受，并向系统所有者或公共控制提供者提供适当指导。授权官员可以确定风险保持在可接受水平以继续操作，或风险不再处于可接受水平以继续操作，并可能发布拒绝运营授权、使用授权或公共控制授权。

风险可能因安全和隐私态势报告中提供的信息而变化，因为报告可能表明安全或隐私风险因素的变化。确定不断变化的条件如何影响组织和个体风险对于管理隐私风险和维持充分安全至关重要。通过进行持续风险确定和风险接受，授权官员可以随时间维护系统和公共控制授权，并过渡到持续授权。再授权行动仅根据联邦或组织政策发生。授权官员向风险管理高级问责官员或风险执行（功能）传达更新的风险确定和接受结果。

使用自动化支持工具捕获、组织、量化、可视化显示和维护安全和隐私态势信息，促进关于组织风险态势的近乎实时风险管理。使用指标和仪表板通过以自动化方式整合数据并以易于理解的格式向组织内不同级别的决策者提供数据，提高组织进行基于风险决策的能力。

参考文献： [SP 800-30]；[SP 800-39]（组织、任务/业务流程和系统层面）；[SP 800-55]；[SP 800-160 v1]（风险管理流程）；[IR 8011 v1]；[IR 8062]。

系统处置

任务 M-7 当系统移除操作时实施系统处置策略并执行所需行动。

潜在输入： 安全和隐私计划；组织和系统级风险评估结果；系统组件库存。

预期输出： 处置策略；更新的系统组件库存；更新的安全和隐私计划。

主要责任： 系统所有者。

支持角色： 授权官员或授权官员指定代表；信息所有者或管理者；系统安全官；系统隐私官；风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官。

系统开发生命周期阶段： 新系统——不适用。现有系统——处置。

讨论： 当系统移除操作时，需要几个风险管理行动。组织确保实施解决系统处置的控制。示例包括媒体清理；配置管理和控制；组件真实性；以及记录保留。组织跟踪和管理系统（包括库存系统）更新以指示正在移除服务的系统。安全和隐私态势报告反映系统的安全和隐私状态。酌情通知托管在处置系统上的用户和应用程序所有者，并审查和评估任何控制继承关系的影响。此任务也适用于移除操作的系统元素。移除操作系统的组织更新信息系统库存以反映移除。系统所有者和安全人员确保处置的系统遵守相关联邦法律、法规、指令、政策和标准。

参考文献： [SP 800-30]；[SP 800-88]；[IR 8062]。

附录

附录 A 参考文献

法律和行政命令

参考文献	描述
32 CFR 2002.4	标题 32 联邦法规第 2002.4 节，定义。2018 版。
40 USC 11331	标题 40 美国法典第 11331 节，联邦信息系统标准的职责。2017 版。
44 USC 3301	标题 44 美国法典第 3301 节，记录的定义。2017 版。
44 USC 3502	标题 44 美国法典第 3502 节，定义。2017 版。
44 USC 3552	标题 44 美国法典第 3552 节，定义。2017 版。
44 USC 3554	标题 44 美国法典第 3554 节，联邦机构职责。2017 版。
44 USC 3601	标题 44 美国法典第 3601 节，定义。2017 版。
PRIVACT	隐私法案 (P.L. 93-579)，1974 年 12 月。
FOIA96	信息自由法案 (FOIA)，5 U.S.C. § 552，经公法第 104-231 号修订，1996 年电子信息自由法案修正案。
FISMA	联邦信息安全现代化法案 (P.L. 113-283)，2014 年 12 月。
EO 13800	行政命令 13800，加强联邦网络和关键基础设施的网络安全，2017 年 5 月。

政策、法规、指令和说明

参考文献	描述
OMB A-123	管理和预算办公室通告第 A-123 号，管理层对企业风险管理和内部控制的责任，2016 年 7 月。
OMB A-130	管理和预算办公室通告 A-130，将信息作为战略资源进行管理，2016 年 7 月。
OMB M-13-13	管理和预算办公室备忘录 M-13-13，开放数据政策 - 将信息作为资产管理，2013 年 5 月。
OMB M-17-25	管理和预算办公室备忘录 M-17-25，关于加强联邦网络和关键基础设施网络安全的行政命令的报告指南，2017 年 5 月。
OMB M-19-03	管理和预算办公室备忘录 M-19-03，通过加强高价值资产计划加强联邦机构的网络安全，2018 年 12 月。
CNSSI 1253	国家信息安全系统委员会指令 1253，国家安全系统的安全分类和控制选择，2014 年 3 月。
CNSSI 4009	国家信息安全系统委员会指令 4009，国家信息安全系统委员会 (CNSS) 术语表，2015 年 4 月。
CNSSD 505	国家信息安全系统委员会指令 505，供应链风险管理，2017 年 8 月。
DODI 5200.44	国防部指令 5200.44，保护任务关键功能以实现可信系统和网络 (TSN)，2017 年 7 月。

标准和指南

参考文献	描述
FIPS 199	联邦信息处理标准出版物 199，联邦信息和信息系统安全分类标准，2004 年 2 月。
FIPS 200	联邦信息处理标准出版物 200，联邦信息和信息系统的最低安全要求，2006 年 3 月。
SP 800-18	特别出版物 800-18，修订版 1，联邦信息系统安全计划开发指南，2006 年 2 月。
SP 800-30	特别出版物 800-30，修订版 1，进行风险评估指南，2012 年 9 月。
SP 800-39	特别出版物 800-39，管理信息安全风险：组织、任务和信息系统的视角，2011 年 3 月。
SP 800-53	特别出版物 800-53，修订版 4，联邦信息系统和组织的安全和隐私控制，2013 年 4 月。
SP 800-53A	特别出版物 800-53A，修订版 4，评估联邦信息系统和组织的安全和隐私控制，2008 年 7 月。
SP 800-53B	特别出版物 800-53B，控制基线，2020 年。
SP 800-160 v1	特别出版物 800-160，第 1 卷，系统工程：可信安全系统工程的多学科方法考虑，2016 年 11 月。
SP 800-161	特别出版物 800-161，联邦信息系统和组织的供应链风险管理实践，2015 年 4 月。
NIST CSF	改进关键基础设施网络安全框架（网络安全框架），版本 1.1，2018 年 4 月。

附录 B 术语表

术语	定义
充分安全	与未经授权的访问、使用、披露、破坏、修改或销毁信息产生的风险相称的安全保护。
授权边界	授权官员授权操作的信息系统的所有组件。不包括连接到信息系统的单独授权系统。
授权包	授权官员用于确定是否授权信息系统操作或提供指定公共控制集的基本信息。至少包括执行摘要、系统安全计划、隐私计划、安全控制评估、隐私控制评估，以及任何相关的行动计划和里程碑。
运营授权	高级联邦官员给予的官方管理决定，授权操作信息系统，并明确接受对机构运营、机构资产、个人、其他组织和国家的风险。
使用授权	授权官员给予的官方管理决定，授权使用信息系统、服务或应用程序，基于另一个组织生成的现有授权包中的信息。
授权官员	具有授权操作信息系统或使用指定公共控制集的高级联邦官员或高管。
控制基线	适用于信息或信息系统的一组控制，以满足法律、监管或政策要求，并解决管理风险的保护需求。
公共控制	由多个信息系统或程序继承的安全或隐私控制。
持续监控	维护持续意识以支持组织风险决策。
控制评估	测试或评估信息系统或组织中的控制，以确定控制在多大程度上正确实施、按预期运行，并产生预期结果。
机密性	保护对信息访问和披露的授权限制，包括保护个人隐私和专有信息的手段。
完整性	防止不当信息修改或销毁，包括确保信息不可否认性和真实性。
可用性	确保及时和可靠地访问和使用信息。
个人信息 (PII)	可用于区分或追踪个人身份的信息，无论是单独使用还是与其他链接到特定个人的信息结合使用。
隐私控制	机构内采用的行政、技术或物理保障措施，以确保遵守适用的隐私要求并管理隐私风险。
风险	衡量实体受潜在情况或事件威胁程度的指标，通常是不利影响和发生可能性的函数。
风险评估	识别对组织运营、组织资产、个人、其他组织和国家的风险的流程，源于系统的操作。
风险管理	管理对机构运营、机构资产、个人、其他组织和国家的风险的计划和支持流程。
风险管理框架 (RMF)	为管理安全和隐私风险提供的纪律、结构化和灵活流程。
系统开发生命周期 (SDLC)	与系统相关的活动范围，包括启动、开发和采购、实施、操作和维护，以及最终处置。
供应链风险管理 (SCRM)	识别、评估和缓解与信息和通信技术产品及服务供应链的全球和分布式性质相关的风险的流程。

附录 C 缩写

缩写	英文全称	中文全称
CIO	Chief Information Officer	首席信息官
CNSS	Committee on National Security Systems	国家信息安全系统委员会
CNSSI	Committee on National Security Systems Instruction	国家信息安全系统委员会指令
CUI	Controlled Unclassified Information	受控非机密信息
DoD	Department of Defense	国防部
EO	Executive Order	行政命令
FedRAMP	Federal Risk and Authorization Management Program	联邦风险和授权管理计划
FIPS	Federal Information Processing Standards	联邦信息处理标准
FISMA	Federal Information Security Modernization Act	联邦信息安全现代化法案
FOCI	Foreign Ownership, Control, or Influence	外国所有权、控制或影响
GRC	Governance, Risk, and Compliance	治理、风险和合规
GSA	General Services Administration	总务管理局
IEC	International Electrotechnical Commission	国际电工委员会
IEEE	Institute of Electrical and Electronics Engineers	电气和电子工程师协会
ISCM	Information Security Continuous Monitoring	信息安全持续监控
IT	Information Technology	信息技术
IR	Internal Report / Interagency Report	内部报告/机构间报告
ISO	International Organization for Standardization	国际标准化组织
NARA	National Archives and Records Administration	国家档案和记录管理局
NIST	National Institute of Standards and Technology	国家标准与技术研究院
NSA	National Security Agency	国家安全局
ODNI	Office of the Director of National Intelligence	国家情报总监办公室
OMB	Office of Management and Budget	管理和预算办公室
OT	Operational Technology	运营技术
PCM	Privacy Continuous Monitoring	隐私持续监控
PII	Personally Identifiable Information	个人身份信息
PL	Public Law	公法
RMF	Risk Management Framework	风险管理框架
SCRM	Supply Chain Risk Management	供应链风险管理

缩写	英文全称	中文全称
SDLC	System Development Life Cycle	系统开发生命周期
SecCM	Security-focused Configuration Management	安全焦点配置管理
SP	Special Publication	特别出版物

附录 D 角色和职责

风险管理流程中的关键参与者

本节描述参与组织风险管理流程的关键参与者的角色和职责。认识到组织有不同的任务、业务功能和组织结构，风险管理角色的命名约定以及如何将风险管理职责分配给组织人员可能存在差异（例如，多人担任单个角色或一人担任多个角色）。然而，基本功能保持不变。本出版物中描述的 RMF 应用具有灵活性，允许组织在各自的组织结构内有效完成特定任务的意图，以最好地管理安全和隐私风险。本出版物中定义的许多风险管理角色在组织执行的 SDLC 流程中有对应角色。组织尽可能将风险管理角色与 SDLC 定义的相似（或互补）角色保持一致。

授权官员

授权官员是高级官员或高管，具有正式承担责任和问责制的权限，以操作系统；提供组织系统继承的公共控制；或使用来自外部提供商的系统、服务或应用程序。授权官员是唯一可以接受对组织运营、组织资产和个人的安全和隐私风险的组织官员。授权官员通常对系统有预算监督，或负责系统支持的任务和/或业务运营。因此，授权官员处于管理职位，具有与理解和接受此类安全和隐私风险相称的权威级别。授权官员批准计划、谅解备忘录或协议、行动计划和里程碑，并确定信息系统或操作环境的重大变化是否需要再授权。

授权官员在授权流程期间与公共控制提供者、系统所有者、首席信息官、高级机构信息安全官、高级机构隐私官、系统安全和隐私官、控制评估员、风险管理高级问责官员/风险执行（功能）和其他感兴趣方协调活动。随着组织内任务/业务流程、合作伙伴关系安排和使用共享服务的复杂性增加，系统可能涉及共同授权官员。如果是这样，在共同授权官员之间建立协议，并记录在安全和隐私计划中。授权官员负责和问责，确保委托给授权官员指定代表的授权活动和职能按指定执行。对于联邦机构，授权官员的角色是固有的美国政府职能，仅分配给政府人员。

授权官员指定代表

授权官员指定代表是由授权官员指定的组织官员，被授权代表授权官员行事，协调和进行与管理系统和组织风险相关的日常活动。这包括执行与 RMF 执行相关的许多活动。授权官员不能委托给指定代表的唯一活动是授权决定和签署相关授权决定文档（即接受风险）。

首席采购官

首席采购官是由机构负责人指定的组织官员，负责建议和协助机构负责人和其他机构官员，确保通过管理机构采购活动实现机构使命。首席采购官监控采购活动和计划的绩效；在机构内建立明确的采购决策权限、问责制和责任线；管理机构采购政策的方向和实施；并建立促进全面公开竞争的政策、程序和做法，从负责任的来源履行最佳价值要求，考虑采购财产或服务的性质。首席采购官与任务或业务所有者、授权官员、风险管理高级问责官员、系统所有者、公共控制提供者、高级机构信息安全官、高级机构隐私官和风险执行（功能）协调，以确保在组织采购和采购中定义安全和隐私要求。

首席信息官

首席信息官是组织官员，负责指定高级机构信息安全官；制定和维护安全政策、程序和控制技术以解决安全要求；监督对安全负有重大责任的人员，并确保这些人员接受充分培训；协助高级组织官员履行其安全职责；并向机构负责人报告组织安全计划的有效性，包括补救行动的进展。首席信息官在风险管理高级问责官员、风险执行（功能）和高级机构信息安全官的支持下，与授权官员及其指定代表密切合作，以帮助确保：

- 组织范围安全计划有效实施，为所有组织系统和操作环境提供充分安全
- 安全和隐私（包括供应链）风险管理考虑整合到编程/规划/预算周期、企业架构、SDLC 和采购中
- 组织系统和公共控制由批准的系统安全计划覆盖，并具有当前授权
- 整个组织所需的安全活动以高效、具有成本效益和及时的方式完成
- 安全活动有集中报告

首席信息官和授权官员基于组织优先级，确定用于保护支持组织任务和业务功能的系统的资源分配。对于处理个人身份信息的信息系统，首席信息官和授权官员与高级机构隐私官协调任何关于分配资源保护这些系统的决定。对于选定的系统，首席信息官可以被指定为授权官员或与其他高级组织官员共同授权。首席信息官的角色是固有的美国政府职能，仅分配给政府人员。

公共控制提供者

公共控制提供者是负责实施、评估和监控公共控制（即组织系统继承的控制）的个人、小组或组织。公共控制提供者还负责确保在安全和隐私计划（或组织规定的等效文档）中记录组织定义的公共控制；确保由合格评估员对公共控制进行所需评估，并具有适当的独立性级别；在控制评估报告中记录评估结果；并为有缺陷的控制产生行动计划和里程碑。公共控制的安全和隐私计划、安全和隐私评估报告，以及行动计划和里程碑（或此类信息的摘要）在信息被负责这些公共控制的授权官员审查和批准后，提供给继承公共控制的系统的系统所有者。

高级机构隐私官负责指定哪些隐私控制可被视为公共控制。指定为公共控制的隐私控制记录在组织的隐私计划计划中。高级机构隐私官对到位或计划满足适用隐私要求和管理隐私风险的公共控制有监督责任，并负责评估这些控制。由组织自行决定，指定为公共控制的隐私控制可以由独立评估员评估。然而，在所有情况下，高级机构隐私官对组织的隐私计划保留责任和问责制，包括独立评估员执行的任何隐私功能。隐私计划和隐私控制评估报告提供给继承指定为公共控制的隐私控制的系统所有者。

控制评估员

控制评估员是负责对已实施的控制和控制增强进行全面评估，以确定控制有效性（即控制在多大程度上正确实施、按预期运行，并在满足系统和组织的安全和隐私要求方面产生预期结果）的个人、小组或组织。对于系统，评估已实施的系统特定控制和系统实施的混合控制部分。对于公共控制，评估已实施的公共控制和公共控制实施的混合控制部分。系统所有者和公共控制提供者依赖评估员的安全和隐私专业知识和判断，使用安全和隐私评估计划中指定的评估程序评估已实施的控制。可能需要具有特定控制要求或技术专业知识的多个控制评估员来有效进行评估。在启动控制评估之前，评估员审查安全和隐私计划，以促进评估计划的开发。控制评估员提供在系统、操作环境和公共控制中发现的缺陷严重性的评估，并可以建议纠正行动以解决识别的漏洞。对于系统级控制评估，控制评估员不评估继承的控制，仅评估混合控制的系统实施部分。控制评估员准备包含评估结果和发现的安全和隐私评估报告。

所需的评估员独立性级别由授权官员基于法律、行政命令、指令、法规、政策、标准或指南确定。当控制评估支持授权决定或持续授权时，授权官员明确确定所需独立性程度。评估员独立性是保持公正和无偏见评估流程的因素；确定评估结果的可信度；并确保授权官员接收客观信息以做出知情、基于风险的授权决定。

高级机构隐私官负责评估隐私控制并向授权官员提供隐私信息。由组织自行决定，隐私控制可以由独立评估员评估。然而，在所有情况下，高级机构隐私官对组织的隐私计划保留责任和问责制，包括独立评估员执行的任何隐私功能。

企业架构师

企业架构师是负责与组织领导层和主题专家合作，建立组织任务和业务功能、任务/业务流程、信息，以及信息技术资产的整体视图的个人或小组。关于信息安全性和隐私，企业架构师：

- 实施促进有效安全和隐私解决方案的企业架构策略
- 与安全架构师和隐私架构师协调，确定系统/系统元素在企业架构中的最佳位置，并解决系统和企业架构之间的安全和隐私问题
- 协助减少 IT 基础设施内的复杂性以促进安全
- 协助确定适当的控制实施和初始配置基线，因为它们与企业架构相关
- 与系统所有者和授权官员协作，促进授权边界确定和控制分配给系统元素
- 作为风险执行（功能）的一部分
- 协助将组织风险管理策略和系统级安全和隐私要求整合到项目、规划和预算活动、SDLC、采购流程、安全和隐私（包括供应链）风险管理，以及系统工程流程中

机构负责人

机构负责人负责和问责，提供与对组织运营和资产、个人、其他组织和国家的风险相称的信息安全保护——即，由或代表机构收集或维护的信息和/或信息系统未经授权的访问、使用、披露、破坏、修改或销毁产生的风险；以及由机构或机构承包商或其他组织代表机构使用或操作的信息系统。机构负责人也是组织中负责确保保护隐私利益并在组织内负责任地管理 PII 的高级官员。机构负责人确保：

- 信息安全和隐私管理流程与战略和运营规划流程整合
- 组织内的高级官员为其控制下的运营和资产的信息和系统提供信息安全
- 指定高级机构隐私官，负责和问责确保遵守适用的隐私要求、管理隐私风险，以及组织的隐私计划
- 组织有充分培训的人员协助遵守立法、行政命令、政策、指令、说明、标准和指南中的安全和隐私要求

机构负责人建立有效管理安全和隐私风险并保护组织执行的任务和业务功能所需的组织承诺和行动。机构负责人建立安全和隐私问责制，并提供对安全和隐私计划监控和改进的积极支持和监督。高级领导层对安全和隐私的承诺在组织内建立应有的谨慎水平，促进任务和业务成功的氛围。

信息所有者或管理者

信息所有者或管理者是对指定信息具有法定、管理或运营权威的组织官员，并负责建立管理其生成、收集、处理、传播和处置的政策和程序。在信息共享环境中，信息所有者/管理者负责建立信息适当使用和保护规则，即使信息共享或提供给其他组织也保留该责任。系统处理、存储或传输的信息的所有者/管理者可能与系统所有者不是同一个人。单个系统可能包含来自多个信息所有者/管理者的信息。信息所有者/管理者向系统所有者提供关于处理、存储或传输信息的系统的安全和隐私要求及控制的输入。

任务或业务所有者

任务或业务所有者是组织内具有特定任务或业务线职责的高级官员或高管，对支持这些任务或业务线的组织系统具有安全或隐私利益。任务或业务所有者是关键利益相关者，在建立组织任务和业务流程以及确保组织任务和业务运营成功的保护需求和安全与隐私要求方面发挥重要作用。任务和业务所有者为风险管理策略提供基本输入，在 SDLC 中发挥积极作用，也可以担任授权官员的角色。

风险执行（功能）

风险执行（功能）是组织内为风险管理提供全面、组织范围方法的个人或小组。风险执行（功能）由风险管理高级问责官员领导，并作为高级领导者、高管和管理人员、任务/业务所有者、首席信息官、高级机构信息安全官、高级机构隐私官、系统所有者、公共控制提供者、企业架构师、安全架构师、系统安全或隐私工程师、系统安全或隐私官，以及对组织任务/业务成功有既得利益的任何其他利益相关者的共同风险管理资源。风险执行（功能）是固有的美国政府职能，仅分配给政府人员。

风险执行（功能）确保系统（包括这些系统的授权决定和这些系统继承的公共控制）的风险考虑从组织角度考虑组织的战略目标和任务执行业务功能。风险执行（功能）确保整个组织管理风险一致，反映组织风险容忍度，并与其他类型的风险一起考虑以确保任务/业务成功。风险执行（功能）与高级领导者和高管协调：

- 建立风险管理角色和职责
- 制定和实施组织范围风险管理策略，为组织提供安全风险的战略视图，并指导和告知组织风险决策（包括如何框架、评估、响应和随时间监控风险）
- 提供全面、组织范围、整体方法来解决风险——提供对组织集成运营的更好理解的方法
- 管理组织系统及其操作环境的威胁、漏洞、安全和隐私风险（包括供应链风险）信息
- 建立组织范围论坛以考虑所有类型和来源的风险（包括聚合风险）
- 基于组织负责的系统操作和使用及其各自操作环境的聚合风险识别组织风险态势
- 对组织实施的风险管理活动提供监督，以帮助确保一致和有效的基于风险的决策
- 建立对组织战略视图及其集成运营的风险的广泛理解
- 建立有效载体并作为焦点，在组织内部和外部的关键利益相关者（例如，授权官员和其他高级领导者）之间沟通和共享风险信息
- 指定父组织允许子组织关于框架、评估、响应和监控风险的自主程度
- 促进授权官员之间的合作和协作，包括需要共同责任的授权行动（例如，联合授权）
- 提供组织范围论坛以考虑对组织运营和资产、个人、其他组织和国家的所有风险来源（包括聚合风险）
- 确保授权决策考虑任务和业务成功所需的所有因素
- 确保使用外部提供商支持组织任务和业务功能的共同责任获得所需的可见性，并提升到适当的决策权威

风险执行（功能）不假定特定组织结构或分配给组织内任何个人或小组的正式责任。机构或组织负责人可以选择保留风险执行（功能）或将功能委托给他人。风险执行（功能）需要混合技能、专业知识和视角，以了解组织的战略目标和目的、组织任务/业务功能、技术可能性和约束，以及塑造组织运营的关键任务和指南。为提供这种所需的组合，风险执行（功能）可以由单一个人或办公室（由专家团队支持）或指定的小组（例如，风险委员会、执行指导委员会、执行领导委员会）填充。风险执行（功能）以促进效率和有效性的方式融入组织治理结构。

安全或隐私架构师

安全或隐私架构师是负责确保利益相关者保护需求和相应的系统要求（保护组织任务和业务功能以及个人隐私所需）在企业架构（包括参考模型、段架构和解决方案架构（支持任务和业务流程的系统））中得到充分解决的个人、小组或组织。安全或隐私架构师担任企业架构师与系统安全或隐私工程师之间的主要联络人，并与系统所有者、公共控制提供者和系统安全或隐私官协调控制分配。

安全或隐私架构师在系统安全或隐私官的协调下，就一系列安全和隐私问题向授权官员、首席信息官、风险管理高级问责官员或风险执行（功能）、高级机构信息安全官和高级机构隐私官提供建议。示例包括建立授权边界；建立安全或隐私警报；评估系统或控制中缺陷的严重性；制定行动计划和里程碑；创建风险缓解方法；以及识别漏洞或隐私风险的潜在不利影响。

当安全架构师和隐私架构师是 separate 角色时，安全架构师通常负责企业架构的方面，保护信息和信息系统免受未经授权的系统活动或行为，以提供机密性、完整性和可用性。隐私架构师负责企业架构的方面，确保遵守隐私要求并管理与处理 PII 相关的个人隐私风险。安全和隐私架构师职责在保护 PII 安全的企业架构方面重叠。

风险管理高级问责官员

风险管理高级问责官员是在组织中领导和管理风险执行（功能）的个人，负责将信息安全和隐私风险管理流程与战略、运营和预算规划流程保持一致。风险管理高级问责官员是机构负责人或由机构负责人指定的个人。风险管理高级问责官员确定风险执行（功能）的组织结构和职责，并与机构负责人协调，可以保留风险执行（功能）或将功能委托给其他组织官员或小组。风险管理高级问责官员是固有的美国政府职能，仅分配给政府人员。

高级机构信息安全官

高级机构信息安全官是负责根据 FISMA 履行首席信息官安全职责的组织官员，并作为首席信息官与组织授权官员、系统所有者、公共控制提供者和系统安全官的主要联络人。高级机构信息安全官还负责与高级机构隐私官协调，以确保隐私和信息安全计划之间的协调。高级机构信息安全官具备管理安全计划职能所需的专业资格，包括培训和经验；将安全职责作为主要职责维护；并领导具有特定使命和资源的办公室，协助组织按照 FISMA 要求实现可信、安全的信息和系统。高级机构信息安全官可以担任授权官员指定代表或安全控制评估员。高级机构信息安全官的角色是固有的美国政府职能，因此仅分配给政府人员。组织也可以将高级机构信息安全官称为高级信息安全官或首席信息安全官。

高级机构隐私官

高级机构隐私官是具有机构范围责任和问责制以确保遵守适用隐私要求和管理隐私风险的高级官员或高管。除其他事项外，高级机构隐私官负责：

- 与高级机构信息安全官协调，以确保隐私和信息安全活动的协调
- 审查和批准创建、收集、使用、处理、存储、维护、传播、披露或处置个人身份信息的信息系统的安全分类
- 指定哪些隐私控制将视为项目管理、公共、系统特定和混合隐私控制
- 识别评估方法论和指标，以确定隐私控制是否正确实施、按预期运行，并足以确保遵守适用隐私要求和管理隐私风险
- 在授权、再授权或持续授权之前审查和批准信息系统的隐私计划
- 审查创建、收集、使用、处理、存储、维护、传播、披露或处置个人身份信息的信息系统的授权包，以确保遵守隐私要求并管理隐私风险
- 进行并记录隐私控制评估的结果，以验证机构选择和实施的所有隐私控制的持续有效性
- 向授权官员提供隐私信息以告知授权决策

系统所有者

系统所有者是负责信息系统采购、开发、集成、修改、操作、维护、处置和处置的组织官员。系统所有者负责确保系统安全和隐私计划到位；确保系统人员接受充分培训；确保系统遵守适用的安全政策和标准；并协调与系统相关的控制和流程的实施。系统所有者与系统安全官和系统隐私官密切合作，以确保系统满足安全和隐私要求。

系统安全官

系统安全官是负责维护信息系统或程序的适当操作安全态势的个人。系统安全官协助系统所有者确保安全控制在系统整个生命周期内正确实施和维护。系统安全官还协调控制评估、准备安全评估报告，并协助制定行动计划和里程碑。

系统隐私官

系统隐私官是负责维护系统或程序的适当操作隐私态势的个人。系统隐私官协助系统所有者确保隐私控制在系统整个生命周期内正确实施和维护。系统隐私官还协调隐私评估、准备隐私评估报告，并协助制定解决隐私相关问题的行动计划和里程碑。

系统安全工程师

系统安全工程师是负责进行系统安全工程活动的个人。系统安全工程师与系统安全官和系统所有者合作，将安全要求整合到系统架构、设计和实施中。

隐私工程师

隐私工程师是负责进行系统隐私工程活动的个人。隐私工程师与系统隐私官和系统所有者合作，将隐私要求整合到系统架构、设计和实施中。

附录 E RMF 任务摘要

RMF 准备步骤 - 组织层面

任务ID	任务名称	主要责任	支持角色
P-1	风险管理角色	机构负责人；首席信息官；高级机构隐私官	授权官员或指定代表；风险管理高级问责官员或风险执行（功能）；高级机构信息安全官
P-2	风险管理策略	机构负责人	风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官
P-3	风险评估——组织	风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官	首席信息官；任务或业务所有者；授权官员或指定代表
P-4	组织定制控制基线和网络安全框架配置文件（可选）	任务或业务所有者；风险管理高级问责官员或风险执行（功能）	首席信息官；授权官员或指定代表；高级机构信息安全官；高级机构隐私官
P-5	公共控制识别	高级机构信息安全官；高级机构隐私官	任务或业务所有者；风险管理高级问责官员或风险执行（功能）；首席信息官；授权官员或指定代表；公共控制提供者；系统所有者
P-6	影响级别优先排序（可选）	风险管理高级问责官员或风险执行（功能）	高级机构信息安全官；高级机构隐私官；任务或业务所有者；系统所有者；首席信息官；授权官员或指定代表
P-7	持续监控策略——组织	风险管理高级问责官员或风险执行（功能）	首席信息官；高级机构信息安全官；高级机构隐私官；任务或业务所有者；系统所有者；授权官员或指定代表

RMF 准备步骤 - 系统层面

任务ID	任务名称	主要责任	支持角色
P-8	任务或业务焦点	任务或业务所有者	授权官员或指定代表；系统所有者；信息所有者或管理者；首席信息官；高级机构信息安全官；高级机构隐私官
P-9	系统利益相关者	任务或业务所有者；系统所有者	首席信息官；授权官员或指定代表；信息所有者或管理者；高级机构信息安全官；高级机构隐私官；首席采购官
P-10	资产识别	系统所有者	授权官员或指定代表；任务或业务所有者；信息所有者或管理者；高级机构信息安全官；高级机构隐私官；系统管理员
P-11	授权边界	授权官员	首席信息官；系统所有者；任务或业务所有者；高级机构信息安全官；高级机构隐私官；企业架构师
P-12	信息类型	系统所有者；信息所有者或管理者	任务或业务所有者；系统安全官；系统隐私官
P-13	信息生命周期	高级机构隐私官；系统所有者；信息所有者或管理者	首席信息官；任务或业务所有者；安全架构师；隐私架构师；企业架构师；系统安全工程师；隐私工程师
P-14	风险评估——系统	系统所有者；系统安全官；系统隐私官	风险管理高级问责官员或风险执行（功能）；授权官员或指定代表；任务或业务所有者；信息所有者或管理者；控制评估员
P-15	需求定义	任务或业务所有者；系统所有者；信息所有者或管理者；系统隐私官	授权官员或指定代表；系统安全官；高级机构信息安全官；高级机构隐私官；首席采购官；安全架构师；隐私架构师；企业架构师
P-16	企业架构	任务或业务所有者；企业架构师；安全架构师；隐私架构师	首席信息官；授权官员或指定代表；高级机构信息安全官；高级机构隐私官；系统所有者；信息所有者或管理者
P-17	需求分配	安全架构师；隐私架构师；系统安全官；系统隐私官	首席信息官；授权官员或指定代表；任务或业务所有者；高级机构信息安全官；高级机构隐私官；系统所有者
P-18	系统注册	系统所有者	任务或业务所有者；首席信息官；系统安全官；系统隐私官

RMF 分类步骤

任务ID	任务名称	主要责任	支持角色
C-1	系统描述	系统所有者	授权官员或指定代表；信息所有者或管理者；系统安全官；系统隐私官
C-2	安全分类	系统所有者；信息所有者或管理者	风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员或指定代表；系统安全官；系统隐私官
C-3	安全分类审查和批准	授权官员或指定代表；高级机构隐私官	风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官

RMF 选择步骤

任务ID	任务名称	主要责任	支持角色
S-1	控制选择	系统所有者；公共控制提供者	授权官员或指定代表；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官
S-2	控制定制	系统所有者；公共控制提供者	授权官员或指定代表；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官
S-3	控制分配	安全架构师；隐私架构师；系统安全官；系统隐私官	首席信息官；授权官员或指定代表；任务或业务所有者；高级机构信息安全官；高级机构隐私官；系统所有者
S-4	计划控制实施的文档	系统所有者；公共控制提供者	授权官员或指定代表；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官
S-5	持续监控策略——系统	系统所有者；公共控制提供者	风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员或指定代表；信息所有者或管理者；安全架构师；隐私架构师；系统安全工程师；隐私工程师；系统安全官；系统隐私官
S-6	计划审查和批准	授权官员或指定代表	风险管理高级问责官员或风险执行（功能）；首席信息官；首席采购官；高级机构信息安全官；高级机构隐私官

RMF 实施步骤

任务ID	任务名称	主要责任	支持角色
I-1	控制实施	系统所有者；公共控制提供者	信息所有者或管理者；安全架构师；隐私架构师；系统安全工程师；隐私工程师；系统安全官；系统隐私官；企业架构师；系统管理员
I-2	更新控制实施信息	系统所有者；公共控制提供者	信息所有者或管理者；安全架构师；隐私架构师；系统安全工程师；隐私工程师；系统安全官；系统隐私官；企业架构师；系统管理员

RMF 评估步骤

任务ID	任务名称	主要责任	支持角色
A-1	评估员选择	授权官员或指定代表	首席信息官；高级机构信息安全官；高级机构隐私官
A-2	评估计划	授权官员或指定代表；控制评估员	高级机构信息安全官；高级机构隐私官；系统所有者；公共控制提供者；信息所有者或管理者；系统安全官；系统隐私官
A-3	控制评估	控制评估员	授权官员或指定代表；系统所有者；公共控制提供者；信息所有者或管理者；高级机构信息安全官；高级机构隐私官；系统安全官；系统隐私官
A-4	评估报告	控制评估员	系统所有者；公共控制提供者；系统安全官；系统隐私官
A-5	补救行动	系统所有者；公共控制提供者；控制评估员	授权官员或指定代表；高级机构信息安全官；高级机构隐私官；风险管理高级问责官员或风险执行（功能）；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官
A-6	行动计划和里程碑	系统所有者；公共控制提供者	信息所有者或管理者；系统安全官；系统隐私官；高级机构信息安全官；高级机构隐私官；控制评估员；首席采购官

RMF 授权步骤

任务ID	任务名称	主要责任	支持角色
R-1	授权包	系统所有者；公共控制提供者；高级机构隐私官	系统安全官；系统隐私官；高级机构信息安全官；控制评估员
R-2	风险分析和确定	授权官员或指定代表	风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官
R-3	风险响应	授权官员或指定代表	风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官；系统所有者或公共控制提供者；信息所有者或管理者；系统安全工程师；隐私工程师；系统安全官；系统隐私官
R-4	授权决定	授权官员	风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员指定代表
R-5	授权报告	授权官员或指定代表	系统所有者或公共控制提供者；信息所有者或管理者；系统安全官；系统隐私官；高级机构信息安全官；高级机构隐私官

RMF 监控步骤

任务ID	任务名称	主要责任	支持角色
M-1	系统和环境变化	系统所有者或公共控制提供者；高级机构信息安全官；高级机构隐私官	风险管理高级问责官员或风险执行（功能）；授权官员或指定代表；信息所有者或管理者；系统安全官；系统隐私官
M-2	持续评估	控制评估员	授权官员或指定代表；系统所有者或公共控制提供者；信息所有者或管理者；系统安全官；系统隐私官；高级机构信息安全官；高级机构隐私官
M-3	持续风险响应	授权官员；系统所有者；公共控制提供者	风险管理高级问责官员或风险执行（功能）；高级机构隐私官；授权官员指定代表；信息所有者或管理者；系统安全官；系统隐私官；系统安全工程师；隐私工程师；安全架构师；隐私架构师
M-4	授权包更新	系统所有者；公共控制提供者	信息所有者或管理者；系统安全官；系统隐私官；高级机构隐私官；高级机构信息安全官
M-5	安全和隐私报告	系统所有者；公共控制提供者；高级机构信息安全官；高级机构隐私官	系统安全官；系统隐私官
M-6	持续授权	授权官员	风险管理高级问责官员或风险执行（功能）；首席信息官；高级机构信息安全官；高级机构隐私官；授权官员指定代表
M-7	系统处置	系统所有者	授权官员或指定代表；信息所有者或管理者；系统安全官；系统隐私官；风险管理高级问责官员或风险执行（功能）；高级机构信息安全官；高级机构隐私官

附录 F 系统和公共控制授权

授权类型

RMF 支持三种类型的授权：

1. **运营授权 (ATO)** - 授权官员给予的官方管理决定，授权操作信息系统，并明确接受对机构运营、机构资产、个人、其他组织和国家的风险。
2. **使用授权 (ATU)** - 授权官员给予的官方管理决定，授权使用信息系统、服务或应用程序，基于另一个组织生成的现有授权包中的信息。使用授权通常适用于云和共享系统、服务和应用程序。
3. **公共控制授权** - 授权官员给予的官方管理决定，授权提供可由组织系统继承的指定公共控制集。

联合授权

联合授权涉及多个授权官员。当系统支持多个组织的任务或业务功能，或系统由多个组织共享时，可能需要联合授权。在联合授权中，参与组织的授权官员共同承担接受风险的责任。

授权包内容

授权包至少包括：

- 执行摘要
- 系统安全计划
- 隐私计划（如适用）
- 安全控制评估报告
- 隐私控制评估报告（如适用）
- 行动计划和里程碑

授权决定文档

授权决定文档由授权官员签署，包括：

- 授权决定（批准或拒绝）
- 授权终止日期或持续授权频率
- 授权的条款和条件
- 风险接受声明

附录 G 授权边界考虑

确定授权边界的原则

1. **管理控制** - 授权边界内的系统元素应在相同的直接管理控制下。
2. **任务/业务功能** - 支持相同任务或业务功能的系统元素应包含在同一授权边界内。
3. **操作特征** - 具有类似操作特征和安全要求的系统元素应分组在一起。
4. **信息类型** - 处理、存储和传输类似类型信息（相同影响级别）的系统元素应在同一边界内。
5. **操作环境** - 驻留在相同或类似操作环境中的系统元素应包含在同一授权边界内。

复杂系统的边界考虑

对于复杂系统（例如，分布式系统、云系统、企业系统），授权边界的确定可能需要额外考虑：

- **地理分布** - 系统元素可能分布在多个物理位置。
- **外部提供商** - 某些系统元素可能由外部提供商管理或操作。
- **系统互连** - 系统可能与其他系统有复杂互连。
- **继承控制** - 系统可能继承来自多个来源的公共控制。

边界变更

授权边界应作为持续监控流程的一部分定期审查。当系统发生重大变化时（例如，添加新组件、更改操作环境、更改管理控制），应重新评估授权边界。

附录 H 系统生命周期考虑

SDLC 阶段与 RMF 步骤的映射

SDLC 阶段	适用的 RMF 步骤
启动/概念	准备、分类、选择
开发/采购	选择、实施、评估
实施/评估	实施、评估、授权
操作/维护	监控、持续授权
处置	监控（系统处置）

敏捷开发考虑

在敏捷开发环境中，RMF 任务可以迭代执行：

- 控制可以增量选择和实施
- 评估可以在每个冲刺或迭代期间进行
- 授权可以基于持续监控进行

DevOps 考虑

在 DevOps 环境中：

- 安全和隐私控制应整合到 CI/CD 管道中
- 自动化可用于持续评估和监控
- 持续授权是首选方法

系统处置考虑

当系统到达其生命周期结束时：

- 实施媒体清理和处置控制
- 更新系统库存
- 通知受影响的用户和利益相关者
- 审查控制继承关系
- 更新授权包以反映系统处置

免责声明

翻译说明

本中文翻译版本由机器、AI 和人工校对结合完成，旨在帮助中文读者理解 NIST 特别出版物 800-37 修订版 2 的内容。

准确性声明

1. **参考性质**：本翻译版本仅供参考之用，不应视为官方或法律认可的 NIST SP 800-37r2 版本。
2. **权威版本**：如有任何歧义、不一致或解释问题，应以 NIST 发布的官方英文原版为准。
3. **翻译误差**：尽管已尽力确保翻译的准确性和完整性，但可能存在翻译误差、遗漏或理解偏差。
4. **专业建议**：对于关键的安全和隐私决策，建议咨询专业的信息安全从业人员或参考官方文档。

版权和许可

- **原文版权**：NIST SP 800-37r2 原文由美国国家标准与技术研究院 (NIST) 发布，在美国不受版权保护。
- **翻译版本**：本中文翻译版本在原文基础上创建，遵循相同的使用条款。
- **归属要求**：使用本翻译版本时，应注明原文来源为 NIST Special Publication 800-37 Revision 2。

使用限制

1. **不提供担保**：本翻译版本按"原样"提供，不提供任何明示或暗示的担保，包括但不限于适销性、特定用途适用性和非侵权性的担保。
2. **责任限制**：在任何情况下，翻译者、分发者或相关方均不对因使用或无法使用本翻译版本而造成的任何直接、间接、附带、特殊、惩戒性或后果性损害承担责任。
3. **专业用途**：本翻译版本不应用于法规合规性声明或法律程序的唯一依据。

原文信息

- **标题**：Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy
- **出版物号**：NIST Special Publication 800-37, Revision 2
- **发布日期**：2018 年 12 月
- **发布机构**：美国国家标准与技术研究院 (National Institute of Standards and Technology)
- **官方链接**：https://doi.org/10.6028/NIST.SP.800-37r2
- **官方页面**：https://csrc.nist.gov/publications/detail/sp/800-37/rev-2/final

联系我们

如发现翻译错误或有改进建议，欢迎反馈以便持续改进本翻译版本。

本免责声明最后更新于 2026 年 3 月